

**Measuring and Mitigating Traditional Threats
Targeting Cryptocurrency Ecosystems**

A Dissertation Presented

by

Muhammad Muzammil

to

The Graduate School

in Partial Fulfillment of the

Requirements

for the degree of

Doctor of Philosophy

in

Computer Science

Stony Brook University

August 2026

Stony Brook University

The Graduate School

Muhammad Muzammil

We, the dissertation committee for the above candidate for the
Doctor of Philosophy degree, hereby recommend
acceptance of this dissertation.

Dr. Nick Nikiforakis - Dissertation Advisor
Associate Professor, Department of Computer Science

Dr. Amir Rahmati - Chairperson of Defense
Associate Professor, Department of Computer Science

Dr. Mohammad Javad Amiri
Assistant Professor, Department of Computer Science

Dr. Zane Ma
Assistant Professor, Department of Computer Science,
Oregon State University

This dissertation is accepted by the Graduate School

Celia Marshik
Dean of the Graduate School

Abstract of the Dissertation

**Measuring and Mitigating Traditional Threats Targeting
Cryptocurrency Ecosystems**

by

Muhammad Muzammil

Doctor of Philosophy

in

Computer Science

Stony Brook University

2026

Instead of interacting with the underlying blockchains directly, cryptocurrency users typically rely on an ecosystem of user-facing infrastructure and software, such as naming services, digital wallets, and decentralized applications. This ecosystem has increasingly converged on the same infrastructure and design patterns as the traditional web, and, as a result, inherits many of the same security and privacy vulnerabilities that have long affected web users. Despite this risk, the prevalence and real-world impact of these inherited vulnerabilities remain largely unmeasured, and practical defenses against them remain limited across the wallets and services that users rely on.

In this dissertation, we measure the extent to which cryptocurrency users are affected by these inherited vulnerabilities and design defenses to mitigate them where existing defenses are either limited or entirely non-existent.

We conduct multiple large-scale measurements within blockchain naming systems. First, we study typosquatting attacks, where attackers register typographic variants of popular domains to exploit user mistakes and divert funds from their intended recipients. Second, we study domain dropcatching

attacks, where adversaries register expired domains to exploit their residual trust and intercept funds intended for the previous owner. Third, motivated by the lack of wallet protections revealed by these measurements, we design and implement a set of client-side defenses against typosquatting, dropcatching, and address poisoning, and integrate them into a widely used cryptocurrency wallet. Fourth, we design and deploy **Crimson**, a distributed system that leverages certificate transparency logs to detect cryptocurrency investment scam websites in real time as they are created. Last, we conduct a systematic study showing that the DNS resolution behavior of cryptocurrency client software leaks application identity and sensitive user behavior to network observers.

Dedicated to my parents, Saman and Faizi.

Contents

List of Tables	xi
List of Figures	xiv
Acknowledgements	xix
Publications	xxiv
 Chapter	
1 Introduction	1
1.1 Thesis Statement and Contributions	3
2 Related Work	6
2.1 Address Poisoning Attacks	6
2.2 Naming Systems	7
2.2.1 Cybersquatting	9
2.2.2 Dropcatching Attacks	13
2.3 Client-Side Wallet Defenses	16
2.4 Cryptocurrency Scams	17
2.5 Threats to User Privacy	19

3	Typosquatting 3.0: Characterizing Squatting in Blockchain Naming Systems	21
3.1	Introduction	21
3.2	Blockchain Name Services (BNSs)	25
3.2.1	Ethereum Naming Service (ENS)	25
3.2.2	Unstoppable Domains (UD)	26
3.2.3	ADA Handles (ADAH)	27
3.3	Motivation and Challenges	28
3.3.1	Typosquatting 3.0	28
3.3.2	Measurement Challenges.	29
3.4	Data Collection	31
3.4.1	Collecting Names, Addresses, and Dates	31
3.4.2	Obtaining Transactions	34
3.4.3	Dataset Overview	35
3.4.4	Establishing Ground Truth	36
3.4.5	Cryptocurrency Exchange Addresses and Token Contracts	37
3.4.6	Identifying Typosquatting Domains	38
3.5	Analysis	39
3.5.1	Typosquatting Analysis	39
3.5.2	Transaction Analysis	48
3.6	Case Studies	54
3.6.1	Squatting cryptocurrency influencers	54
3.6.2	Squatting against Vitalik Buterin	58
3.7	Discussion	60
3.7.1	Limitations	61
3.7.2	Defenses and Future Work	62

3.8	Chapter Summary	65
4	Panning for gold.eth: Understanding and Analyzing ENS Domain Drop-catching	67
4.1	Introduction	67
4.2	Background and Motivation	69
4.2.1	Ethereum Name Service (ENS)	69
4.2.2	Motivation	70
4.3	Data Collection	71
4.3.1	Registrations, Renewals, and Transfers	71
4.3.2	Ethereum Transactions	73
4.4	Analysis	73
4.4.1	Re-registration Overview	74
4.4.2	Re-sale Market	77
4.4.3	Re-registered Domain Characteristics	78
4.4.4	Financial Losses	80
4.5	Discussion	87
4.5.1	Countermeasures	87
4.5.2	Limitations	87
4.5.3	Ethical Considerations	87
4.6	Chapter Summary	88
5	No Wallet for Old Tricks: Introducing Client-Side Defenses Against Cryptocurrency-Based Social Engineering Attacks	89
5.1	Introduction	89
5.2	Background	93
5.3	Threat Models	95
5.3.1	Address Poisoning	95
5.3.2	ENS Attacks	97

5.4	Attack Detection Layer	99
5.5	Detection Mechanisms	101
5.5.1	Address Poisoning Detection	101
5.5.2	ENS Attack Detection	103
5.6	Evaluation and Discussion	107
5.6.1	Runtime Performance Analysis	107
5.6.2	Testing Detection Effectiveness	108
5.6.3	Future Directions	111
5.7	Chapter Summary	112
6	The Poorest Man in Babylon: A Longitudinal Study of Cryptocurrency	
	Investment Scams	113
6.1	Introduction	113
6.2	System Design	116
6.2.1	Domain Selection and Distribution	117
6.2.2	Content-based Selection	119
6.2.3	LLM-assisted Classification	121
6.2.4	Account Creation and Wallet Extraction	124
6.3	Scam Website Analysis	126
6.3.1	Domain Name Characteristics	127
6.3.2	Clustering	127
6.3.3	Life-span	139
6.4	Estimating Financial Losses	141
6.5	Discussion	145
6.5.1	Coverage	145
6.5.2	Limitations	147
6.6	Ethical Considerations	148
6.7	Chapter Summary	148

7	New Trains, Same Rails: Fingerprinting Cryptocurrency Software via Network Requests	150
7.1	Introduction	150
7.2	DNS Observability and Threat Model	154
7.3	Application Suite	156
7.4	Experimental Setup	157
7.4.1	Browser Extensions	158
7.4.2	Desktop and Hardware Wallet Applications	160
7.4.3	Mobile Applications	162
7.4.4	Cryptocurrency Mining Firmware	163
7.5	Analysis	164
7.5.1	Fingerprintability of Cryptocurrency Client Software	164
7.5.2	User Action Identification	170
7.6	Real-World Observability	173
7.7	Chapter Summary	178
8	Discussion	180
8.1	Implications	180
8.2	Lessons Learned and Open Problems	181
8.2.1	Establishing Transaction Intent	181
8.2.2	Attributing Transactions to BNS Domains	182
8.2.3	Digital Wallet Warnings	183
8.2.4	Content-based Malicious Website Detection	184
8.2.5	DNS as a Privacy Leak	184
9	Conclusion	186
	Bibliography	188

List of Tables

3.1	Overview of the extracted domains along with the number of resolution addresses and their corresponding transactions. . . .	33
3.2	Typosquatting models and variations for <code>johndoe.eth</code>	36
3.3	Overview for legitimate-to-typosquatting name clusters	39
3.4	Examples of targets, typosquatting names, and typosquatting addresses of Type (i) typosquatting attacks (i.e. where attackers register only one typosquatting domain, and no other domains)	47
3.5	Examples of targets, typosquatting names, and typosquatting addresses of Type (ii) typosquatting attacks (i.e. where attackers register multiple domains targeting dissimilar legitimate domains)	48
3.6	Examples of targets, typosquatting names, and typosquatting addresses of Type (iii) typosquatting attacks (i.e. where attackers register >1 domains targeting similar legitimate domains)	48
3.7	Typosquatting names that had Coinbase as a common sender from <code>vitalik.eth</code> , and the funds sent to them.	59
3.8	Digital wallets used in cold/warm typos experiments	62
4.1	Comparison of lexical and transactional features of re-registered/non re-registered domains	79

4.2	Popular ENS supporting digital wallets (custodial or non-custodial) do not display a warning before a transaction is being sent to an expired/re-registered domain	82
6.1	Keyword filters used in the <i>URL-filter</i> and <i>Content-filter</i> modules	122
6.2	Performance and cost efficiency of LLMs in classifying cryptocurrency investment scam websites. The hybrid approach using GPT-4 + LLama3:70b offers a balance between performance and cost.	123
6.3	Top 5 most frequent TLDs among investment scam websites .	128
6.4	Top 10 words in investment scam domain names detected by Crimson	128
6.5	Shared IP addresses hosting multiple scam websites, along with the largest cluster sizes. Certain hosting providers are hosting large numbers of scam websites, often on the same IP address.	130
6.6	Distribution of shared IoCs among detected cryptocurrency investment scam websites. Scammers are reusing the email addresses, phone numbers, and social media handles across websites.	134
6.7	YouTube channels embedded within the HTML of detected cryptocurrency investment scam websites, along with their subscriber counts, channel titles, example video titles, and the number of scam websites that linked to each channel.	136
6.8	Instagram account usernames embedded within the HTML of detected cryptocurrency investment scam websites, along with the number of scam websites that linked to each username. . .	136
6.9	Telegram handles embedded within the HTML of detected cryptocurrency investment scam websites, along with the number of scam websites that linked to each handle.	136

6.10	Most common JavaScript library use-cases	137
6.11	Top 20 investment scam domains sorted by revenue earned through Bitcoin payments, along with their Bitcoin wallet addresses, revenue in USD, and whether they were active at the time of writing. Web browsers show no deception warnings when a user visits any of these websites. Almost all of the listed websites are active, and are still potentially receiving payments from unsuspecting users	143
6.12	Top 20 investment scam domains sorted by revenue through Ethereum payments detected by Crimson , along with their Ethereum wallet addresses, revenue in USD, and whether they were active at the time of writing.	144
6.13	Percentage of scam websites detected by Crimson that were also present in known block-lists.	146
7.1	Cryptocurrency software analyzed in this study. For each application, we report the oldest and latest versions included in our measurements, the number of tested versions, and approximate user counts when available.	153
7.2	Domain categories observed in the latest version (v7.44.0) of the MetaMask mobile application	166
7.3	Number of fingerprintable and non-fingerprintable applications under different uniqueness definitions.	169
7.4	Behavior fingerprintability across interaction groups.	171
7.5	Distribution of Web3-related domains across ASNs.	173

List of Figures

3.1	Attackers can “surround” benign Web3 domains in order to capitalize from typos. Unlike traditional domain squatting, a single typo can result in the immediate and irrevocable loss of user funds.	24
3.2	High-level view of our data collection pipeline and how our analysis interfaces with different APIs and third-party services. . .	29
3.3	Frequency of the number of typosquatting registrations against legitimate names	41
3.4	Frequency of the different misspelling strategies used by typosquatters to form spelling variations of legitimate names . .	41
3.5	Correlation between the number of typosquatting names registered each year with the price of each cryptocurrency	42
3.6	Time difference (in days) between the registration of the legitimate and typosquatting names	44
3.7	Number of unique names targeted by the same squatter (Left). Number of times a given name is targeted by a squatter (Right)	45
3.8	Number of targets vs. number of typosquatting names for Top 50 ENS attackers	47

3.9	Distributions for the number of other domains owned by typosquatting wallets (left), the average cosine similarity of typosquatting names and other domains owned by typosquatting wallets (middle), and the average cosine similarity of all domains owned by typosquatting wallets (right)	49
3.10	Frequency of the total number of victims attracted by a unique typosquatting name (left), number of common senders (victims) that have sent assets to a pair of legitimate and typosquatting name through a custodial address (middle)/non-custodial address (right)	51
3.11	Amount in USD sent to addresses of typosquatting names through the set of all senders (left), common custodial-senders (middle), and common non-custodial senders (right)	52
3.12	Distribution of time (in days) between a transaction to a legitimate name vs a transaction to a typosquatting name through a common custodial or non-custodial wallet address	53
3.13	Profile of the most popular Twitter/X user advertising his ENS domain name.	56
3.14	Distribution of the number of followers of all the collected BNS names popularized on Twitter/X	56
3.15	Frequency of the number of typosquatting registrations against legitimate names popularized on Twitter/X	57
3.16	Example of the “Cold Typos” experiment, showing the stages to sending assets to <code>treysongs.eth</code> (targeting <code>treysongz.eth</code>) through Metamask without warnings.	65
4.1	A schematic representation of our data collection, illustrating the integration of third-party APIs.	71

4.2	Total registrations, expirations, and re-registration events in ENS along the years 2020 to 2023	74
4.3	Time (in days) between ENS name expiration and re-registration by a different owner	74
4.4	Frequency of the number of times a single domain has been re-registered by a different owner after it expired	75
4.5	Number of times a unique address re-registered an expired ENS domain	75
4.6	Income in USD received by previous owners of re-registered and control domains.	78
4.7	Amount of hijackable USD sent to the corresponding wallet address of an expired ENS domain.	80
4.8	Amounts transacted (in USD) to a_2 by a common sender c . . .	80
4.9	Number of transactions sent by a common sender c to the previous owner a_1 as compared to the new owner a_2 where c is either a Coinbase or non-custodial address.	81
4.10	Number of transactions sent by a common sender c to the previous owner a_1 as compared to the new owner a_2 where c is a non-custodial address.	85
4.11	Comparison between the cost of re-registering an expired ENS domain name vs income received from common senders.	85
5.1	Illustration of an address poisoning attack.	97
5.2	Illustrations of ENS-based social engineering attacks: typosquatting (top) and domain dropcatching (bottom).	98
5.3	CDF of the total USD value lost in the address-poisoning attacks reported by Toxin Tagger [1] that are successfully detected by our MetaMask in-wallet poisoning defense.	109

6.1	A schematic representation of Crimson 's pipeline	115
6.2	Weekly count of unique scam websites discovered by Crimson .	126
6.3	Cumulative Distribution of investment scam websites over IP Addresses. A majority of scam websites are hosted on a small percentage of all IP addresses	128
6.4	Fake certificate displayed by the investment scam website alpinextrade.com on their home-page	132
6.5	Example clusters of investment scam websites, categorized by design similarities, dissimilarities, and deposit page designs. . .	133
6.6	4-dimensional Venn diagram illustrating the numbers of scam websites shared among all cluster permutations	139
6.7	Total number of transactions and US Dollars directed towards scammer-owned cryptocurrency wallets from each victim . . .	141
7.1	Experimental setup for analyzing browser extensions. Each ex- tension version is executed in an isolated Chromium instance with all outbound traffic routed through an <i>mitmproxy</i> instance for traffic interception.	158
7.2	Linux network namespace setup for isolating desktop applica- tions and capturing their outbound DNS traffic.	161
7.3	Experimental setup for analyzing cryptocurrency mining firmware. The mining device is connected to a personal router for Internet access, with a passive network tap inserted inline to mirror all outbound traffic to a monitoring host for DNS traffic capture. . .	163
7.4	Top 5 applications by number of <i>strong</i> domains comparing the number of unique <i>strong</i> domains in all versions vs. latest version.	167
7.5	Trend of number of <i>strong</i> domains across versions for selected applications, one from each category.	168

7.6	Aggregate number of customers and requests associated with domains from DNS fingerprints over time.	175
7.7	The top panel reports the number of customers resolving two or more domains belonging to the same application fingerprint within a 30-minute window, shown over the 2021 to 2025 period. The bottom panel shows the number of customers resolving the five most frequently observed hostnames in the dataset over time.	176
7.8	Number of customers resolving domains from application fingerprints spanning multiple industry categories over time. . . .	178

Acknowledgements

I am sincerely and deeply grateful to my advisor, Dr. Nick Nikiforakis, for his role in helping me achieve this milestone, and in shaping the progression of my career as a whole. Over the course of my PhD, I have learned an incredible amount from Nick, from his deep expertise in web security research and from watching how he mentors students, communicates his ideas, and carries himself within the academic community. His strong work ethic and the high standards he holds himself to have quietly set the bar for how I approach my own work. He has taught me not to shy away from ambitious ideas, and to trust that being curious and working hard would carry me the rest of the way. During my first few months as a PhD student, I often struggled to find my footing and was far from certain I would make it to the end. I am here today in no small part because of Nick's patience and his willingness to give me room to grow into the researcher I needed to become. I feel honored to have had the opportunity to work with him. I would also like to thank Dr. Amir Rahmati, Dr. Mohammad Javad Amiri, Dr. Zane Ma, and Dr. Aruna Balasubramanian for their valuable feedback on my work.

There was a time when I never imagined a PhD would be part of my future. However, I was fortunate to have met a group of people who encouraged

me from the onset, and helped me make this a reality. My first experience of academic research came through Dr. Fareed Zaffar during my undergraduate studies at LUMS. I worked with Dr. Fareed on some of his ongoing projects, through which I met his collaborators, Dr. Ashish Gehani, Dr. Hashim Sharif, and Dr. Sazzadur Rahaman. From them, I learnt a great deal about how to approach research problems, and about the academic publication process. I am thankful to Dr. Zafar Qazi and Dr. Basit Shafiq, who wrote recommendation letters for my graduate school applications. I am deeply indebted to all the teachers I have had throughout my life, in school and at LUMS. Their sincerity and dedication to their profession laid the foundation for my academic journey.

I was a summer intern at Infoblox in 2024 and 2025, where I worked on a DNS security project. This internship was instrumental in exposing me to industry approaches to web security research. I am thankful to my close friend, Zafir Ansari, for helping me secure this internship.

I am grateful to all my talented colleagues and friends at Stony Brook University who, in their own unique ways, made this experience better for me, whether through game nights, research discussions, or even a friendly water-cooler conversation. I feel impelled to mention a few of them by name: Babak Amin Azad, Brian Kondracki, Xigao Li, Johnny So, Chris Tsoukaladelis, Billy Tsouvalas, Ruining Yang, Narong Chaiwut, Benny Zheng, Syeda Mahwish, Zhengyu Wu, Abisheka Pitumpe, Doris Gutierrez, Daniyal Dar, and Sandeep Pinjala. I have spent countless hours in the lab with Sandeep, Daniyal, and Billy, talking through research and life in general. Their presence made this

experience considerably more enjoyable. I will miss our conversations, and will remember them as my first *work besties*.

This journey, and this milestone, are so much more meaningful to me because of the friends and family I got to share it with. Saeed Boorboor, Maheen Rashid, Roya Boorboor, Zainab Aamir, Sumeer Ahmad and Muhammad Farrukh have been there for me through every celebration and setback in these past years. I will remember my first few months in Stony Brook, when I felt most homesick. Saeed, Maheen, and Roya, like they always do out of their kind hearts, made their home feel like my own during this time. Being there gave me a comfort for which I will be indebted to them. I am grateful to Zainab for her constant optimism, it has very often shifted how I see things for the better. I am equally thankful to her for letting me steal chocolates from her snack drawer every now and then. To Sumeer, for being my go-to person whenever I had a question about a computer networking concept, it was so convenient having him right next door. And to Farrukh, for being up for making chai for all of us during our hangouts; I'd estimate he made hundreds of cups over the years, and for simply being the warm person that he is. I will always cherish the memories I made with them.

I have been very fortunate to have a close set of friends from high school: Abdullah Jauhar, Farrukh Masood, Roshaan Javaid, and Muhammad Nabeel. Since LUMS, I have been equally fortunate to have Noor Wali, Ali Mansoor, Salar Ahmad Rauf, Irzum bin Mansoor, Kashif Fayyaz, Umer Iqbal, Hammad Qayyum, Hamza Khalid, Muaz Ali, Faraz Karim, and Zain Ali Babar.

Whether through our WhatsApp group chats or during my visits back home, the banter with all these friends over the years has carried me through the harder days. Despite their busy schedules, they were always just a phone call away.

I am extremely thankful to Rukhshan Haroon for being a constant companion throughout this PhD. What I appreciate most about Rukhshan is how deeply he invests himself in any challenge I share with him, whether to seek advice or simply for comfort. He always treats my problems as his own, and I have always known that I can count on him to be there for me.

Even from the other side of the world, I could always feel my family's presence and support. I am deeply indebted to my grandparents: Shalla, Nasim, Afshan, and Naveed, whose warmth and unconditional love have stayed with me throughout. I want to especially acknowledge my paternal grandmother, Shalla, for her support toward my education in my early years. I am thankful to my uncles and aunts: Amna, Danish, Ghania, Safi, and Ali, who have supported me in more ways than I can count. My cousins: Ibrahim, Usama, Mustafa, Rameen, Romman, Rayyan, Anoushay, Musa, Essa, and Humna, have filled the years and every visit home with laughter and joy.

I am extremely thankful to my loving siblings, Muneeb and Juwariyah, for always loving me and being there for me. No matter what, I have always known that I could count on them, and that has been a source of strength for me. Lastly, I would like to make an attempt to thank my parents, Saman Faizi and Mohammad Faizi. Since my early childhood, they have shaped how

I value my education. I remember the day my father brought home an English dictionary for me when I was in primary school. At the time, I did not know what a dictionary was, or how to use one. He taught me how to read it, and helped me learn new words every day. My mother woke me up for school, and we often recall the mornings when, on our way to school on exam days, she would make me practice arithmetic problems on the fogged-up window. Both of my parents have worked extremely hard throughout their lives, whether in the scorching heat or in heavy monsoon rains, to fund the education I have been fortunate to receive. During my PhD, they have consistently supported me emotionally, and have always believed in me to do my best. Whatever I am, or am yet to become, is because of the love and care they have given me.

This dissertation was supported through funding by the Defense Advanced Research Projects Agency (DARPA).

Muhammad Muzammil

New York, July 2026

List of Publications

- (1) Muhammad Muzammil, Zhengyu Wu, Lalith Harisha, Brian Kondracki, and Nick Nikiforakis, “Typosquatting 3.0: Characterizing Squatting in Blockchain Naming Systems,” *Proceedings of the APWG Symposium on Electronic Crime Research (eCrime)*, 2024.
- (2) Muhammad Muzammil, Zhengyu Wu, Aruna Balasubramanian, and Nick Nikiforakis, “Panning for gold.eth: Understanding and Analyzing ENS Domain Dropcatching,” *Proceedings of the ACM Internet Measurement Conference (IMC)*, 2024.
- (3) Muhammad Muzammil, Abisheka Pitumpe, Xigao Li, and Nick Nikiforakis, “The Poorest Man in Babylon: A Longitudinal Study of Cryptocurrency Investment Scams,” *Proceedings of the ACM Web Conference (WWW)*, 2025.
- (4) Muhammad Muzammil, Harsh Shah, and Nick Nikiforakis, “No Wallet for Old Tricks: Introducing Client-side Defenses Against Cryptocurrency-based Social Engineering Attacks,” *Proceedings of the European Workshop on System Security (EuroSec)*, 2026.
- (5) Muhammad Muzammil, Oleksii Starov, Zane Ma, and Nick Nikiforakis, “New Trains, Same Rails: Fingerprinting Cryptocurrency Software via Network Requests,” *Proceedings of the IFIP Networking Conference*, 2026.

Chapter 1

Introduction

Traditionally, financial institutions have served as trusted intermediaries that facilitate electronic transactions between parties. In 2008, Satoshi Nakamoto introduced Bitcoin [2], a model that replaced the trust users place in these financial institutions with a new form of currency that runs on top of cryptographic proofs, enforced by a decentralized network rather than a central authority. This laid the foundation for what we know today as *cryptocurrency*. With these cryptographic primitives in place, cryptocurrencies allow parties to transact directly with one another without any third-party intermediary. These transactions are broadcast to and verified by a decentralized network of participants who collectively maintain the *blockchain*, which is a shared and append-only record of every transaction that has ever occurred. Every participant in this network can independently verify that a transaction is authorized by its rightful owner, and the network as a whole agrees on a single, shared history of transactions. As a result, well-established blockchains, and the cryptocurrencies built on top of them, have developed a reputation for being highly secure.

It is important to recognize, however, that the blockchain itself is merely

the underlying protocol on which cryptocurrencies run, much like the traditional Internet is the underlying infrastructure on which the modern web is built. Interacting directly with blockchain networks is inherently complex, requiring users to acquire specialized hardware and navigate unfamiliar technical protocols.

To lower this barrier to entry and fuel the growth of the ecosystem, a layer of user-facing software has been built around familiar web-based infrastructure and design patterns. This has made cryptocurrencies significantly more accessible, but in doing so, the ecosystem has also inherited many of the same security and privacy vulnerabilities that have long affected users of conventional web applications.

In contrast to the traditional web, adversaries targeting cryptocurrency users are often directly financially motivated, and the consequence of a successful attack typically results in a financial loss. Since blockchain transactions are immutable, any funds lost to an attacker cannot be recovered. Therefore, unlike fraud scenarios in traditional financial systems, where victims can often reverse a transaction or seek restitution from the institution involved, cryptocurrency users have no recourse once a transaction is confirmed on the blockchain. Moreover, as participants in a blockchain network are identified by a pseudonymous address rather than a real-world identity, adversaries can operate with a degree of anonymity that is not available in conventional financial settings.

In addition to inherited security threats that can cause financial loss,

cryptocurrency users are also exposed to privacy risks. Much of the software that users rely on to access blockchain networks is built on top of traditional Internet infrastructure, such as DNS, which can passively leak sensitive information about a user’s financial activity to third parties.

1.1 Thesis Statement and Contributions

In this dissertation, we advance this area of research in two ways. First, we measure, at scale and using real-world data, the extent to which cryptocurrency users are affected by inherited “traditional” web vulnerabilities. In doing so, we identify concrete artifacts of these threats in the wild, such as malicious domains and wallet addresses, and use them to quantify the financial losses and exposure they cause. Second, we design, implement, and evaluate practical defenses against threats that have been recognized worldwide but have not yet been mitigated in practice.

The thesis statement of this dissertation is the following: *The web-based infrastructure and design patterns used to access blockchain networks inherit security and privacy vulnerabilities from the traditional web that financially motivated adversaries can exploit. This dissertation measures the prevalence of these threats, reports and analyzes their artifacts, and presents practical defenses to mitigate them.*

In summary, we make the following contributions:

- We characterize typosquatting attacks on Blockchain Naming Systems (BNSs), where a single mistyped name guarantees the irreversible loss

of any funds sent through it. We collect 4.9 million domain names and 200 million transactions across three popular BNSs and show that typosquatters are active and growing every year, targeting both globally popular domains and those owned by popular Twitter/X users. We further show that custodial and non-custodial wallets alike offer no defenses against this threat. We present this study in Chapter 3.

- We characterize domain dropcatching in the Ethereum Name Service (ENS), where a domain re-registered after expiring can silently continue receiving funds intended for its previous owner. We curate the largest dataset of ENS domains and transactions to date, finding that a significant fraction of expired domains are re-registered by new owners and that thousands of transactions worth thousands of dollars have already been misdirected to them. We again find a complete absence of wallet-level warnings for this threat. We present this study in Chapter 4.
- We design and implement the first in-wallet defenses against address poisoning, ENS typosquatting, and ENS dropcatching by extending MetaMask, one of the most widely used cryptocurrency wallets. Our detection mechanisms warn users inline before a risky transaction is broadcasted and successfully detects real-world attacks with negligible runtime overhead. We demonstrate that the wallet-level protections found missing in Chapters 3 and 4 are practical and inexpensive to deploy. We present this system in Chapter 5.
- We characterize cryptocurrency investment scams, in which malicious

websites and social-media campaigns lure victims into depositing funds that are never returned. We build a system that detects such scams automatically and in real time using Certificate Transparency logs and large language models, identifying tens of thousands of unique scam websites and estimating tens of millions of dollars in losses over an eight-month period. We present this study in Chapter 6.

- We characterize the privacy risks introduced by cryptocurrency client software’s reliance on DNS, showing that the domains an application queries during routine use are distinctive enough to fingerprint the application, its version, and sensitive user actions. We validate this finding using global passive DNS records and enterprise network telemetry, inferring tens of thousands of real-world instances of cryptocurrency activity. We present this study in Chapter 7.

Chapter 2

Related Work

This chapter surveys the prior work most relevant to the threats studied throughout this dissertation. We describe the state of research on cryptocurrency-specific threats and situate it within the longer-studied body of traditional web security research.

2.1 Address Poisoning Attacks

Cryptocurrency addresses are typically long and complex hexanumeric strings that are hard to remember and manage. Therefore, users often rely on copy-pasting addresses from their transaction history to make further transactions with addresses they have previously transacted with. This gives adversaries the opportunity to target users with an address poisoning attack (detailed in Chapter 5).

In past work, security researchers have quantified the scale of blockchain address poisoning attacks across major public chains. Tsuchiya *et al.* [3] analyzed more than two years of Ethereum and Binance Smart Chain transaction data and identified approximately 270 million poisoning attempts targeting 17 million potential victims, with 6.6 thousand successful incidents resulting in an

estimated \$84 million in losses. Similarly, Guan and Li [4] developed *Poison Hunter* to detect poisoning attacks on Ethereum and found that adversaries disproportionately target USDC and USDT holders, which are detected by our detection mechanism in MetaMask.

2.2 Naming Systems

A naming system is a mechanism that maps human-readable identifiers to underlying resources they refer to. They allow users to interact with a system without needing to memorize or directly handle low-level resources.

Paul Mockapetris introduced DNS in 1983 to replace the centralized `hosts.txt` file used to map human-readable names to numerical IP addresses. DNS provided a hierarchical, distributed alternative that could scale with the rapidly growing Internet [5]. More recently, Blockchain BNSs first emerged with Namecoin in 2011, which forked Bitcoin’s blockchain to provide a decentralized, censorship-resistant alternative to DNS by storing name-to-resource mappings directly on-chain [6]. Since then, BNSs have evolved beyond simply replicating DNS’s name-to-IP model, with systems such as the Ethereum Name Service (ENS) mapping names not only to websites, but also to cryptocurrency wallet addresses.

Among other benefits of BNSs, they are often argued to be the remedy for address poisoning attacks [3, 4]. However, a naming system’s reliance on users to correctly recall and enter identifiers also makes it a target for adversaries who exploit user error. A large body of security research has studied this

threat, broadly known as domain squatting, in which an attacker registers an identifier similar enough to a legitimate one that an unsuspecting user mistakenly resolves it instead, landing on the attacker’s resource rather than the one they intended. A related line of research in naming system security has studied *domain dropcatching*. In this attack, an attacker re-registers a domain immediately after it expires, capturing any requests or transactions still directed toward it by users and services that are unaware its ownership has changed.

The key distinction between the cybersquatting and dropcatching attacks examined in this dissertation (Chapters 3 and 4) and their traditional DNS counterparts lies in the complexity and likelihood of successfully exploiting a victim. As we discuss in greater detail in later chapters, DNS squatting is a significantly stronger attack vector, where a single typo in a wallet application or online exchange can translate directly into the immediate and irrevocable loss of funds, without requiring an attacker to further social-engineer the victim, infect their machine with malware, or exfiltrate sensitive information. This distinction reflects a recurring theme of this dissertation, that vulnerabilities inherited from familiar, traditional-web design patterns, such as naming and resolution systems modeled on DNS, can produce more severe and unrecoverable consequences once transplanted into the cryptocurrency setting.

2.2.1 Cybersquatting

In traditional DNS, cybersquatting (registering trademarks not belonging to the registrant) and typosquatting (registering typo-variations of existing popular domains) can be traced back to the 1990s [7, 8]. Due to their popularity and level of abuse, these phenomena attracted a large body of research examining how typos are constructed, how quickly users are compromised, whether keyboard layout affects typosquatting, and how typosquatting domains are abused by their owners [9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21]. Researchers have also identified and studied other types of squatting, including *homograph domains* (malicious domains that abuse visually similar characters with their victim domains [22]), *soundsquatting* (malicious domains that sound like popular domains [23, 24]), *bitsquatting* (malicious domains that are one-bit-flip variations of popular domains [25, 26]), and *combosquatting* (malicious domains that include popular trademarks [27, 28]).

Wang et al. introduced Strider Typo-Patrol in 2006 [29], one of the earliest systematic studies of DNS typosquatting. Rather than relying on individual, manually investigated cases, the authors built an automated system to scan typo variations of popular domains at scale and analyze the third-party advertising infrastructure behind them. Their analysis revealed that typosquatting was not a scattered or marginal practice but a concentrated, profit-driven business, where a handful of domain parking services were responsible for serving advertisements on the majority of active typo domains, and a single large-scale typosquatter alone owned a substantial share of all

typo domains they discovered, including many that redirected traffic from children’s websites to ads of an adult nature.

In 2015, Agten et al. [12] performed a longitudinal study of the typosquatting attacks on the 500 most popular domains. Prior to this, Banerjee et al. [14], Moore et al. [15], Szurdi et al. [11], and Wang et al. [29] had worked on identifying domains that are targeted most, and characterized the preferred monetization strategies of typosquatters. However, these studies only focused on characterizing typosquatting activity in a single snapshot of time and focused on domain registration data only. Contrastingly, this paper presented the first study that studied the typosquatting phenomenon in a longitudinal fashion, and also focused on monitoring the content of typosquatting domains over a period of 7 months.

The works highlighted above indicate how cybersquatting research has heavily relied on DNS domain name lists ranked by popularity, such as the Alexa [30] and Tranco [31] lists, to identify likely targets. These rankings are often derived, at least in part, from DNS resolution data; for example, the Tranco list aggregates several ranking sources, including Cloudflare Radar, which ranks domains using DNS traffic to its 1.1.1.1 resolver, and Farsight’s passive DNS dataset, both of which capture how frequently a domain is resolved and therefore serve as a proxy for its real-world usage [31]. However, no such resolution data exists in the BNS space. While on-chain activity such as registrations and transfers is publicly visible, this only reflects how a name was administratively used, not how often it was actually queried or relied upon by

users and applications. This lack of a reliable, usage-based popularity signal has shaped how prior work on BNS naming has approached the problem of identifying which names to consider as likely targets for squatting.

Kalodner et al. [32] were the first to systematically study blockchain naming systems. They focus their study on Namecoin, a fork of Bitcoin that supports the storage of arbitrary name-value pairs on its blockchain, a feature used to implement the ‘.bit’ TLD, in which domain names resolve to IP addresses on the traditional web. Their goal was to assess the health and adoption of Namecoin by distinguishing active, in-use domains from those held purely for speculation. To do so, the authors infer ownership and intent from the domain’s value itself. Since squatters advertising names for sale tend to reuse the same contact information across every domain they hold, large clusters of speculatively-held names can be identified by finding domains that share a value. Using this method, they find that at least 76% of .bit domains are held by squatters, and that of the roughly 196,000 registered names, only 28 served unique, non-trivial content not also reachable through a conventional domain, suggesting that the namespace saw almost no genuine adoption. This method was necessary in the absence of any usage data, such as a popularity ranking, that could otherwise have been used to distinguish active domains from speculative ones.

Later work facing the same lack of a native popularity signal has instead relied on external, DNS-derived rankings as a proxy. Xia et al. [33] presented a systematic analysis of ENS, a widely known BNS, measuring its growth

and the different types of attackers it has attracted. Lacking a popularity ranking for ENS names, the authors identify likely squatting targets using a manually curated list of known trademarks, evaluating the extent to which attackers squat on popular domains and trademarks that do not belong to them (e.g., `google.eth` and `facebook.eth`). This is an instance of *inter-system* squatting, in which attackers target the reputation of an entity from outside the naming system itself. As we discuss in Chapter 3, the threat models behind this type of squatting are distinctly different from the ones we explore later in this dissertation, with attackers hosting malware or intending to sell the squatting domains back to their original trademark holders, as opposed to monetizing typos occurring during the exchange of funds.

Beyond squatting, several studies have been conducted on the security concerns revolving around BNS [34, 35, 36, 37, 38, 39, 40, 41, 42, 43, 44, 45] and digital wallets [46, 47, 48, 49, 50, 51, 52]. Ito et al. [41] studied TLD name collisions, in which the same top-level domain string is independently registered across multiple, competing BNS platforms. Because no equivalent to ICANN exists to arbitrate ownership of a TLD across chains, the same name can resolve to different IP addresses or different wallet addresses depending on which BNS resolver a user happens to query, leading to communication failures or, more critically, the misdirection of funds to an unintended address.

2.2.2 Dropcatching Attacks

The risks of re-registered domains and residual trust have attracted substantial research attention [53, 54, 55, 56, 57, 58, 59, 60, 61, 62, 63, 64, 65, 66, 67, 68, 69, 70, 71, 72, 73]. In general, these works start from a specific class of domains or systems already known or suspected of interest to adversaries, and then investigate how their re-registration could be exploited.

Nikiforakis et al. [61] started from domains linked through remote JavaScript inclusions and demonstrated that their expiration and re-registration enable adversaries to launch code-injection attacks against the websites that still reference them. Moore and Clayton [59] focused specifically on domains previously used by U.S. banks that had shut down or merged, finding that 33% of these expired domains were re-registered by malicious actors.

Lever et al. [60] similarly began from domains already known to be malicious, those previously listed on public blacklists or resolved by malware, and introduced residual trust as a unifying concept underlying several seemingly distinct security problems. Examining domains that expired between 2009 and 2015, they found 27,758 blacklisted domains and 238,279 malware-resolved domains that were subsequently re-registered. In 2018, Miramirkhani et al. [74] presented a longitudinal study of dropcatching in the *.com*, *.net*, and *.org* TLDs, tracking re-registrations over a period of eight months. They find that no less than 75K domains drop every day, and that the median percentage of domains that get re-registered on the first day after expiration is 11%. Interestingly, they find that domains that were malicious before their

expiration were re-registered twice as often as domains that were previously benign.

However, in 2022, So et al. [53] departed from this targeted approach by re-registering 201 expired domains without any specific target in mind. They demonstrated that even an opportunistic, target-agnostic attacker can stumble upon high-value residual trust, including domains previously used as a university lab-usage tracking API, an Android library backend, and security-vendor DNS sinkholes. In follow-up work [75], they showed that expired domains can persist in Android application logic, creating opportunities for abuse until developers update their apps.

Beyond the risks posed by re-registration itself, several works in the security community have also examined the intent behind domain registrations more broadly by analyzing DNS lookup patterns, particularly which networks perform the earliest lookups to a given domain. Hao et al. [76] analyzed the early DNS activity of newly registered domains, showing how the observable behavior of malicious domains differs from that of legitimate ones. Halvorson et al. [58, 57, 77] later studied the registration patterns of more than 500 new TLDs introduced by ICANN to investigate the intent behind domains registered within each one.

Within the context of BNS, Xia et al. [33] systematically study ENS, describing its growth along with the different types of attacks the domains can be vulnerable to. They were the first to point out a security vulnerability stemming from the fact that the resolution records of ENS domains are

kept even after expiration, and that digital wallets can keep resolving these domains to their corresponding wallet addresses. As a result, expiration and re-registration events can easily go unnoticed, resulting in new owners of such domains being able to intercept cryptocurrency transactions intended for the previous owner.

Thottungal Valapu *et al.* [78] reported that many systems link a DNS domain to an external resource, such as a wallet address, but never check whether that domain’s ownership has since changed. ENS exhibits this pattern through its DNS import feature [79], which lets a user link a domain they already own, such as a `.com`, directly to an Ethereum wallet address, so that others can send them cryptocurrency using a familiar domain name instead of a long wallet address. Crucially, this link is established once, by submitting an on-chain transaction that proves DNS ownership at that moment in time (using DNSSEC); ENS does not automatically re-verify this ownership afterward. If the underlying DNS domain is later allowed to expire and is re-registered by a different party, the original wallet address mapping persists on-chain and continues to resolve, unless someone manually triggers a resync. The authors term this resulting stale mapping a *zombie linkage*. Studying ENS alongside two other DNS-linked systems, they find that zombie linkages are common and, in ENS’s case, never get cleared once created, leaving them available for an attacker to exploit indefinitely.

In Chapter 4 of this dissertation, we build on the observation by Xia *et al.* [33] and present a large-scale measurement study of dropcatching in ENS,

reporting on re-registration patterns, attacker behavior, and cases of financial loss resulting from this attack vector.

2.3 Client-Side Wallet Defenses

The literature discussed above shows that cryptocurrency users are exposed to social engineering attacks that allow attackers to redirect funds intended for a legitimate recipient. In all such cases, the digital wallet is the user’s final point of contact before a transaction is irreversibly broadcast to the blockchain, making it the natural place to intervene and warn a user before they fall victim to an attack. However, prior work indicates that cryptocurrency wallets are ill-equipped to play this role, both due to limitations in their design and due to widespread misunderstandings that users hold about how these wallets, and the security mechanisms within them, actually function.

At the time of writing, no cryptocurrency wallet currently protects its users with context-aware defenses against social engineering attacks. Guan and Li [80] evaluated 53 cryptocurrency wallets and found that only three displayed warnings for malicious addresses. None of the wallets recognized the defining characteristics of address poisoning, such as one-sided dust transfers from lookalike addresses, nor did they provide interface cues that help users distinguish suspicious inbound transfers or verify intended recipients. Moreover, multiple studies of how users interact with cryptocurrency wallets have concluded that the average cryptocurrency wallet user routinely underestimates or is unaware of the security risks involved in managing digital

assets [81, 82, 83, 84, 85, 86, 87, 88]. Users frequently hold incorrect mental models about how security mechanisms in wallets operate, such as how private keys are generated or secured, and how transactions should be verified. These misunderstandings ultimately manifest as a range of unsafe behaviors. These research efforts motivate the need to develop features within cryptocurrency wallets that make it easier for novice (and even experienced) cryptocurrency users to protect themselves from social engineering attacks.

2.4 Cryptocurrency Scams

Online scams that rely on social engineering rather than technical exploitation are a long-standing and well-studied problem on the web, predating the rise of cryptocurrency by more than a decade. Miramirkhani et al. [89] conducted the first large-scale study of technical support scams, in which victims are convinced their machine is infected with malware and are coerced into paying for unnecessary remote technical support. The authors found that scammers operating out of organized call centers were able to make millions of dollars from a comparatively small fraction of their overall victim base.

Prior to the work presented in Chapter 6, studies on cryptocurrency investment scam websites relied on links collected through social media and online forums [90, 91, 92]. Atondo Siu and Hutchings [90] trained machine learning classifiers to identify investment scam advertisements posted on Bitcointalk and Reddit, finding that roughly five percent of posts on both platforms promote such schemes. Li et al. [93] similarly studied scam advertise-

ments embedded in YouTube comments, where scammers impersonate channel owners or pose as financial advisors to solicit contact from viewers; by directly engaging with scammers identified through this method, they estimate that the scammers in their dataset alone stole the equivalent of over 100 million US dollars, predominantly through cryptocurrency payments.

A related and more extensively studied category of cryptocurrency investment scam is the Ponzi scheme, in which scammers repay earlier investors using funds from newer investors rather than legitimate profits. These schemes can occur across various platforms, including conventional websites, Ethereum smart contracts, social media, and play-to-earn games. They have been studied extensively on blockchain platforms such as Ethereum and Bitcoin, where researchers analyze smart contract code and transaction patterns to uncover their structure and operation [94, 95, 96, 97, 98]. Bartoletti et al. [95], for instance, conducted a comprehensive survey of “smart” Ponzi schemes on Ethereum, examining how these schemes leverage smart contracts to automate their fraudulent processes. Unlike this body of work, which largely relies on the structure of on-chain contracts or previously curated link lists, Chapter 6 presents the first system built to detect cryptocurrency investment scam websites in real time, immediately upon their creation.

The closest prior work to our own is by Li et al. [99], who developed CryptoScamTracker to identify cryptocurrency giveaway scams [100, 101], in which scammers deceive victims by promising to return a multiplied amount of cryptocurrency if they first send a small amount to a provided wallet, often posing

as a donation drive or falsely advertising a giveaway endorsed by a public figure. Comparing our results in Chapter 6 to theirs, we find that investment scams are considerably more widespread, with approximately 8.5 times more scam websites detected overall. We further find that investment scam websites remain active for longer durations and are responsible for substantially larger financial losses, a pattern also reported by government agencies [102, 103].

2.5 Threats to User Privacy

Prior research has shown that user activity on the web can be inferred through tracking mechanisms embedded in websites and third-party services, enabling the collection and correlation of sensitive information across browsing sessions [104]. Torres et al. [46] and Winter et al. [105] show that decentralized finance (DeFi) applications inherit these risks once cryptocurrency functionality is exposed through browser-based front ends, demonstrating that wallet extensions and DeFi interfaces integrate with the existing web-tracking ecosystem and may leak sensitive information, such as wallet addresses, to third parties. Both works assume a threat model in which privacy loss arises from interactions with websites or embedded third-party scripts. In contrast, Chapter 7 shows that cryptocurrency-related activity can be inferred without any web-based tracking at all: DNS resolution activity generated by cryptocurrency client software itself reveals application identity and behavior, due to its reliance on application-specific Internet infrastructure.

DNS has been widely used as a signal for security monitoring [106, 107,

108, 109, 110, 111]. For example, prior work has shown that DNS can reveal connections to command-and-control infrastructure via domain generation algorithms [112, 113], and can be used to fingerprint IoT devices based on their DNS behavior [114]. To the best of our knowledge, we are the first to show that DNS visibility alone is sufficient to attribute cryptocurrency application identity and version.

A separate line of work has shown that application usage can be inferred from encrypted network traffic by analyzing packet-level metadata such as packet sizes and timing, with applications to mobile app identification [115], VPN detection [116], and cryptomining activity [117]. These approaches rely on probabilistic classification over traffic features collected at the packet level. In contrast, our approach requires only DNS visibility, a coarser and far more commonly logged signal, to directly attribute cryptocurrency application identity and version through its underlying DNS dependencies.

Chapter 3

Typosquatting 3.0: Characterizing Squatting in Blockchain Naming Systems

3.1 Introduction

Since the inception of Bitcoin, there has been increased interest in the concept of cryptocurrencies, the blockchains supporting them, and the applications that they enable. Many view the distributed, trustless nature of cryptocurrencies as a welcome alternative to the increased centralization of power and control [118]. In the context of payments, cryptocurrencies offer willing parties the ability to exchange funds without the need for trusted middlemen that can arbitrarily limit transactions. In the context of the web, the so-called “second-generation” blockchains such as Ethereum promise to bring about the next iteration of the web (i.e. Web3 or Web 3.0) [119, 120]. This decentralized web allows the deployment of application logic on public blockchains where it can be vetted, ownership of digital assets that are decoupled from any specific third-party service, and the ability of users to manage their own identity by authenticating themselves using their own private keys.

Given that this concept of identity is critical in cryptocurrencies, re-

searchers and developers soon discovered the need to build layers of abstraction on top of the public-key addresses corresponding to each user’s wallet. To avoid reintroducing centralization, Blockchain Naming Systems were developed that not only enable the binding of user-friendly strings to wallet addresses (such as `vitalik.eth` to `0xd8dA6BF269[...]15D37aA96045`) but store the resolution data on blockchains where only their owner can modify them. Today, modern BNSs not only allow the easier exchange of funds between users but also enable other use cases, such as pointing to web content stored on distributed file-storage networks (e.g. on the InterPlanetary File System [121]), resulting in censorship-resistant web applications.

Security researchers have already started studying these new BNS systems, devising threat models and documenting existing types of abuse [122, 33, 123, 32, 38, 124, 41]. These include hoarding domains for speculation purposes, using takedown-resistant BNS names in the context of malware, domain dropcatching, and squatting trademarks and domains from the traditional web (e.g. attackers owning `google.eth`).

In this paper, we perform the first analysis of *intra-service* typosquatting on popular Blockchain Naming Systems. Instead of looking for which trademarks and domains from the traditional web are being squatted in these BNSs, we focus on attackers registering typo variations of other popular names on the same BNS. This threat model takes into account one of the original uses of BNSs (the exchange of funds between users) and highlights the disproportionate effects of a typo in a BNS, compared to typos in DNS. Whereas

a typo in a DNS resolution may require additional social engineering, hosting phishing sites, the downloading of malware, and the exfiltration of sensitive user data, a single BNS typo in the context of a cryptocurrency transaction *guarantees* the loss of user funds. As Figure 3.1 shows, all that attackers need to do is register typosquatting variations of popular BNS domains and receive the accidental transactions sent by victim users.

We focus our work on three popular BNSs, namely the Ethereum Name Service (ENS), Unstoppable Domains (UD), and ADA Handles (ADAH). ENS and UD are built on Ethereum (with UD also supporting the minting of domains on Polygon), whereas ADAH is built on top of Cardano. We build a corpus of 4.9 million domain names registered across these BNSs and study the levels of intra-BNS squatting activity, using transaction volume as a proxy for domain popularity. We find tens of thousands of squatting domains across the studied BNSs, targeting as many as 37% of the most popular legitimate domains. We find that BNS users rarely register typosquatting variations of their own domains, which could route funds mistakenly sent through a typosquatting domain to their own wallet. We report on the makeup of the identified typosquatting domains and show that typosquatting registrations increase year over year, with most squatting domains being registered within 100 days of the legitimate domains they target.

Next to the domains themselves, we take advantage of the public nature of the three underlying blockchains to understand to what extent attackers have been successful in stealing funds from unsuspecting users. We find thou-

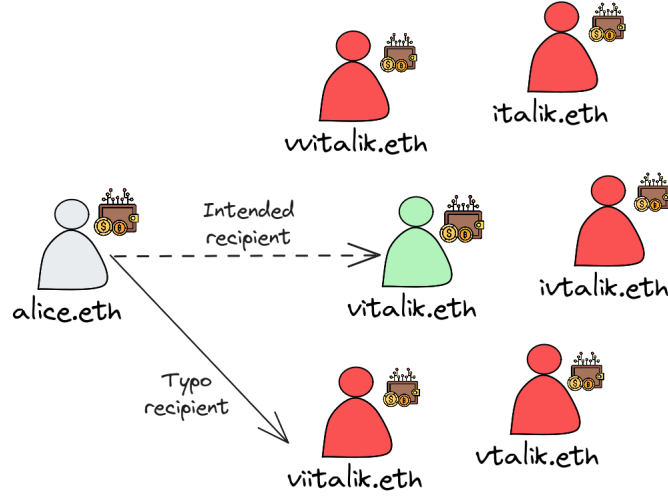


Figure 3.1: Attackers can “surround” benign Web3 domains in order to capitalize from typos. Unlike traditional domain squatting, a single typo can result in the immediate and irrevocable loss of user funds.

sands of instances where a sender has sent funds to both a legitimate domain and a typo-variation of that same domain, with an average transaction sending \$1,790 to scammers. We confirm the typosquatting phenomenon by focusing on popular cryptocurrency “influencers” on Twitter/X and characterize the 74 typosquatting domains targeting the inventor of Ethereum. Lastly, we assess the countermeasures in popular custodial and non-custodial wallets observing a *complete* lack of defenses against typosquatting.

Availability: To encourage more research in the area of BNS security, our dataset of BNS domains, and scripts to collect blockchain transactions are available here [125].

3.2 Blockchain Name Services (BNSs)

The fundamental concept of BNSs (resolving human-readable domains to addresses) is borrowed from the traditional Domain Name System (DNS). However, there are significant differences between the two. Central authorities like ICANN have control over DNS whereas BNSs are decentralized naming systems that operate on a blockchain network without a single point of control or failure. Moreover, BNS names can be censorship-resistant in that third parties cannot arbitrarily change the resolution address of a BNS domain name.

3.2.1 Ethereum Naming Service (ENS)

ENS [126] is one of the earliest and the most popular BNS, launched in May 2017. It is a decentralized naming system that, at its core, is a collection of smart contracts deployed on the Ethereum blockchain, which uses an account-based transaction model. Smart contracts are self-executing digital contracts with the terms of the agreement directly written into the code. They allow for transactions to occur on the blockchain ensuring anonymity and requiring no form of trust between the sender and the receiver. For example, the Registry contract in ENS maintains a list of all domains and subdomains, keeping track of the owners and resolvers for each domain. Resolvers are also smart contracts that respond to queries about a provided domain name, such as returning the wallet address a domain resolves to. Usually, names use the public resolver deployed by ENS, but users may develop and use their resolvers tailored to their needs. An ENS name is an NFT tied with three main entities: registrant,

owner, and controller. The owner of the name is the one who can change a resolver, expiry date, create or reassign subdomains, or transfer the name to another address, after which the name will change ownership to the new address. The controller may edit the records of a name. The registrant is the owner of a registration [127]. ENS makes use of a dot-separated hierarchical architecture for its names; names and subdomains registered on it have the extension `.eth`, as in `johndoe.eth` and `funds.johndoe.eth` respectively. A user can register an ENS domain for a certain period after which it will expire unless renewed.

3.2.2 Unstoppable Domains (UD)

UD [128] is a BNS built on the Ethereum and Polygon blockchains, both following an account-based transaction model. Similar to ENS names, UD names are also NFTs controlled by an “Owner” and an “Operator” (known as “Controller” in ENS). Both ENS and UD provide the functionality of holding a variety of records including cryptocurrency addresses, IPFS hashes, and various text records such as URLs, email, and social-media handles. It is important to note that they can be mapped to addresses for more than one cryptocurrency at a time, allowing users to receive payments in different cryptocurrencies using the same domain name. Some users (either speculators or users/developers who have not yet decided how to use their domain names) may opt not to add any resolution records to their domain names. Unlike ENS, once registered, UD domains do not expire (they can always be sold by

their owners to other users). At the time of this writing, UD supports more than ten different TLDs including `.crypto`, `.nft`, and `.blockchain`.

3.2.3 ADA Handles (ADAH)

ADAH [129], based on the Cardano blockchain, follows a UTXO-based transaction model. Unlike the previously described BNSs, ADAH do not use smart contracts for their operations. Rather, they are stored natively on the Cardano blockchain that supports tokens without the need for smart contracts. This approach circumvents potential issues affecting smart-contract-based BNSs, such as, the need to migrate names to a new smart contract after locating a bug in the current smart contract. ADA Handles are NFTs, and like any other NFT follows a specific minting policy, which is a predefined set of rules governing their creation, distribution, and management. The creators of ADAH publicize the Policy ID they use for this project. An ADA Handle resides inside a wallet address of a user, and payments directed to any handle will be routed to the wallet address in which they reside. Like UD domains, ADAH do not expire and can be owned indefinitely by a user until sold. The use of ADA Handles is growing [130] but, being a relatively new naming system on a less popular blockchain, the absolute number of registered domains is smaller than the previous two BNSs. ADA Handles also depart from the traditional hierarchical naming of domain names, instead prepending domains with a dollar sign (e.g. `$johndoe`).

3.3 Motivation and Challenges

In this section, we introduce the idea and importance of studying typosquatting in BNSs along with similarities and differences with typosquatting in traditional DNS.

3.3.1 Typosquatting 3.0

A traditional typosquatting attack in DNS targets users who mistype a domain name in the URL fields of their browsers. In doing so, they give the opportunity to attackers to control the IP address of that resolution and monetize the user’s mistake. That monetization typically comes from redirecting users to phishing sites, affiliate-abuse scams, exploit kits, and social-engineering-based attacks. The attacker has to typically convince the user to either provide sensitive information to the landing page (e.g. for phishing sites and survey scams) or willingly accept the download of malware. Even in the worst-case of a resulting malware infection, attackers still need to somehow monetize the infection, either by exfiltrating sensitive data which they can then sell, or relying on ransomware and botnet activities. In short, a typosquatting attack in traditional DNS *may* result in loss of funds, with users having multiple chances to stop the attack before that happens. Even in rarer forms of typosquatting (e.g. users mistyping a recipient’s email address) there are still no guarantees that the missent email will contain any sensitive information.

Contrastingly, when a user is trying to send cryptocurrency funds to another user and mistypes the latter’s BNS domain name (depicted in Fig-

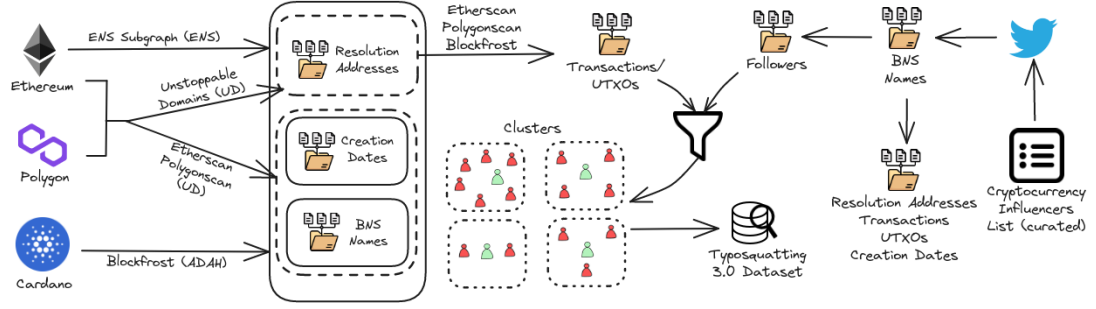


Figure 3.2: High-level view of our data collection pipeline and how our analysis interfaces with different APIs and third-party services.

ure 3.1), the loss of funds is direct, immediate, and irrevocable. All that attackers need to do is register typo-variations of popular BNS domains and resolve these domains to their own wallet addresses. There is no need to serve phishing sites, host malware, or in any way try to further engage with victims.

3.3.2 Measurement Challenges.

Traditional domain squatting has been extensively studied in past research [27, 11, 12, 25, 14, 13, 15]. It is therefore tempting to assume that all prior methods used by researchers are applicable to studying squatting in BNSs. We argue that effectively studying squatting in BNSs is, in fact, more complicated than studying traditional DNS-based domain squatting for the following reasons:

3.3.2.1 Non-availability of ground truth.

Every domain-squatting study starts with identifying a list of potential targets for attackers. In past studies, given that typosquatting abuse always

occurred in the context of navigating the web, popularity of websites was used as a proxy for popularity of domain names. This typically means selecting the domain names of the most popular websites (e.g. top Alexa [30] or top Tranco [31]) and mutating them to arrive at possible squatting domains. In BNSs however, domain names are predominantly used in receiving payments with most domain names merely pointing to the wallet address of their owners. As such, looking just at on-chain data related to these domain names, there is no clear way to differentiate popular domains (i.e. domains that squatters are likely to target) from unpopular ones.

3.3.2.2 Aliasing of domains to wallets.

Without external sources that can inform the design of a popularity metric for BNS domain names, one reasonable on-chain source of data are transactions. That is, all else being equal, if $addr_1$ has received more incoming transactions than $addr_2$, then it is reasonable to assume that $domain_1$ (i.e. the domain which resolves to that address) is more popular than $domain_2$. The issue with this metric is that it cannot account for multiple domain names resolving to the same wallet address. If $domain_a$ and $domain_b$ both resolve to $addr_1$, there is no on-chain data to conclude which of the two domains is responsible for the most transactions to $addr_1$.

One objective source of off-chain resolution data are software wallets responsible for conducting BNS resolutions. Despite reaching out to multiple wallet vendors with millions of users, those that responded to us informed

us that they do not log resolution data and in turn rely on larger platforms for resolutions (e.g. MetaMask relies on Infura for resolutions [46]). At the time of this writing, we have not been able to get into contact with these larger platforms and hence must devise our own popularity metrics relying on publicly available on-chain data for the majority of our analysis.

3.4 Data Collection

This section describes our data-collection and analysis methodology (shown in Figure 3.2) and presents an overview of the datasets used in this work.

3.4.1 Collecting Names, Addresses, and Dates

Given the public nature of the blockchains supporting the evaluated BNSs, all registration/domain-management events are scattered throughout different blockchain blocks. Because of the volume of data available in these chains and the impracticality of linearly searching all these blocks, various third parties (known as ingestion services) mine these blockchains and extract data and insights which they then make available through blockchain explorers. These blockchain explorers can then be used either manually or programmatically via traditional web APIs. As much as possible, we rely on these APIs to obtain the BNS domain names, on which the rest of our analysis is built.

3.4.1.1 Ethereum Name Service (ENS)

Past work analyzing ENS has shown how difficult it is to extract a complete list of registered ENS domain names directly from the Ethereum blockchain (with or without the use of third-party blockchain explorers) [33]. This is mostly due to the use of the *namehash* algorithm, allowing ENS to store domains of all lengths as fixed-length (256 bit) cryptographic hashes. Depending on the smart contract mined by researchers, the extraction can be as straightforward as locating the actual domain name in the payload data of a domain-registration event, or as complicated as constructing hashes following the namehash algorithm and then comparing these hashes against the ones controlled by the smart contract.

In 2020, Ethereum developers released “The Graph” a decentralized indexing protocol for organizing blockchain data and making that data accessible using GraphQL (a data-query and data-manipulation language used in APIs) [131]. Different organizations can run different “subgraphs” for indexing different blockchain data. ENS supports its own subgraph [132] which sources events from relevant ENS contracts. In this paper, we leverage this resource to extract ENS domain names, resulting in a dataset that is *significantly* larger than the one that prior work was able to extract directly from the Ethereum blockchain.

BNS	# Names Collected	# Resolvable Names	# Resolution Addresses	# Transactions Collected
ENS	3,047,188	2,214,012	699,548	140,183,178
UD	1,707,017	1,156,697	393,290	44,819,348
ADAH	198,121	198,121	64,612	15,487,746
<i>Total</i>	<i>4,962,326</i>	<i>3,568,830</i>	<i>1,157,450</i>	<i>200,490,272</i>

Table 3.1: Overview of the extracted domains along with the number of resolution addresses and their corresponding transactions.

3.4.1.2 Unstoppable Domains (UD)

Due to the lack of a GraphQL endpoint for UD, we adopt an alternative strategy to harvest names. Third parties take advantage of the public nature of popular blockchains to index them, and offer access to their indices via blockchain explorers, such as, Etherscan [133] and Polygonscan [134]. UD names, unlike ENS names, are minted on two different blockchains: Ethereum and Polygon. Etherscan and Polygonscan facilitate data retrieval from these respective blockchains, allowing us to query the relevant smart contracts. We focus on querying the smart contracts listed by UD for both Ethereum and Polygon. UD lists separate registry addresses for Ethereum and Polygon minted names, which we utilize to crawl domain names using Etherscan and Polygonscan respectively. Additionally, we leverage another registry smart contract listed on Etherscan that contains a substantial amount of UD names with the `.crypto` TLD, all minted on the Ethereum blockchain. Using the two block explorers, we query each event log on every block that involved the use of the three mentioned smart contracts. As with any blockchain transaction, the registration of a UD name will also appear as an event log, and will contain the name itself as an argument to the smart contract function. We supplement this data with additional data from the API offered by Unstoppable Domains

itself [135] to extract the resolution addresses of each domain name.

3.4.1.3 ADA Handles (ADAH)

To collect ADAH data, we make use of the Blockfrost API [136], an open-source API project that aids in accessing and processing information on the Cardano blockchain, such as addresses, blocks, assets, and transactions. Using the publicly available policy ID for ADAH, we use the “asset” endpoint of the Blockfrost API (used to query information regarding NFTs) to collect ADA Handles minted on-chain along with their creation dates and the wallet addresses in which they are located.

3.4.2 Obtaining Transactions

For both ENS and UD, we use Etherscan APIs to collect transactions on the Ethereum blockchain. We provide all the Polygon and Ethereum resolution addresses as inputs to the API calls, upon which they output both incoming and outgoing transactions that each particular resolution address was involved in. Each transaction contains a sender address, receiver address, amount of ETH sent, the transaction hash, and the timestamp. For UD minted on the Polygon blockchain, we use Polygonscan APIs which is queried exactly as the Etherscan APIs. To collect transactions for ADAH, we use the Blockfrost API to first collect the transaction hashes for each Cardano address in our dataset in which at least one ADA handle resides. For each identified transaction hash, we then collect all associated UTXOs. In the case where we have multiple

input addresses in a UTXO for one output address, we count the number of transactions as the number of input addresses and the value as the amount that goes into the output address divided by the number of input addresses.

3.4.3 Dataset Overview

Table 3.1 provides a summary of the number of domain names that we collected for each BNS along with the total number of resolution addresses (i.e. the domain names can be resolved to wallet addresses by the BNS) and transactions. We also report the number of names that have a resolution address. Drawing parallels with traditional DNS, a domain name may be absent from the zone records of an authoritative server for a specific TLD (i.e. it cannot be resolved to an IP address) but it is owned by someone and unavailable for registration. We note how many ENS names have an “ETH” resolution address set and how many UD names have an “ETH” or a “MATIC” address set. Since ADAH resolution addresses are the addresses of the wallets that they reside in, all ADAH had resolution addresses.

We use the described data collection methodology to collect the largest dataset for BNSs to date. We obtained 97% ENS names from the ENS Subgraph with only 96,667 returning empty API responses. Because of our use of the Subgraph (as opposed to trying to identify ENS domain names through blockchain explorers), we manage to collect 23% more `.eth` names than Xia et al. [33] until block 13,170,000, which was the cut off for their data collection. Due to API call failures for resolving UD, we were not able to collect

Model	Variation
<i>Duplication</i>	jjohndoe.eth
<i>Addition</i>	johndoew.eth
<i>Removal</i>	johndo.eth
<i>Swapping</i>	johnode.eth
<i>Substitution</i>	nohndoe.eth
<i>Hyphenation</i>	john-doe.eth
<i>Pluralization</i>	johndoes.eth

Table 3.2: Typosquatting models and variations for *johndoe.eth*

resolution address records for approximately 10K UD registered names, which means that we managed to collect over 99% of UD names that have ever been registered, with 100% recovery rate for ADAH.

Overall, we were able to collect almost 5 million domain names registered across the three evaluated BNSs which we analyze in the rest of this paper.

3.4.4 Establishing Ground Truth

To investigate the prevalence of typosquatting activity using our datasets, it is important to first identify the legitimate names that attackers are likely to be targeting. However, as discussed in Section 3.3, establishing this ground truth for BNS names is non-trivial because of the unique aspects of BNS domain names, compared to traditional DNS domain names.

We rely on two heuristics to establish ground truth (i.e. a set of legitimate domains that attackers are likely to target via squatting): i) we assume that a resolution address with a significant volume of transactions is owned by a benign user (or at least a user that attackers will target), and ii) a large number of domain names all pointing to the same resolution address constitutes

suspicious behavior, suggesting either domain speculators, or squatters who are expecting to capitalize typos when resolving BNS domain names. By combining these two heuristics, we can classify all resolution addresses using the following formula: w_T/w_D , where w_T represents the number of transactions linked to each domain’s resolved wallet address, and w_D denotes the number of domain names it is linked to. Note that this sorting is based on the transactions of the cryptocurrency resolution address, and not the owner address. Our metric allows us to prioritize the analysis of popular domain names (using the number of transactions as a proxy for their popularity) while penalizing wallets that contain multiple domain names (by uniformly distributing the total number of transactions of that address to all N domains).

3.4.5 Cryptocurrency Exchange Addresses and Token Contracts

Through our analysis of the sorted domain names, we discovered a number of BNS names that point to the known wallets of central cryptocurrency exchanges (like Coinbase). Given the popularity of these wallets and their volume of transactions, these domain names ranked near the top of our list. Yet, we can clearly infer that the popularity of these wallet addresses has little to do with the domain names (whether these domain names are managed by the exchanges themselves, or by ENS users who misconfigured their resolution settings is outside the scope of this work). Similarly, we located a number of domain names that resolved to addresses of token contracts as opposed to reg-

ular wallet addresses. Given the diversity of these token contracts, we cannot make any definitive general claims about how these domain names are used in the context of transactions.

As a result, we filter any addresses (along with the domain names resolving to these addresses) that belong to known central-exchange wallets and token contracts, as labeled by Etherscan and Polygonscan. Unfortunately, we could not identify a trustworthy source of labeled exchange wallets for Cardano hence we did not filter our ADAH addresses. This lack of filtering is somewhat mitigated by the lower popularity of ADAH which, as shown in Table 3.1, has an order of magnitude fewer domain names registered.

3.4.6 Identifying Typosquatting Domains

We define a typosquatting name of a particular BNS name as one belonging to the categories listed in Table 3.2. These typo models have all been established by prior work in traditional typosquatting [27, 11, 12, 25, 14, 13, 15].

Given a list of target domain names (which constitute the top N domains after we sort the total list of domain names given our popularity metric), we generate all typosquatting variations using the aforementioned typo models and identify which ones have already been registered. We cluster these typosquatting domains together, according to the domain name that they target. When domain names are short, the likelihood of accidental squatting increases. For example, assuming that `abc.eth` is a popular ENS domain, is the less popular `abv.eth` a targeted squatting attack, or a legitimate do-

BNS	# Legitimate Names	# Legitimate Names having at least one typo	Total Typosquatting Names
ENS	10,711	3,920 (37%)	25,396
UD	12,026	701 (6%)	1,137
ADAH	931	191 (21%)	396

Table 3.3: Overview for legitimate-to-typosquatting name clusters

main that happens to be syntactically close to the first one? By manually investigating pairs of syntactically-close domain names, we empirically set a lower analysis limit to 5 characters. That is, popular domains that are shorter than that threshold are excluded from the rest of our analysis. Finally, to further reduce false positives, we discard any discovered squatting domains whose registration date predates the corresponding target domain. While these are within a single-character distance of the target domains and may very well end up receiving funds intended for other domains, they do not conform to our threat model of attackers registering domains for the express purpose of squatting existing popular ones.

3.5 Analysis

In this section, we discuss our findings we extract through comprehensively analyzing our datasets for each of the three BNSs.

3.5.1 Typosquatting Analysis

Given that both the Ethereum Name Service (ENS) and Unstoppable Domains (UD) have attracted millions of domain registrations, we choose the

top 10K wallets of our ordered list, as the ones that could be targeted by squatters. We refer the domains pointing to these wallets as “legitimate” domains, only to differentiate them from typosquatting domains. Given that the vast majority of these domains are not attached to known companies and individuals, we cannot be certain that they are associated with legitimate activity. Since ADA Handles (ADAH) have an order of magnitude fewer registrations, we also pick an order of magnitude smaller set of targets (i.e. top 1K domains).

Table 3.3 provides a high-level overview of the sets of legitimate domains that we selected across all BNSs, along with the number of typosquatting domains targeting them. For both ENS and UD, we observe that there are more legitimate domains than wallet addresses, since a few wallets “hold” more than one domain. For ADAH we observe the opposite where some domains were filtered out of our analysis due to their short length. In terms of typosquatting activity, ENS is clearly more targeted than the other two BNSs which is intuitively correct given that it is the oldest and most popular BNS of the three.

3.5.1.1 Number of Typosquatting Registrations.

Figure 3.3 shows the number of legitimate names with one or more typosquatting registrations against them. Our analysis reveals that a significant number of names are being targeted more than once. The ENS name targeted the most was `mickey.eth` with 102 typosquatting names. Similarly for UD, `cryptoden.blockchain` attracted 19 typosquatting names, and `$xn--bs8h` for

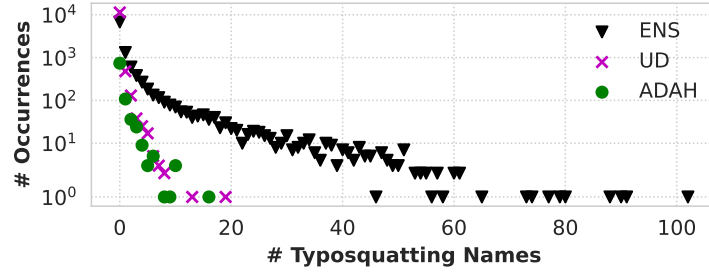


Figure 3.3: Frequency of the number of typosquatting registrations against legitimate names

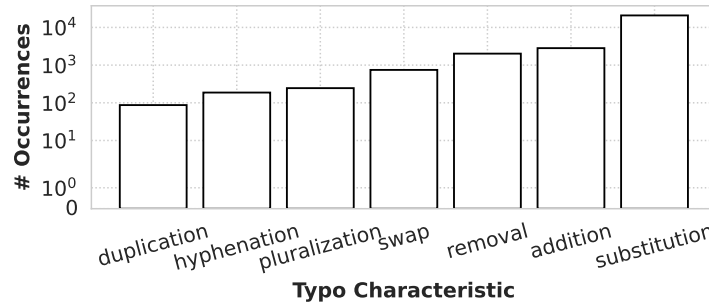


Figure 3.4: Frequency of the different misspelling strategies used by typosquatters to form spelling variations of legitimate names

ADAH with 16 typosquatting names. The ADAH domain is clearly an internationalized domain name (IDN) which corresponds to an emoji when viewed in UTF-8. We assume that not all users can type IDNs in their native format hence we consider their ASCII-based Punycode representations as in scope for squatting.

3.5.1.2 Typosquatting Characteristics and Volume of Activity.

Applying different typo models to the same target domain results in tens if not hundreds of possible typosquatting domains. In terms of domains that squatters have chosen to register, Figure 3.4 presents the models that are most popularly used across all studied BNSs. We observe that the character-

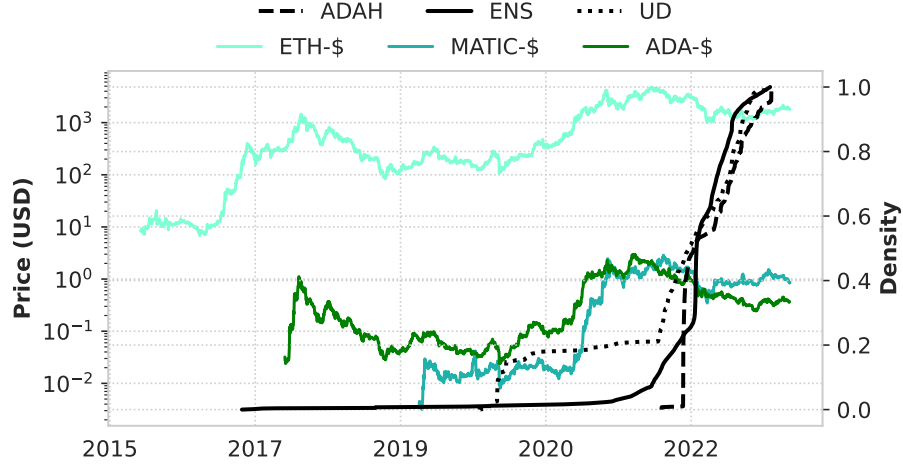


Figure 3.5: Correlation between the number of typosquatting names registered each year with the price of each cryptocurrency

substitution model is the one most commonly employed by attackers, followed by character additions, removals, and swaps. In 2015, Agten et al. reported that, in traditional domain squatting, attackers appear to prefer character omission, over introducing additional characters [12]. We also report that 24% of legitimate domains are altered in the first character to produce the typosquatting domain.

Figure 3.5 shows the fluctuation in prices of Ethereum, Matic, and ADA, along with the number of typosquatting names registered over the years. The trends show that all three BNSs have attracted a rapidly increasing number of typosquatting names each year, with a sharp increase in the registration of names after 2021. In 2021, the prices of all three cryptocurrencies reached their maximum exchange rates, which could be a possible explanation for this drastic increase in registrations of typosquatting names. There is no observable slowdown in registrations since 2021 and we expect sustained registrations as

cryptocurrencies further gain in popularity.

3.5.1.3 Defensive Registrations.

Like in traditional domain names, users of BNSs may proactively register typosquatting variations of their own domain names to protect themselves from the types of attacks discussed in this paper. In the aforementioned 2015 paper, Agten et al. had discovered that 156 of the 500 evaluated top Alexa domains (i.e. 31.2%) were engaging in at least one defensive registration of typosquatting domains [12]. In our case, we note a substantially lower rate of defensive registrations, with just 13 ENS legitimate domains (out of the 10,711 selected domains) owned by the same wallet address as at least one typographic variation of itself. We were not able to identify *any* defensive registrations in UD and ADAH. One possible reason behind this lack of defensive registrations is the current absence of large commercial interest in these BNSs. Companies with billions of dollars in revenue can afford the recurring registrations costs of defensive registrations whereas individuals (even if they are aware of the issue) may not be able to sustain these costs.

3.5.1.4 Trends of Typosquatting Registrations.

Next, we look at the registration-time deltas between the legitimate name and typosquatting names, the results of which are shown in Figure 3.6. We note that the median time difference is ≈ 100 days, which could be because of the time it takes for a legitimate name to become popular enough to attract

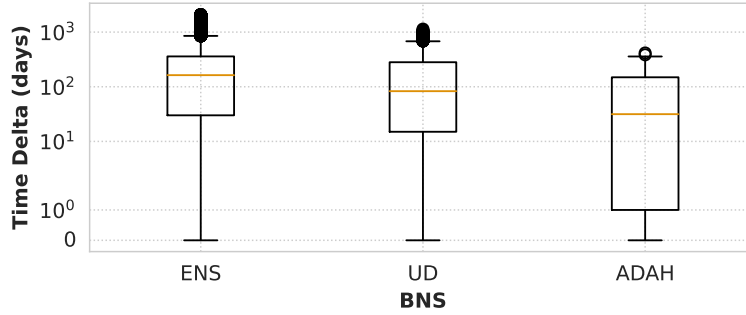


Figure 3.6: Time difference (in days) between the registration of the legitimate and typosquatting names

squatters. However, it is important to note that the number of typos registered at the very same day of the original name is non zero. One potential explanation for this behavior is that speculators observe the registration of a domain name and predict that it may eventually become popular, thereby immediately registering typo variations of it. One source for these predictions could be social media, where accounts with large followings obtain one or more BNS domain names. Since they are already popular, attackers can immediately register variations of their domain names. We analyze the phenomenon of BNS squatting in relation to social media popularity in Section 3.6.

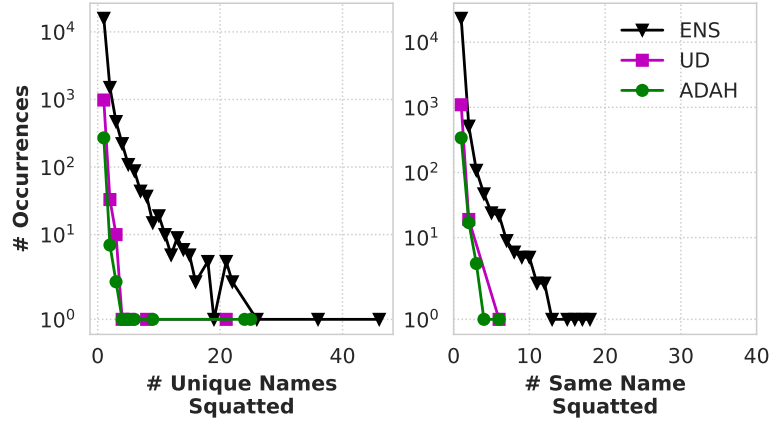


Figure 3.7: Number of unique names targeted by the same squatter (Left). Number of times a given name is targeted by a squatter (Right)

3.5.1.5 Behavior of Typosquatters.

Furthermore, we explore the behavior of squatters, specifically on how they choose their targets. We analyze the number of times a squatter (as identified by their wallet address) has registered a typosquatting name for the same legitimate name, and the number of unique names a typosquatter has registered a typosquatting name for. Figure 3.7 shows our results. The attacker that has targeted the most typosquatting names from ENS has targeted a total of 46 legitimate names, registering a total of 90 typosquatting names, and holds 1,368 domains at the time of our study. Figure 3.8 is focused on the top 50 ENS attackers, in terms of their registration activity. There we see not just that attackers register tens of squatting domains related to the legitimate ones in our study but that they hold hundreds (and occasionally thousands) of other domains in the same wallets.

Of all the typosquatting wallets, 71% of ENS, 87% of UD, and 66% of ADAH wallets have registered at least one other domain. Since a wallet address can register both UD and ENS names, we also observe that 25% wallets that had registered UD names, had also registered ENS names, and 7% vice versa, indicating that squatters are registering multiple domains across different BNSs as well. The leftmost subplot in Figure 3.9 shows that squatters are indeed registering multiple other domains, indicating suspicious behavior, with the maximum number of domains registered by a single wallet being 3,099 for ENS, 6,963 for UD, and 1,477 for ADAH. To further understand the motivation behind this mass registration behavior, we compute the average cosine similarity score of each typosquatting name with all other domains registered by its address (one-to-many), and the average cosine similarity of all names registered by the squatter (many-to-many). Cosine similarity values range from 0 to 1, with a higher score depicting a high semantic similarity. These scores are calculated by using word embeddings obtained using the **bert-large-uncased** model [137], which is currently state-of-the-art for natural language processing tasks. Using manual inspection, we decide on thresholds to categorize whether two domains are semantically similar in meaning or not, where a score of $x < 0.5$ indicates that the domains are not similar, $0.5 \leq x < 0.75$ indicates moderate similarity, and $x \geq 0.75$ indicates high similarity. Figure 3.9’s middle and rightmost subplots show our results, where the average cosine similarity trend suggests that names registered by typosquatters are more often than not different in their meaning. From this analysis, we notice that there are

Target	Typosquatting Name	Typosquatting Address
vitalik.eth	vitqlik.eth	0x6c30...83a90
vitalik.eth	vitalik.eth	0x4bcb...d920
vitalik.eth	vitlaik.eth	0x90e9...84d6
vitalik.eth	vitalii.eth	0x4c81...5492
vitalik.eth	vitaiik.eth	0x0325...e09ec
vitalik.eth	vitalki.eth	0x8c26...fe68
vitalik.eth	vitalij.eth	0x5201...80a3
metascan.nft	m3tascan.nft	0xcd9f...aab9
play2earn.crypto	play2ern.crypto	0xaf81...b4bb
jjlin.eth	jhlin.eth	0xc3e0...67e7
jjlin.eth	jnlin.eth	0x3682...333a
jjlin.eth	jlin.eth	0x793b...0805
blackcoin.crypto	balckcoin.crypto	0x8e77...0fa4
\$ada_astronaut	\$adaastronaut	addr1q82...40t9
\$cnftjunky	\$cnftjunk	addr1q9t...uq6c

Table 3.4: Examples of targets, typosquatting names, and typosquatting addresses of **Type (i)** typosquatting attacks (i.e. where attackers register only one typosquatting domain, and no other domains)

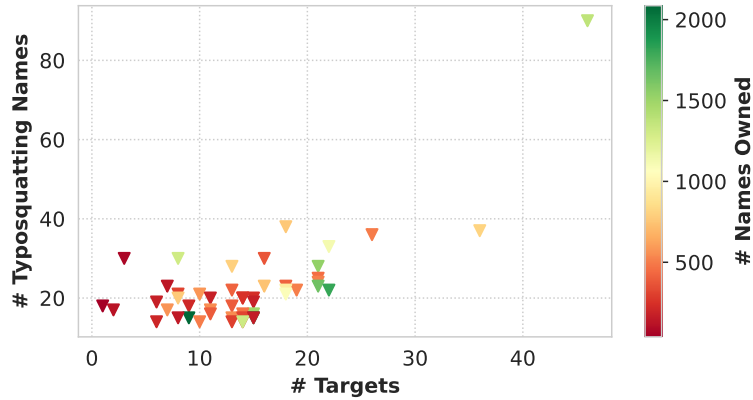


Figure 3.8: Number of targets vs. number of typosquatting names for Top 50 ENS attackers

three squatting styles among attackers: *i*) registering a single typosquatting domain, *ii*) registering multiple domains for different targets (most popular style of attack in our data), and *iii*) registering multiple domains with similar targets. Examples of each type are shown in Tables 3.4, 3.5, and 3.6.

Address	0x4ea8...567e	0x7afd...e4a2	0xba44...ae33	addr1q87...py2f	addr1qyd...hk6z
Sample Domains	googleeth.eth	vitalik3.eth	oldtrafford.crypto	\$-handles-	\$olidity
	treysong.eth	masterkard.eth	oldtrafford.nft	\$-handle-	\$occer
	ahopkin.et	maricle.eth	vitalybuterin.nft	\$-handles	\$tewart
	vitulik.eth	mckillip.eth	vitalik0.x	\$-handle	\$anchez
	vitalikbuteri.eth	bl0ckhead.eth	j0ebiden.nft	\$dana.swap	\$hrek
	votalik.eth	btcafe.eth	b0bmarley.nft,	\$dana_	\$stevenshandle
	paradigm.eth	akward.eth	0x00001.x	\$bitfinex	\$teveshandle
	paradigm.eth	beelive.eth	0x000001.x	\$binance	\$paulshandle
	pradigm.eth	greatfull.eth	k0bebryant.blockchain	\$usbank	\$tephanieshandle
	jimmyfalloneth.eth	dallasfans.eth	krypt0.blockchain	\$-eternlwallet-	\$stephanies
	starbuk.eth	chesleafans.et	Optimusprime.nft	\$-eternl.wallet	\$stephans
	mariogotz.eth	heatfan.eth	an0nymous.blockchain	\$-eternl.wallet-	\$tephanshandle
	pornhb.eth	wilsonfamily.eth	0xpunk.crypto	\$ada_handles-	\$ex-appeal
	pornhbu.eth	taylorfamily.eth	nakamoto1.crypto	\$ada_handles.	\$ex-appeal
	simsung.eth	figurati.eth	stevej0bs.crypto	\$adahandles	\$sex.appeal
	amsang.eth	johnwaynegacy.eth	w0nderw0man.nft	\$ada-handle-	\$haman
	davidsiwonchi.eth	p0rntv.eth	daviddunn.nft	\$walgreens	\$motor-yacht
	davidsiwonchio.eth	nfasset.eth	w0lfman.nft	\$rockwell	\$showbiz
Total Domains Owned	116	773	5862	1475	438

Table 3.5: Examples of targets, typosquatting names, and typosquatting addresses of **Type (ii)** typosquatting attacks (i.e. where attackers register multiple domains targeting dissimilar legitimate domains)

Address	0xc900...e268	0x250a...cc2f	0xc7d9...2434	0x143a...a1d1	0x92c3...bb57
Sample Domains	w3bank.eth	98223.eth	derick2.eth	0878888888.blockchain	1818181818.wallet
	web3nk.eth	98454.eth	erick2.eth	0908888888.888	1818181818.wallet
	web4nk.eth	98534.eth		0998888888.888	1818181818.blockchain
		98393.eth		0908888888.bitcoin	1818181818.blockchain
		98441.eth		0908888888.dao	1818181818.nft
		98094.eth		0998888888.dao	1818181818.nft
Total Domains Owned	3	179	2	13	14

Table 3.6: Examples of targets, typosquatting names, and typosquatting addresses of **Type (iii)** typosquatting attacks (i.e. where attackers register >1 domains targeting similar legitimate domains)

3.5.2 Transaction Analysis

Next, we investigate how successful attackers have been with their typosquatting registrations in BNS. Our aim is to identify the number of times users have mistakenly sent funds to an attacker-controlled wallet through a typosquatting BNS name. We note that inferring the intent of each transaction is difficult, since on-chain data just reveal the transactions themselves

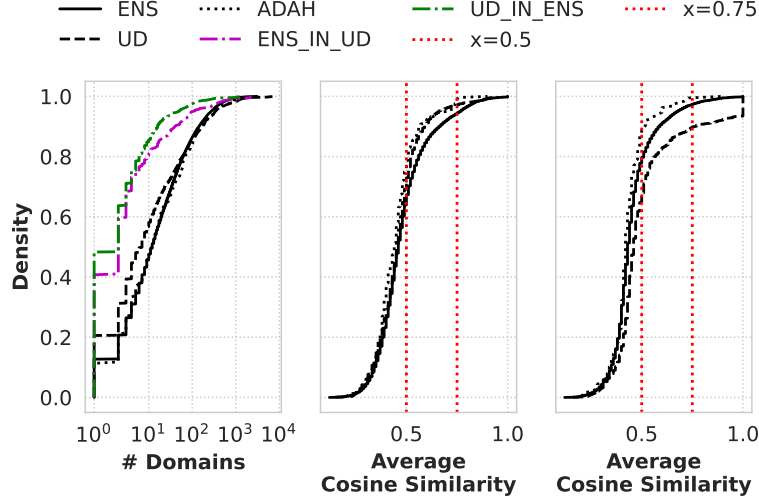


Figure 3.9: Distributions for the number of other domains owned by typosquatting wallets (left), the average cosine similarity of typosquatting names and other domains owned by typosquatting wallets (middle), and the average cosine similarity of all domains owned by typosquatting wallets (right)

and not which domain the sender used (aliasing issue discussed in Section 3.3), let alone which BNS domain a user intended to type. This lack of data can lead to false positives when performing our analysis, as funds going into an attacker-controlled wallet address might not necessarily be through the typosquatting BNS name, but rather through another BNS name resolving to the same wallet address.

To counter these possible false positives, we present two different analyses. First, we report on all transactions that these typosquatting wallets received, with the caveat that some of these transactions may have occurred through domains other than the identified typosquatting ones (i.e. domains that point to the same squatter wallets). Second, we search for senders who have sent funds to both the legitimate *and* the squatting domain, indicating

that a mistype was involved in one of their regular transactions. To this end, we extract the transactions of the addresses that resolve from the legitimate name and the corresponding typosquatting names and find the senders that have initiated transactions to both addresses. We report on how many custodial and non-custodial common senders have sent assets to both, the amount of funds that were sent to the squatting address, and the time difference between the transaction to the legitimate address and the squatting ones. We note that the results of this analysis are a lower bound of the transactions that typosquatting domains attracted since we ignore transactions from senders who did not attempt to send any funds to the corresponding legitimate domain.

On-chain data also lacks relevant insights needed to distinguish whether a transaction was initiated by entering a BNS name or the actual wallet address. At the time of our study, only Coinbase, among all custodial wallets, offers a name resolution service, supporting ENS and UD domains. This suggests that transactions processed via custodial wallets other than Coinbase most likely occurred through direct wallet address rather than BNS name resolution. We exploit this characteristic as a mechanism to filter out such transactions, which accounted to 16% of all transactions to typosquatting domains.

3.5.2.1 Victims

Figure 3.10 provides three different types of analysis we perform to report the number of transactions towards the typosquatting domains in our dataset. The leftmost figure highlights the frequency of the total number of

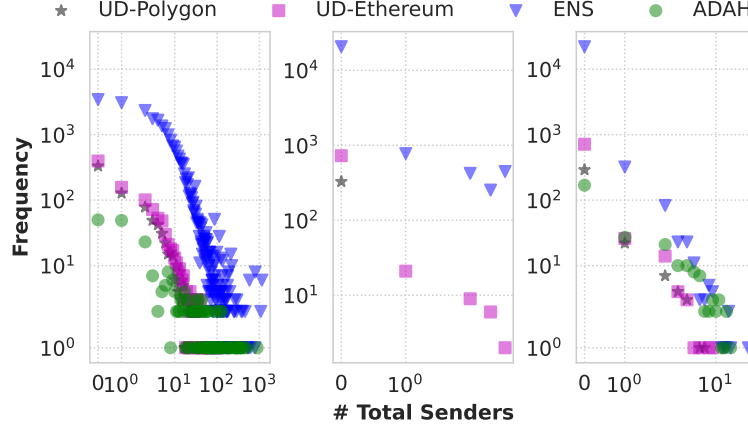


Figure 3.10: Frequency of the total number of victims attracted by a unique typosquatting name (left), number of common senders (victims) that have sent assets to a pair of legitimate and typosquatting name through a custodial address (middle)/non-custodial address (right)

senders/victims attracted by a typosquatting domain. There are 6 typosquatting ENS domains held by a single wallet address which have attracted the highest number of victims, i.e. 1,141. At the time of this study, this wallet holds a total of 112 ENS domains that are all either hexadecimal or decimal numbers. Examples that have been flagged as typosquatting domains are `0x1861.eth`, `0x1862.eth`, and `0x1863.eth`, which are targeting the domain `0x186d.eth` (linked with a wallet that has over 2,000 transactions, and only holds that domain). Similarly, 796 senders have sent assets to 8 different typosquatting names in our dataset that are linked to the same wallet. This wallet owns a total of 99 domains that are all decimal numbers, examples include `93813.eth` and `93815.eth` targeting `95813.eth` (over 5,600 transactions and linked with only one other domain).

Since it is plausible that the transactions were initiated through a domain name not flagged as a typosquatting model but owned by the same

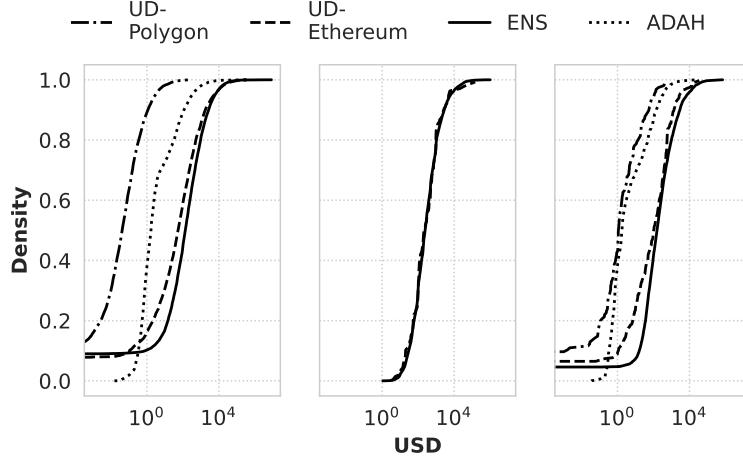


Figure 3.11: Amount in USD sent to addresses of typosquatting names through the set of all senders (left), common custodial-senders (middle), and common non-custodial senders (right)

wallet, we also report our findings using the common senders approach in the middle and rightmost plots of Figure 3.10. In total, we find 483 pairs of legitimate and typosquatting ENS names, 100 for ADAH, 51 for UD on the Ethereum blockchain, and 38 for UD on the Polygon blockchain that have received transactions sourced through a non-custodial wallet. In terms of Coinbase (custodial-wallet) sourced transactions, we find 1,899 such pairs for ENS, 38 for UD on Ethereum blockchain and 0 for UD on the Polygon blockchain. The top three pairs with most number of transactions from common senders all belonged to ENS with the top pair being `qwerky.eth` and `qw3rky.eth` (target) receiving transactions from 28 common senders.

3.5.2.2 Funds sent to squatters

Figure 3.11 shows the funds in US dollars that were sent by the set of all senders (left), as well as common senders through custodial and non-custodial

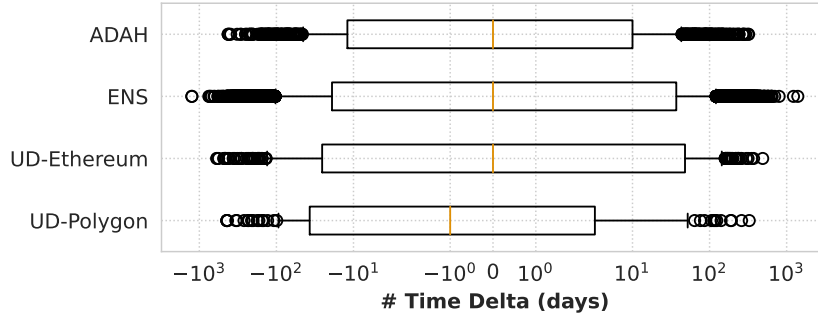


Figure 3.12: *Distribution of time (in days) between a transaction to a legitimate name vs a transaction to a typosquatting name through a common custodial or non-custodial wallet address*

wallets to the wallet addresses of the typosquatting names (middle and right). To convert the amount of each cryptocurrency into USD, we utilize the transaction timestamps along with the closing conversion rate for the day of the transaction. Our analysis reveals that the registration of typosquatting names have been successful for attackers in the context of extracting funds from users. From all transactions sent to typosquatting domains, the average amount of funds sent was \$1,790 (\$127 median). The average loss through senders that had sent transactions to both the legitimate and typosquatting names in custodial wallets was \$1,999 (\$241 median) dollars compared to \$1,862 (\$95 median) in non-custodial wallets. This finding supports our distinction between traditional typosquatting and BNS-based typosquatting where a single typo can now cost users thousands of dollars in lost funds.

3.5.2.3 Differences in transaction times

Lastly, we calculate the time difference between the transactions of a common sender to a legitimate name vs. its typosquatting equivalent. Fig-

ure 3.12 shows that the median time difference is approximately one day and the interquartile range of all transactions is less than ± 100 days around the origin. Both positive and negative differences are intuitive since users may mistype either in their first transaction, or a later one.

3.6 Case Studies

In this section, we complement the high-level results of Section 3.5 with an analysis of BNS typosquatting activity against popular Twitter/X users, as well as against the inventor of Ethereum.

3.6.1 Squatting cryptocurrency influencers

It is common for BNS users to publicize their names on their Twitter/X profiles for branding (e.g. associating themselves with a specific technology) or simply to enable their followers to send them cryptocurrency payments. From an attacker’s point of view, these Twitter-associated BNS names are ideal typosquatting targets, particularly when their legitimate owners are influencers with millions of followers and thereby a large pool of prospective victims. From our point of view, these influencer-associated BNS names give us an opportunity to verify our earlier observations since Twitter allows us to objectively establish account popularity (and thereby likelihood of targeting specific BNS domains) without restricting ourselves to on-chain data.

3.6.1.1 Data Collection.

We perform our analysis of typosquatting against cryptocurrency influencers as follows: we start by collecting popular influencer accounts in the cryptocurrency space on Twitter. We curated two such lists, one of 187 popular influencers in the cryptocurrency space from the top 3 Google search results in January 2023 for the search query “Top 100 Cryptocurrency Influencers on Twitter”. Since ADAH were not sufficiently represented in the resulting list, we searched for the keywords “adahandle” and “cardano” on Twitter and selected 120 additional legitimate accounts.

Given this initial list of influencer accounts, we use the Twitter API to access the accounts that they follow, and the accounts that their “followers” follow in search for other popular accounts that advertise BNS domains in their profiles.

In total, we manage to collect 14,910 ENS names, 733 UD names, and 1,849 ADAH names from Twitter accounts. In terms of their footprint on social media, ENS is significantly more popular than the other two, while UD is the least. We perform another step to narrow down and select the BNS names that were found in the profiles of users with large numbers of followers (and thereby large numbers of potential victims for squatters). We create two lists, one comprising of a total of 1,000 ENS and UD domains belonging to popular accounts, and the other consisting of 100 ADAHs. Our decision to combine the ENS and UD domains list was inspired by the fact that very few UD names in our dataset belonged to accounts with significant



Figure 3.13: Profile of the most popular Twitter/X user advertising his ENS domain name.

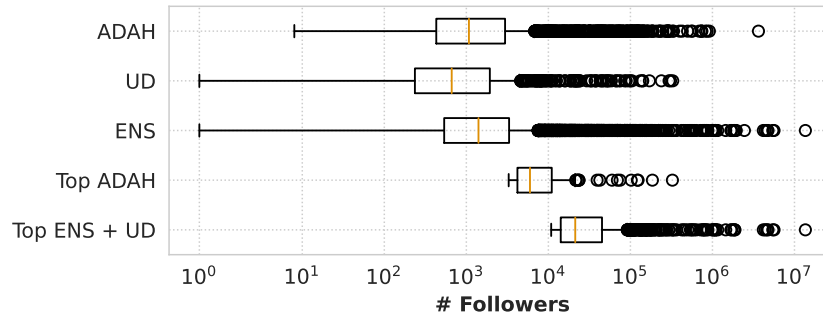


Figure 3.14: Distribution of the number of followers of all the collected BNS names popularized on Twitter/X

numbers of followers. Figure 3.13 shows the profile of the most popular user on Twitter among those who advertise their ENS domains with 13.1 million followers. Figure 3.14 shows the number of followers of users collected before and after we filter out unpopular accounts. We obtain all relevant addresses and transactions using the same methodology as the one in our Section 3.4 analysis.

3.6.1.2 Analysis.

Our findings from analyzing this Twitter dataset suggest that typosquatting activity for such BNS names is popular among attackers. Specifically, we identified 86 typosquatting names related to ADAH and 2,116 tied to ENS

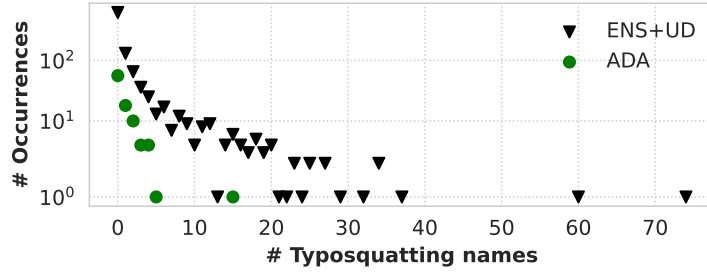


Figure 3.15: Frequency of the number of typosquatting registrations against legitimate names popularized on Twitter/X

and UD names. Of all legitimate ENS and UD names, 38% were targeted at least once; this percentage was marginally higher (40%) for ADAH. Figure 3.15 shows the frequency of the number of typosquatting names targeting legitimate names, showing a similar trend as that of Figure 3.3. For example, the ADAHs `$bullion` and `$villion` are registered against the legitimate name `$billion`. A total of 17 names target the ENS name `hayden.eth` (inventor of the Uniswap protocol), and a few examples of typosquatting names include `hayd3n.eth`, `haydin.eth`, and `hyden.eth`. UD domains in the Twitter dataset are overall targeted less than the ones in Section 3.5, with some attack instances against popular accounts. For instance, `metascan.nft` is the BNS name owned by the popular Web3 service, MetaScan, and has attracted 3 typosquatting names: `metascam.nft`, `metacan.nft`, and `m3tascan.nft`.

The three most targeted names in our Twitter dataset from each BNS were `vitalik.eth` (further analysis in Section 3.6.2), `metascan.nft`, and `$crypto`. We hypothesise that since such influencers are aware that their BNS are well-known, they could be more careful and might have defensive registrations for their domains. However, we find that only 16 ENS users and

2 ADAH users have one defensive registration each against their BNS names. We report that 85 wallet addresses hold more than one typosquatting names that target the legitimate names in our dataset. A single wallet holding 9 domains that are typos of popular domains in our Twitter dataset holds in total over 800 domains.

After performing the same transaction analysis of typosquatting names on this dataset, we find that Twitter-targeting squatters have been just as successful as the ones studied in Section 3.5. When all transactions to typosquatting names are considered, an average of \$2,277 per transaction (\$140 median) is transferred to typosquatting names. When focusing just on transactions from senders who have sent funds to both legitimate and typosquatting domains, an average of \$1,192 (\$196 median) per transaction is transferred through Coinbase and \$174 (\$0.5 median) through non-custodial wallets to typosquatting domains. We also find that 297 pairs of legitimate and typosquatting ENS and UD names have received at least one transaction through a common custodial sender (Coinbase), and 55 through a common, non-custodial wallet. For ADAH, 8 pairs received funds through the same non-custodial sender.

3.6.2 Squatting against Vitalik Buterin

In this case study, we report on the typosquatting activity against Vitalik Buterin, the inventor of Ethereum. Vitalik Buterin owns `vitalik.eth` and advertises it on his Twitter profile. Given the association between Buterin and

Typosquatting Name (Number of names linked to the same wallet)	Funds (in USD) sent to squatter
fitalik.eth (14)	33,310
vitalak.eth (17)	24,144
vltalik.eth (286)	7,109
italik.eth (103)	3,773
vytalik.eth (115)	1,523

Table 3.7: *Typosquatting names that had Coinbase as a common sender from `vitalik.eth`, and the funds sent to them.*

Ethereum, `vitalik.eth` is the most squatted domain in our Twitter dataset, with a total of 74 typosquatting names registered against it resolving to 66 unique wallet addresses.

3.6.2.1 Typosquatting Name Strategies

Among the typosquatting names registered, the most popular typo model was that of character substitutions, with 40 typosquatting instances. A few examples of this are `vitqlik.eth`, `vlitalik.eth` and, `vigalik.eth`. Other strategies involved substitutions that convert the name into one that sounds similar (known as soundsquatting [23]) including `witalik.eth`, `vetalik.eth` and, `vitalyk.eth`. Less popular strategies included the removal of characters (`italik.eth`), swapping two characters (`vitalki.eth`), pluralization (`vitaliks.eth`), character duplication (`vitalikk.eth`), and hyphenation (`v-italik.eth`).

3.6.2.2 Temporal Analysis

Typos targeting `vitalik.eth` are constantly being registered starting from just four days after the registration of the original domain (`vitalikb.eth` was the first typosquatting domain registered in 2017). The name that was

registered most recently in our dataset is `v-italik.eth` in December 2022. The number of typosquatting names registered each year is also increasing, consistent with the overall typosquatting growth observations in Section 3.5. Namely, 41 typosquatting domains targeting `vitalik.eth` were registered in 2022, compared to just 18 in 2021.

3.6.2.3 Transaction Analysis

Lastly, we perform a transaction analysis, finding that only custodial wallets were used to send funds to *both* `vitalik.eth` and a typosquatting name. We find 108 transactions where funds have been transferred to typosquatting names using only Coinbase as the source wallet. Table 3.7 shows the domains these funds were sent to and the amount of funds that has been sent. It highlights not only that the various typosquatting techniques utilized by attackers have been successful, but also that the typosquatters of `vitalik.eth` have also registered hundreds of other names either hoping to sell them for profit in the future, or capitalizing on typos for multiple accounts. As in all cases involving custodial wallets, we cannot know exactly how many individual users were behind these transactions.

3.7 Discussion

In this section we describe the overall limitations of our study and assess the presence of typosquatting countermeasures in wallets and exchanges. Based on our results, we propose some directions for future work in this

area.

3.7.1 Limitations

The limitations of this study are grounded on the two challenges listed in Section 3.3, i.e., the lack of ground truth regarding domain popularity and the aliasing of multiple domains to the same wallet address. These limitations make it difficult for us to categorically state that each and every transaction sent to a typosquatting variation of a legitimate domain name was the result of a typo. There is insufficient on-chain information to differentiate between a user consciously sending funds to a domain other than a typosquatting domain name, if these two are resolving to the same wallet address. At the same time, we argue that even if some of the identified typosquatting transactions are false positives, this paper sheds light on the overall typosquatting problem in BNSs. Without such a study, centralized exchanges and wallet providers can never try to solve an issue that they do not know they have.

We approached these fundamental limitations through a series of conservative filters, focusing on the senders that have sent funds to pairs of legitimate/typosquatting domain names and thereby excluding one-off transactions that could very well have been the result of typos. Similarly, regarding centralized exchanges, we focused just on Coinbase-originating transactions since that is the only exchange that supports ENS/UD resolutions and thereby the only exchange where transactions could have realistically been the result of a typo. Lastly, our Twitter/X case study confirms the overall problem of ty-

BNS	Custodial	Non-Custodial		
ENS	Coinbase	Metamask v10.32.0	Bitcoin.com v8.5.1	Alpha Wallet v3.65
UD	Coinbase	Atomic Wallet v1.11.5	Bitcoin.com v8.5.1	Alpha Wallet v3.65
ADAH	N/A	Eternl v1.10.10	Nami Wallet v3.5.0	Typhon Wallet v2.5.6

Table 3.8: *Digital wallets used in cold/warm typos experiments*

posquatting since we see similar levels of typosquatting activity even when we change our approach for identifying legitimate domains, i.e., domains that attackers target with typosquatting registrations.

3.7.2 Defenses and Future Work

On the traditional web, public DNS servers will resolve all registered domains (both legitimate as well as squatting ones) but some browsing software may warn users about potential typos, requiring confirmation before actually navigating to the website hosted on a suspicious domain [138]. One may wonder whether similar countermeasures exist in the systems that support BNS resolutions, namely wallet software for non-custodial wallets and the web applications operated by centralized exchanges.

3.7.2.1 Experiments

To assess whether these defenses exist, we perform the following two experiments on a centralized exchange that supports BNS resolution as well as on popular wallet software that resolves domains for all three evaluated BNSs:

Cold typos: Attempt to send funds to a squatting domain without any other related interactions. Do exchanges and wallet software operate global squatting-related blocklists?

Warm typos: Attempt to send funds to a squatting wallet *after* having sent funds to the legitimate (i.e. squatted) domain. Do exchanges and wallet software operate local (user-specific) squatting-related blocklists?

We use the wallets and custodial exchanges shown in Table 3.8. Coinbase is, to our knowledge, the only centralized exchange that supports the resolution of ENS and UD domains at the time of this writing. No exchanges currently support ADA Handles. In terms of non-custodial wallets, we select popular wallets advertised by each respective BNS. For example, the Metamask wallet is installed by more than 10 million users, just on the Google Chrome store. For our cold-typos experiment, we simply send a minimal amount of cryptocurrency to typosquatting names of popular names from each BNS and note the presence of any warnings or errors. For our warm-typos experiment, we first send funds to a legitimate address resolved through a popular BNS domain and then send funds to a typosquatting variant of the same domain.

3.7.2.2 Ethical Considerations

We are familiar with the ethical issues surrounding the sending of funds to attackers, as part of research experiments. For all experiments, we sent the smallest amount of cryptocurrency that the exchange/wallet software would allow us. For example, while Coinbase has a minimum transaction amount of

0.001 ETH, we were able to submit significantly lower transactions through our non-custodial wallets.

In this, we follow prior security studies where authors make modest payments to attackers and underground economies as a way of shedding light to the studied malicious ecosystems. In past work researchers have, among others, sent small amounts of funds to cyber criminals in order to understand how they construct fake Twitter accounts [139], operate CAPTCHA farms [140], attempt to compromise users [141], and create artificial backlinks [142]. As with this prior work, we argue that these small payments are acceptable if the value of the gained insights outweigh the funds sent, and no alternative method was available.

For this paper, we sent a total of \$12.52 spread over multiple attackers, a vanishingly-small amount considering the actual typo-payments that these attackers are stealing from victims (Section 3.5.2). These were unavoidable since we lack access to the logic of centralized exchanges and resolution-services of software wallets, meaning that unless we try to send a small payment, we cannot know if there is some resolution-level/transaction-level mechanism that will stop that payment from going through.

3.7.2.3 Results

All variations were allowed to go through without any warnings. The only exceptions are Eternl and Bitcoin.com wallets which show a warning after *every* name resolution (for both legitimate and typosquatting domains)

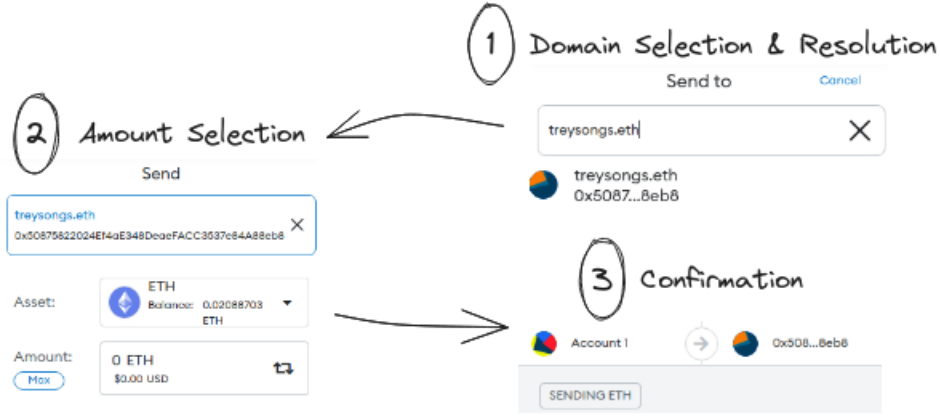


Figure 3.16: Example of the “Cold Typos” experiment, showing the stages to sending assets to `treysongs.eth` (targeting `treysongz.eth`) through Metamask without warnings.

reminding users that it is their responsibility to confirm the addresses that they are sending funds to, as all transactions are irreversible. Figure 3.16 illustrates the screen views from Metamask when sending funds to a typosquatting domain. These results highlight that there is ample room for deploying global and local defenses to protect cryptocurrency users.

Even without any trusted third parties (i.e. along the overall ethos of cryptocurrencies and trustless P2P payments), software wallets can keep local lists of the domains that their users have resolved and sent funds to, calculate typosquatting variations using well-known typo models, and warn users if they ever try to send funds to these variations in the future.

3.8 Chapter Summary

In this chapter, we drew attention to the issue of typosquatting in Blockchain-based Naming Systems (BNSs) and performed the first study of intra-chain squatting across three BNSs. We built a corpus of 4.9 million domains hosted

across these services which we used to define legitimate domains and identify squatting domains targeting them. Through conservative filters aimed at overcoming the inherent limitations of the available on-chain data, we discovered tens of thousands of squatting domains, targeting as many as 37% of the benign domains in their corresponding BNS. We observed an increasing number of typosquatting registrations per year, with defensive domain registrations being almost entirely absent. In terms of transactions, we observed thousands of sender pairs with transactions involving substantial amounts of cryptocurrency, often equivalent to hundreds or thousands of dollars. We confirmed the typosquatting phenomenon on Twitter data and observed that modern software wallets and online exchanges do not currently support mechanisms to protect users from typosquatting.

Chapter 4

Panning for gold.eth: Understanding and Analyzing ENS Domain Dropcatching

4.1 Introduction

The Ethereum Name Service (ENS) [126] functions analogously to the Domain Name System (DNS), providing user-friendly, memorable names that map to cryptocurrency addresses. This simplifies transactions within the cryptocurrency ecosystem by allowing users to utilize easy-to-remember ENS domains instead of lengthy and complex cryptographic addresses. The adoption of ENS domains has expanded significantly, capturing interest from both corporations and public figures. For instance, in 2022, the multi-national sportswear brand Puma adopted the ENS domain `puma.eth` and prominently displayed it as their Twitter/X username [143].

However, ENS domains are susceptible to the same range of attacks as traditional DNS domains, including domain dropcatching. This attack occurs when legitimate domain owners forget to renew their ENS domains on time, allowing attackers to re-register the “dropping” ENS domains either for the purpose of selling them back to the original owner for a profit or potentially

intercepting future transactions intended for the original owners. The latter vulnerability (i.e. where the funds sent to `alice.eth` do not go where the sender intended them to, but to whoever re-registered the expired domain) is of particular concern in the ENS context, as successful attacks can result in immediate and irreversible financial losses. Furthermore, even benign, non-malicious re-registrations of dropped domain names can still result in the new owner of a domain receiving funds intended for the previous owner. Prior research has acknowledged this danger of expired domain names in the context of ENS but did not empirically study this phenomenon and the extent to which these attacks are already happening [33].

In this paper, we present the first large-scale study investigating ENS domain expirations and re-registrations. Our study identifies characteristics of ENS domains that make them good candidates for re-registrations (i.e. why are some expired domains more likely to be re-registered than others) and reports on the results of a detailed transaction analysis to quantify incidents of financial loss.

To perform this study, we have compiled the most comprehensive dataset of ENS domain data to date (3.1M names), identifying 241K domains that were re-registered by a new owner following expiration. We find that domains with larger amounts of income directed toward their previous wallet addresses are significantly more likely to be targeted for re-registration. Additionally, our analysis reveals 2,633 transactions that potentially represent cases of financial loss due to these re-registrations, with an average of 4,700 USD mistakenly

sent to the new domain owners.

Availability. To encourage further research in this area, we have made our dataset of ENS domains and code to crawl ENS registration data and Ethereum transactions publicly available [144].

4.2 Background and Motivation

4.2.1 Ethereum Name Service (ENS)

In the ENS ecosystem, “domains” are non-fungible tokens (NFTs) owned by users, granting them full control over the domain’s use and its associated records. Ownership persists until the domain expires or the owner willingly transfers it. To maintain ownership, users must renew their domain registration before it expires, with the option to extend for multiple years in advance. If a domain is not renewed by its expiration date, it becomes available for others to register after a 90-day grace period (the owner has this time to renew their registration before they lose control of it). To re-register an expired domain, users have to pay an additional temporary premium along with the base price of the domain. The temporary premium starts at a 100M USD at the time of writing, and exponentially decays to 0 USD over 21 days (also known as a “Dutch Auction”). We note that decaying premium is unique to ENS (i.e. there is no equivalent mechanism for dropping domains in DNS [56]) temporarily favoring the users who are willing to invest the most resources to

purchase a domain name vs. the users who are the fastest to act upon a domain's expiration.

4.2.2 Motivation

Traditionally, after the expiration of DNS domains, attackers are known to re-register them immediately and then host malicious content on them, capitalizing on the residual trust of the domain [56, 60, 53, 59]. We argue that in terms of ENS domains, the stakes are even higher due to the nature of blockchain and cryptocurrency transactions. Unlike DNS domains where the primary risk of expired domain names is closely tied to the purpose of the original domain name (and therefore may or may not lead to a high-impact vulnerability), the re-registration of ENS domains can directly lead to financial losses. When attackers register an ENS domain that was formerly used in financial transactions, they do not need to host any content; they simply wait for transactions. Due to the immutable nature of blockchain transactions, any funds inadvertently sent to the re-registered domain based on its previous ownership are immediately and irreversibly lost to the attacker.

We argue that domain re-registrations in ENS can be harmful even when they are done without mal-intent. In DNS, re-registered domains with benign intentions may still attract traffic; however, users are typically not harmed as they can often discern from visible webpage characteristics that the domain's ownership has changed. In contrast, ENS domain re-registrations, even with benign intent, carry inherent risks. This is because transaction-initiating users

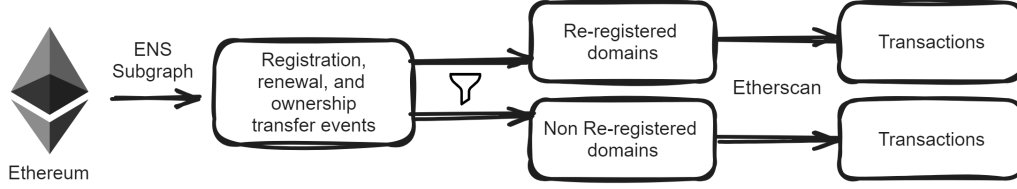


Figure 4.1: A schematic representation of our data collection, illustrating the integration of third-party APIs.

— barring assistance from their cryptocurrency wallets — have no ability to immediately identify that the ENS domain that they are about to send funds to has switched hands.

4.3 Data Collection

In this section, we describe our data sources and an overview of the data collected for this study (illustrated in Figure 4.1).

4.3.1 Registrations, Renewals, and Transfers

Previous research has highlighted the inherent difficulties in extracting a comprehensive dataset of ENS domains from the Ethereum blockchain [33, 34]. This complexity primarily stems from the manner in which ENS domains are stored: rather than being recorded in a human-readable format, they are stored on the blockchain in the form of their keccak-256 hash values. When clients wish to resolve a domain name, they first obtain that hash and then call the appropriate ENS smart contract with the hashed ENS domain as a parameter. While this makes ENS smart contracts more efficient because they can use fixed-length strings, it complicates the process of comprehensively identifying

all domains that have been registered. As a result, prior work had to rely on secondary sources and brute-forcing dictionary words into hashes in order to build as complete a list of ENS names as possible [33].

To query ENS data from the Ethereum blockchain, we take advantage of a relatively recent development in the space of blockchains and utilize the ENS subgraph [145], a GraphQL endpoint built atop The Graph protocol [146]. This subgraph is managed by the ENS team itself, which ensures data correctness and completeness. This approach enables the efficient retrieval of information regarding ENS domain names, encompassing ownership details, resolver addresses, and associated records. We queried the ENS subgraph and successfully collected registration data for 3,103,000 ENS domains (and 846,752 subdomains), including registration, renewal, and ownership transfer events. This dataset includes new ownership records, expiration dates, block numbers, and transaction IDs corresponding to these events. However, due to API limitations, 34K ENS names remained unrecoverable, resulting in a data recovery rate of 99.9%. This methodology offers a straightforward, comprehensive, and efficient means of data acquisition compared to direct extraction from the Ethereum blockchain, a process that, as Xia et al. highlighted, faces significant challenges in ensuring data completeness as they were able to collect only 90.1% of all ENS domains [33].

4.3.2 Ethereum Transactions

The public nature of prominent blockchains enables third-party entities to index their data, subsequently offering access via blockchain explorers like Etherscan [133]. To crawl transaction data within the Ethereum blockchain [147], we leverage the Etherscan API, submitting Ethereum addresses (of ENS domain owners) to procure data on associated incoming and outgoing transactions. This data includes sender and receiver addresses, the amount of ETH transferred, transaction IDs, and timestamps. We manage to collect transactions for all Ethereum addresses that are relevant to our study, extracting a total of 9,725,874 transactions.

4.4 Analysis

We utilize registration data for each ENS domain to determine the frequency of registrations attributed to distinct owners. Specifically, we identify domains that have been registered by two or more unique entities. Our dataset comprises a total of 241,283 ENS domains that have undergone at least one cycle of registration, expiration, and re-registration (colloquially known as “dropcatching” in the traditional DNS world [56]).

In this section, we present a detailed analysis of these domains, focusing on patterns and implications of re-registration behaviors. Given that our dataset encompasses registration events of 99% of all ENS domains, it is highly unlikely that a significant number of re-registration events have evaded this analysis.

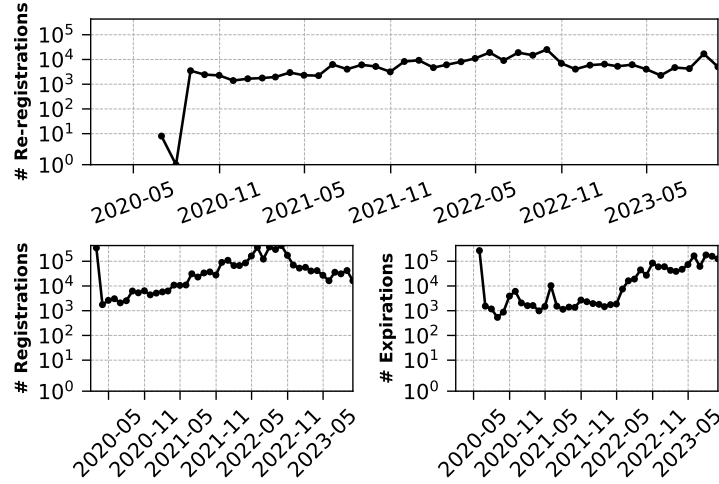


Figure 4.2: Total registrations, expirations, and re-registration events in ENS along the years 2020 to 2023

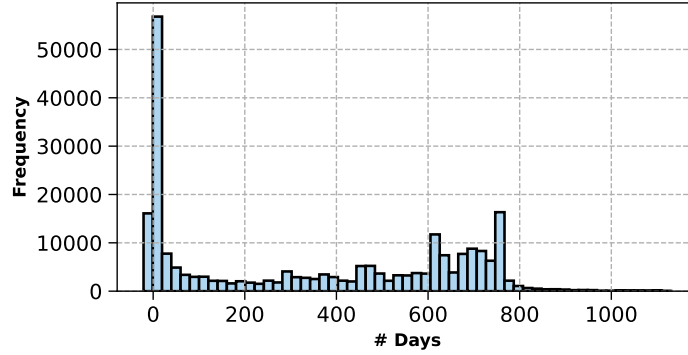


Figure 4.3: Time (in days) between ENS name expiration and re-registration by a different owner

4.4.1 Re-registration Overview

Figure 4.2 illustrates the trends in registrations, expirations, and re-registrations of ENS domains from February 2020 to September 2023. Notably, both registrations and expirations exhibit significant spikes in early 2020. This pattern can be attributed to a critical bug identified in the ENS smart contracts in 2020 [148], prompting a transition from an auction-based system to a new contract framework that supports timed registration and expiration. Under



Figure 4.4: Frequency of the number of times a single domain has been re-registered by a different owner after it expired

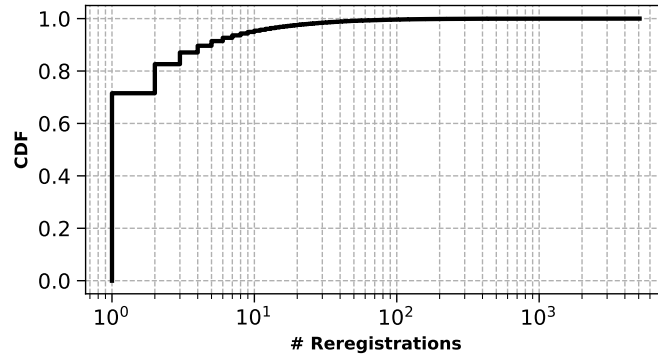


Figure 4.5: Number of times a unique address re-registered an expired ENS domain

the new system, domain owners were mandated to renew their registrations by May 2020. Failure to comply resulted in the expiration of these domains, thus making them available for new registrations. This event catalyzed a surge in expirations and provided a unique opportunity for users to acquire previously unavailable domains and potentially capture transactions directed to former owners. The data indicates a rising trend in registrations until the end of 2022, followed by a decline. Concurrently, there was a sharp increase in expirations. However, the rate of re-registrations remained relatively consistent throughout the observed period, with the peak monthly re-registrations reaching 25,193.

Figure 4.3 displays the interval, measured in days, between the expiration of an ENS domain and its re-registration by a different owner. We identify new ownership by searching for domains that are held by new wallets post-expiration vs. pre-expiration. Figure 4.4 depicts the distribution of the frequencies at which ENS domains have been re-registered, where 12,614 ENS domains have been registered more than twice. Together, these figures indicate a high demand for certain ENS domains; notably, 56,792 domains were re-registered shortly after their temporary premium periods concluded, with 20,014 domains being re-registered on the very day the premium ended. Interestingly, 16,092 domains attracted re-registrations at a premium price pointing to users who were willing to pay significantly more than the standard price to obtain expired ENS domains.

The data reveals that several users have acquired multiple domains following their expiration. Figure 4.5 presents the CDF of the number of re-registrations by unique owners, showing that a subset of users have engaged in the re-registration of a large number of expired domains, which may indicate potential speculative or opportunistic behaviors. Overall, the owners of 19,763 Ethereum addresses have engaged in the re-registration of more than one expired ENS domain. The three addresses most active in such behaviors have re-registered 5,070, 3,165, and 2,421 domains, respectively.

4.4.2 Re-sale Market

In addition to speculative dropcatching, re-registrations of ENS domains may also be motivated by intentions to resell at a higher price. To explore this aspect, we investigated the listings and sales of re-registered domains on OpenSea [149], the largest NFT marketplace [150]. Using the OpenSea API [151], we tracked the events associated with re-registered domains listed for sale. Our findings indicate that only 19,987 (8%) of re-registered domains were ever listed on OpenSea by their new owners, and of these, 12,130 were successfully sold. This data suggests that name hoarding does not appear to be the predominant motive behind the re-registration of ENS domains. It is, nevertheless, important to acknowledge that regardless of benign or malicious intent, ENS names are being re-registered for various purposes and can always receive transactions that were meant for the previous domain owners. For example, the domain `gno.eth` was re-registered for 12K USD by an address that has a high volume of transactions with the “Gnosis: Active Treasury Management” smart contract (labeled by Etherscan). This smart contract is related to the Gnosis chain [152] (an Ethereum side-chain) and transactions can only be approved towards this smart contract if a certain percentage of owners approve them [153], suggesting that the `gno.eth` domain was acquired by Gnosis developers. Before this registration, `gno.eth` used to belong to another user who had registered it for the equivalent of 735 USD. That former user had never transacted with a Gnosis smart contract but had transacted with multiple other different addresses which might still mistakenly send transactions

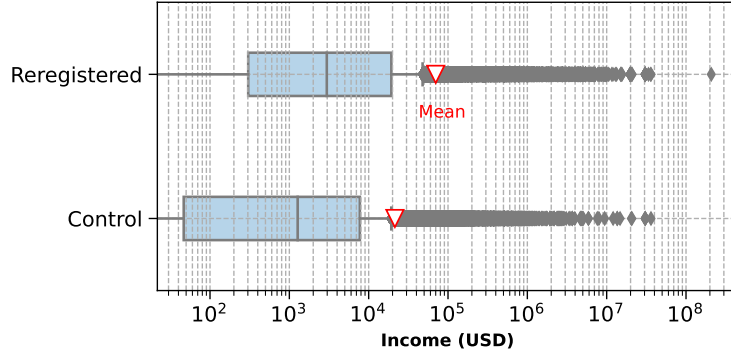


Figure 4.6: Income in USD received by previous owners of re-registered and control domains.

through the repurposed `gno.eth` domain.

4.4.3 Re-registered Domain Characteristics

When an ENS domain expires, it can be attractive for re-registration due to its potential perceived value. In this section, we explore the attributes that contribute to the valuation of ENS domains, focusing on lexical and transactional features (listed in Table 4.1), and compare these attributes with those of domains that expired but were not re-registered. Regarding the lexical features, we draw inspiration from the work of Miramirkhani et al. who investigated traditional domain droptatching in 2018 [56] and sought to identify which features make some expired DNS domains more likely to be re-registered than others.

We hypothesize that lexical attributes influence the value of ENS domains for re-registration. For example, domains such as `abc.eth` and `000.eth`, characterized by their concise three-letter format, typically sell for high prices in the six-figures range [154]. The owners of these domains are recognized as

Feature	Re-registered	Control
average_income_USD	69,980	21,400
average_num_unique_senders	8	7
average_num_transactions	25	24
average_length	8	10
contains_digit	12,751 (2.3%)	65,432 (27.1%)
is_numeric	33,482 (13.9%)	32,534 (13.48%)
contains_dictionary_word	108,913 (45.1%)	89,444 (37.1%)
is_dictionary_word	17,955 (7.4%)	2,238 (0.93%)
contains_brand_name	1,352 (0.6%)	993 (0.41%)
contains_adult_word	1,635 (0.7%)	1,998 (0.8%)
contains_hyphen	6,753 (2.8%)	14,764 (6.12%)
contains_underscore	514 (0.2%)	5,275 (2.19%)

Table 4.1: Comparison of lexical and transactional features of re-registered/non re-registered domains

members of the “3 Letters Club” [155], highlighting the market for short and memorable names. The transactional features of an ENS domain can also play a role in its value for re-registration, including the number of transactions, the number of unique sender addresses, and the total amount of ETH transacted to the previous owner’s address linked to the domain.

To systematically evaluate the significance of these features, we conduct a comparative analysis using an equally-sized control group of 241,283 domains randomly sampled from the 1.17M domains that expired and were *not* re-registered by a different owner. We collect the same set of features for this control group. For categorical features, we employ proportion tests, while for numerical features, we utilize t-tests to compare the mean values between the re-registered domains and the control group and determine a feature to be statistically significant if the p-value was less than 0.05.

Our results, shown in Table 4.1, suggest that domains that are easy to

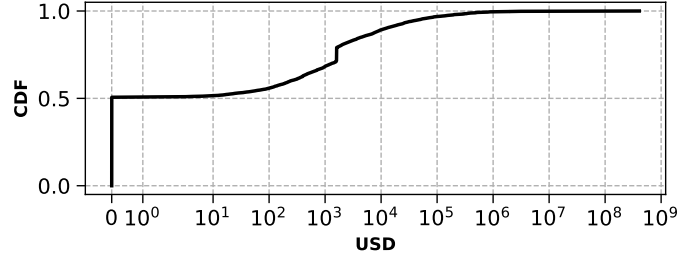


Figure 4.7: Amount of hijackable USD sent to the corresponding wallet address of an expired ENS domain.

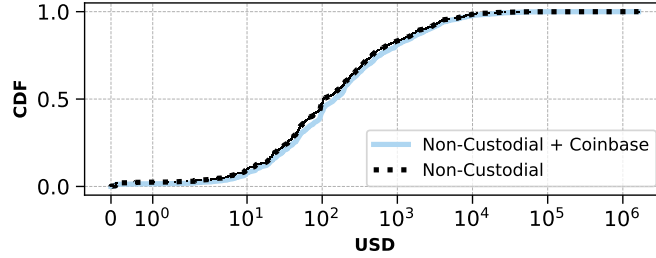


Figure 4.8: Amounts transacted (in USD) to a_2 by a common sender c .

recall, transactionally active, and financially lucrative are generally preferred for re-registration. All considered features are statistically significant in distinguishing between domains that are re-registered and those that are not. *Income* is the most notable feature, referring to the total USD value transacted through the domain before its expiration (converted from ETH using the adjusted closing price on the day of each Ethereum transaction [156]). The income differences between the two groups are depicted in Figure 4.6, showing a clear preference for higher-income domains in the re-registration process.

4.4.4 Financial Losses

In this section, we describe our methodology for quantifying the success of attackers in terms of receiving unintended transactions in their wallets from

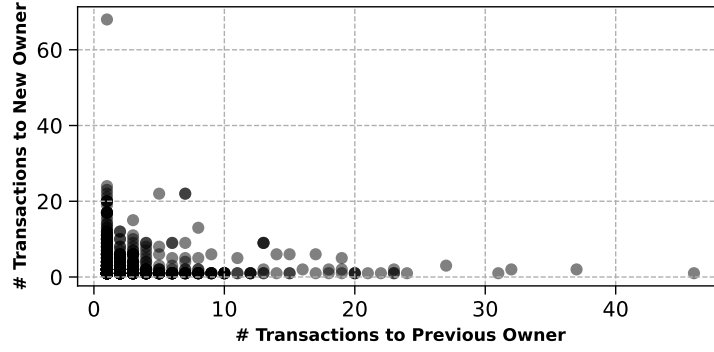


Figure 4.9: Number of transactions sent by a common sender c to the previous owner a_1 as compared to the new owner a_2 where c is either a Coinbase or non-custodial address.

re-registered ENS domains.

According to the ENS documentation [157], domains that were registered after ENS contract migration continue to resolve to the addresses set by previous owners even after expiration. This design decision is a clear departure from the behavior of DNS domain names (which stop resolving when they expire) which effectively hides problems by keeping ENS domains functional until it is too late. That is, an expired ENS domain remains functional (its owner is receiving transactions sent by other users) until the new owner registers the domain name and overwrites its resolution address. Without any warning (such as resolution failures) that domain name suddenly starts resolving to a new address that will now receive all transactions intended for the previous owner of that domain.

We attempt to resolve expired domains on popular ENS-supporting wallets (Table 4.2), finding that none of these wallets display a warning that the domain name has expired but continue to resolve the domain to the corre-

Digital Wallet	Date/Version #	Displays Warning
Metamask	11.13.1	No
Coinbase	05/2024	No
Trust Wallet	2.9.2	No
Bitcoin.com	8.22.1	No
Alpha Wallet	3.72	No
Atomic Wallet	1.29.5	No
Rainbow Wallet	1.4.81	No

Table 4.2: Popular ENS supporting digital wallets (custodial or non-custodial) do not display a warning before a transaction is being sent to an expired/re-registered domain

sponding address.

This means that attackers can in fact register expired ENS domains and hijack transactions that these domains might still be receiving. Figure 4.7 illustrates the amount of hijackable funds that were sent to the corresponding wallet addresses of the expired domains before they were re-registered (i.e. could have been redirected by attackers, had they registered the domain names before their real owners re-registered them).

Identifying the precise number of unintended transactions directed towards new owners of ENS domains is not straightforward. Unlike DNS domains, where passive DNS data can reveal resolution frequencies, ENS domains lack such visibility. Transactions via an ENS domain involve a smart contract, known as a resolver, which resolves the domain to its corresponding wallet address before the transaction is executed on the Ethereum blockchain. However, only an address-to-address transaction will be visible on Ethereum, and not the resolution event or the ENS domain that was used. Consequently, one cannot definitively conclude that a given transaction was initiated using an

ENS domain vs. by directly pasting the wallet address into the digital wallet and bypassing ENS entirely. We made multiple efforts to acquire resolution data from various digital wallet vendors, but were ultimately unsuccessful due either to the vendors' reluctance to share such data or the unavailability of long-term resolution data.

Given this absence of data, we adopt a conservative approach to identify cases of financial loss using registration history data and raw transactions from our dataset. Our approach aims to minimize false positives in our analysis, by focusing on cases where there is a high probability that funds sent to the new owner of an ENS domain, were in fact intended for a previous owner.

We consider this scenario: address a_1 holds the domain d , which expires and is then re-registered by address a_2 . There is a sender c that sent funds to a_1 only while a_1 held d , but only ever sent funds to a_2 when a_2 held d , and never again to a_1 . This pattern suggests that c likely used the ENS domain to send funds, unaware of the change in ownership, thus mistakenly sending their funds to a_2 instead of the intended recipient a_1 through the re-registered domain name. While there are additional scenarios where a_2 could have received funds intended for a_1 (such as in the case of a user who had never transacted with a_1 pre-expiration), these are harder to identify by purely using transaction data. As such, in the rest of this section, we focus on the aforementioned scenario to quantify financial losses.

Note that c can either be a custodial or a non-custodial wallet address. Custodial wallets are managed by a third party, such as an exchange or ser-

vice provider, that holds and controls users' private keys and funds on their behalf. Multiple users can access and utilize the same wallet infrastructure, and hence subsequent transactions by a custodial address c might be sourced by different users even if they share the same address. Contrastingly, non-custodial wallets operate on the principle of individual ownership and control. Each non-custodial wallet is associated with a single user who has exclusive control over their private keys and funds. There are multiple ENS-supporting non-custodial wallets, however, Coinbase is the only exchange that supports ENS resolution at the time of this writing. This gives us the opportunity to filter out the transactions where c is a non-Coinbase custodial address. To do so, we source a list of 558 non-Coinbase custodial addresses from Etherscan and filter out any transactions where they are the sending address. We also collect 25 Coinbase addresses from Etherscan and report our results where c is a Coinbase address.

There are currently 484 domains that have received funds in accordance with our aforementioned scenario through an address c that is a non-custodial address. This number increases to 940 when considering Coinbase addresses for c . Figure 4.9 displays a scatter plot comparing the number of transactions from c to addresses a_1 and a_2 for both Coinbase and non-custodial addresses c . Figure 4.10 shows the same scatter plot restricted to non-custodial addresses only as c . In both cases, the most commonly observed transaction ratio between a_1 and a_2 is one-to-one, although many-to-many and one-to-many relationships are also prevalent.

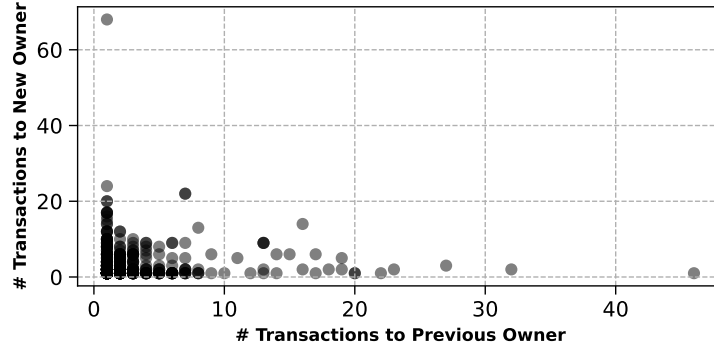


Figure 4.10: Number of transactions sent by a common sender c to the previous owner a_1 as compared to the new owner a_2 where c is a non-custodial address.

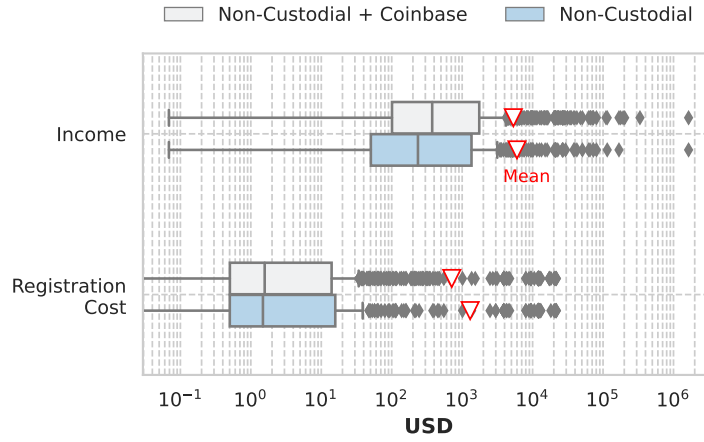


Figure 4.11: Comparison between the cost of re-registering an expired ENS domain name vs income received from common senders.

Our findings reveal that an average of 1,944 USD was transferred to a_2 addresses by 195 unique non-custodial c addresses, spanning 1,617 transactions. Conversely, an average of 1,877 USD was transferred by 201 unique addresses, encompassing both Coinbase and non-custodial addresses, across 2,633 transactions. Figure 4.8 illustrates the amounts in USD transferred to a_2 through c addresses.

Figure 4.11 shows the amounts in USD that attackers spent to re-register expired domains alongside the income they were able to attract towards their

wallets from c , showing a clear distinction between the two groups. In total, we find that 91% of addresses that re-registered an expired domain profited from doing so and that the average profit gained from dropcatching an ENS domain is 4,700 USD. Hence, despite applying a conservative methodology for estimating financial losses, we find that attackers are successful in profiting from expired ENS domains.

For example, the domain `profittrailer.eth` underwent registration by two different owners. The initial owner a_1 controlled the domain from February 2020 to January 2021. Subsequently, a_2 acquired it from November 2022 to November 2023. During a_1 's period of ownership, an address c initiated 46 transactions to a_1 . However, during a_2 's ownership, c sent only one transaction to a_2 , and ceased transactions to a_1 . After a_1 's ownership of the domain expired, it continued to resolve to a_1 ; we observe 10 transactions from c to a_1 in this time-period. Similarly, `spambot.eth` changed hands three times, each to a different owner. a_1 managed the domain from April 2022 to April 2023, and a_2 took over in July 2023, maintaining ownership to date. Address c dispatched 13 transactions to a_1 during this ownership phase, but only a single transaction to a_2 during a_2 's control. No transactions occurred in the gap between these registrations. The domain `cryptobuilders.eth` received only one transaction to both a_1 and a_2 from c . Interestingly, both these transactions were of the same value of 1.0 ETH. In all aforementioned examples, c is a non-custodial address.

4.5 Discussion

4.5.1 Countermeasures

In both Coinbase and non-custodial wallets, no warning is shown if users attempt to send funds to recently expired/re-registered domain names (Table 4.2). Adopting such warnings is a straightforward countermeasure that we expect would greatly reduce the security impact of expired ENS domains.

4.5.2 Limitations

Given the unavailability of off-chain ENS domain resolution data, we employed a conservative methodology to identify funds potentially misdirected toward re-registered domains. Even though we anticipate that our methodology is most likely to *underestimate* the total financial losses associated with ENS dropcatching, it is possible that some of the transactions we flagged were intentional, i.e., a user c who had sent funds to a_1 *intended* to send a transaction to a_2 who also happened to re-register an expired domain that used to belong to a_1 . We hope that wallet providers will eventually share their resolution data with researchers so that follow-up work can more authoritatively quantify accidental ENS transactions.

4.5.3 Ethical Considerations

This chapter reports on the analysis of publicly available data from the Ethereum blockchain and the ENS subgraph. We did not interact with any users (benign or malicious) for any of the experiments in this work. Hence,

this chapter does not raise any ethical concerns.

4.6 Chapter Summary

In this chapter, we drew attention to the issue of domain dropcatching in the context of the Ethereum Name Service (ENS) and performed the first empirical study of this phenomenon. We collected the largest dataset of ENS domains to date and identified 241K cases where an ENS domain changed hands to a new owner post-expiration. Among others, we observed that the income towards the pre-expiration wallet of the domain name was significantly higher in re-registered domains vs. domains that expired but were not re-registered. Through careful and conservative analysis of transaction data, we identified 2,633 transactions (or 1,617 if only non-custodial senders are considered) that appear to have been intended for the previous owners of domain names and yet were sent to new owners because of expired and re-registered ENS domains.

Chapter 5

No Wallet for Old Tricks: Introducing Client-Side Defenses Against Cryptocurrency-Based Social Engineering Attacks

5.1 Introduction

As modern systems continue to harden and technical vulnerabilities become increasingly difficult for attackers to exploit, compromising infrastructure through purely technical means has become substantially more challenging. Consequently, adversaries continue to rely on social engineering strategies that manipulate users into performing actions that undermine their own security [158]. Over the past two decades, users on the web have faced a broad spectrum of such attacks (such as phishing and typosquatting) and these threats have been formally recognized by governments and national cybersecurity agencies worldwide [159, 160, 161]. In response, defenders have deployed a variety of mitigations designed to help users identify and avoid these threats. Modern web browsers and email providers, for example, integrate phishing- and typosquatting-detection mechanisms that warn users when they attempt to access known malicious domains [162].

More recently, cryptocurrencies have emerged as a particularly lucrative

medium for social-engineering attacks. Cryptocurrencies are digital assets secured by blockchain technology, enabling peer-to-peer transactions without the need for intermediaries, such as, banks or payment processors. Each cryptocurrency transaction is permanently recorded on an immutable and decentralized ledger, making cryptocurrency transfers effectively irreversible. Attackers frequently exploit this property by deceiving users into sending funds to addresses under their control. In contrast to traditional web services where users may recover compromised accounts or reverse fraudulent transactions, victims in the cryptocurrency ecosystem typically have no recourse once a malicious transfer has been confirmed on the blockchain. In 2024, the US Internet Crime Complaint Center reported a total of 9.3 billion USD in losses to cryptocurrency-related fraud, a large share of which is attributed to social engineering attacks [163].

Several forms of social engineering targeting cryptocurrency users have attracted significant attention due to their prevalence and financial impact [86, 4, 80, 164, 99, 165, 166, 167, 168, 108, 3]. One prominent example is *address poisoning*, in which attackers generate addresses that closely resemble those appearing in a victim’s transaction history and insert them via small transfers [169, 3, 4, 80, 170, 1]. Because wallets prominently display recently used addresses, victims may mistakenly select or copy an attacker-controlled lookalike when initiating a transaction, resulting in irreversible on-chain losses (Section 5.3.1). Public reports document a single address-poisoning incident in 2024 resulting in a loss of \$68.7M [169, 171], while measurement stud-

ies estimate cumulative losses in the hundreds of millions of dollars over a two-year period [3, 4]. To mitigate such risks, users are often advised to rely on blockchain-based naming services such as the Ethereum Name Service (ENS) [172, 126], which map human-readable names (e.g., `johndoe.eth`) to cryptocurrency addresses and reduce reliance on long hexadecimal strings. However, this usability improvement introduces security risks analogous to those observed in DNS, often with more severe financial consequences. Attackers register typographic variants of legitimate ENS names to exploit user input errors, or monitor and re-register expired ENS domains to intercept transactions intended for the original owner (Section 5.3.2). Both these attacks have led to substantial financial losses for ENS domain owners [33, 167, 168, 173].

Prior work has shown that cryptocurrency wallets provide little to no effective protection against social engineering attacks. Guan and Li [80] report that none of 53 popular Ethereum wallets meaningfully defend against address-poisoning attacks, while Muzammil *et al.* [168, 167] find that widely deployed wallets lack defenses against domain-based attacks targeting blockchain naming services. Instead, existing wallet protections primarily rely on third-party blocklists [174, 175, 176, 177].

For instance, MetaMask collaborates with Blockaid, a third-party service that detects and maintains feeds of known malicious addresses [177]. When a user interacts with an address appearing in these feeds, MetaMask displays a warning in the wallet interface. However, to preserve user privacy, MetaMask does not share transaction details with these providers. Consequently,

these services can only flag addresses that have already been identified as malicious and cannot assess whether a user is vulnerable in a given transaction involving a previously unseen address. Such approaches do provide users with protection against known malicious addresses but are inherently insufficient by themselves, as social engineering attacks are often highly targeted and unlikely to be captured promptly by public threat feeds. As a result, users remain vulnerable precisely at the moment they authorize transactions. Analogous to the traditional web, where defenses against social engineering are largely implemented by web browsers and hosting providers, the most promising path toward protecting cryptocurrency users lies within the wallets themselves as they serve as the primary interface between users and the blockchain.

In this paper, we build on this insight and advance the idea that cryptocurrency wallets can deploy client-side, context-aware defenses against social engineering attacks, complementing existing protections that primarily rely on public blocklists. Such defenses can leverage wallet-specific context and user interaction patterns to detect attacks that are otherwise difficult to capture using centralized approaches. To demonstrate the feasibility of this idea in practice, we develop in-wallet defenses against address poisoning, ENS typosquatting, and ENS domain dropcatching attacks by extending the MetaMask browser extension [178], which is currently the most widely used Ethereum wallet [179]. Our mechanisms detect these attacks before a transaction is broadcasted to the blockchain, providing users with an opportunity to protect their funds before they are irreversibly transferred to an attacker.

In our extended version of MetaMask, when a user enters a *poisoned* address or suspicious ENS name, the wallet displays an inline warning directly within the transaction-confirmation interface, informing the user of the specific risk associated with the recipient. These warnings appear at the moment the user reviews the transaction details and require explicit acknowledgement before the user may proceed. We ensure that our design adheres to the coding conventions and interface patterns used within the MetaMask codebase, allowing the defenses to integrate seamlessly into existing workflows without disrupting normal wallet usage.

In total, our detection mechanisms require only 1,356 lines of code, representing 0.21% of the MetaMask codebase by line count. This demonstrates that such defenses can be implemented through targeted and localized engineering efforts. We evaluate our implementation against confirmed address-poisoning attacks reported by Toxin Tagger [1] and find that it successfully detects *all reported cases*. We further benchmark runtime performance and observe that detection executes orders of magnitude faster than routine wallet operations, such as ENS resolution, introducing only negligible overhead. While our prototype is implemented within MetaMask, the defenses themselves are generic and can be ported to other cryptocurrency wallets.

5.2 Background

Ethereum and ERC-20 Tokens. Ethereum is a public, decentralized blockchain that enables users to transfer value and interact with smart

contracts without centralized intermediaries. Transactions are recorded on an immutable ledger, making transfers effectively irreversible once confirmed. Beyond native currency transfers, Ethereum supports programmable smart contracts that enable a wide range of decentralized applications [180]. Fungible assets on Ethereum commonly follow the ERC-20 token contract standard, which specifies a standardized set of functions and events (e.g., `transfer`, `approve`) that define how tokens behave and how wallets and applications should interact with them. As ERC-20 deployment is permissionless, anyone may create and distribute tokens with arbitrary properties.

Ethereum identifies entities using 20-byte addresses, displayed as 42-character hexadecimal strings prefixed with `0x`. These addresses correspond either to externally owned accounts (EOAs), which are controlled by users via private keys, or to smart contracts, which contain executable code and respond to transactions sent to them. From the user’s perspective, both address types are interacted with uniformly through wallet interfaces, which prominently display truncated address representations during transaction workflows.

Blockchain-based Naming Services. Blockchain-based naming services map human-readable identifiers to cryptocurrency addresses, improving usability over long hexadecimal strings. Prominent examples include Handshake [181], Unstoppable Domains [128], Solana Name Service [182], and Ethereum Name Service (ENS) [126], which is the most widely adopted. ENS domains use the `.eth` namespace, and ownership of these names is implemented using ERC-721 tokens, enabling ownership to be recorded and trans-

ferred on-chain. ENS registrations are time-limited and require periodic renewal at a price that depends on the domain’s length (e.g., a 5+ character ENS domain costs \$5 per year) [183]. After expiration, domains enter a grace period and may subsequently be reclaimed by new owners [184, 33, 167].

5.3 Threat Models

In this section, we describe the threat models for the social engineering attacks against which we implement defenses.

5.3.1 Address Poisoning

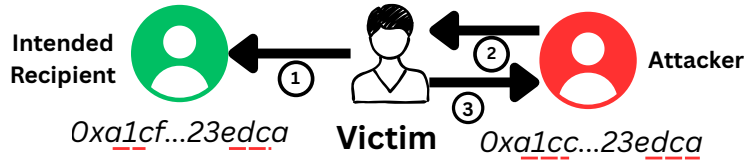
Address poisoning attacks exploit the way users often rely on their wallet’s transaction history when sending funds. Many digital wallets display recent addresses that the user has previously interacted with. Because of this feature, while sending transactions to a known contact, users often select the recipient address from the wallet’s history rather than manually entering the address or copying it from a trusted source. This common user behavior is exploited in address poisoning attacks, which happens in three steps.

First, the victim user makes a legitimate transaction to a trusted recipient address, which gets recorded in their wallet’s recent activity list. Next, attackers generate a large number of cryptocurrency addresses that are visually similar to an address in the victim’s transaction history. To do this, they repeatedly create EOAs until the hexadecimal representation of their address shares a short prefix/suffix with the target (often 5–8 hex characters total).

This choice is also optimal as wallet user interfaces often truncate addresses in the middle for better readability, showing only the beginning and end characters to users. The attacker then sends a tiny-value transaction (such as 0.000001 ETH) from one of the attacker-controlled lookalike addresses to the victim. This causes the attacker’s address to appear in the victim’s recent-activity list inside their wallet. Since many wallets automatically display or suggest recently seen addresses when the user is preparing a new transaction, this “poisons” the history by placing the attacker’s lookalike address where the victim expects to find the legitimate one.

Next to tiny-value transfers, attackers have developed more sophisticated variants of this attack, which use zero-value transfers and counterfeit tokens. In the zero-value variant, the attacker invokes the `transferFrom (sender, receiver, amount)` function from the token smart contract with amount 0 (the token transfer amount) but sets the victim as sender and the lookalike as receiver in the function parameters. Since many ERC-20 implementations permit arbitrary sender/receiver for zero-value calls, the victim’s history now shows an apparent prior “send” to the lookalike. In the counterfeit-token variant, the attacker deploys a fake ERC-20 token with a familiar name or symbol, then logs a transfer from the victim to the lookalike for the same nominal amount; because token names/symbols are unrestricted, near-copies are trivial, and the attacker can script transfers on behalf of any address.

Both variants increase plausibility in the victim’s recent-activity list, raising the chance of a successful address poisoning attack. Later, when the



Victim's Transaction History

From	To	ERC-20 Token Amount	
0xa1cf...23edca		20.0	Recipient → Victim
	0xa1cf...23edca	12.3	Victim → Recipient
	0xa1cc...23edca	12.3	Poisoning Transfer
	0xa1cc...23edca	7.7	Victim → Attacker

Figure 5.1: Illustration of an address poisoning attack.

user intends to send funds to the legitimate recipient, they open their wallet's recent addresses list and choose the attacker-controlled lookalike address, believing it is the one they actually intend to use as the prefix/suffix match and the interface hides the full address. The user then initiates a transfer to the attacker-controlled address, and irreversibly loses their funds to the attacker. We illustrate this attack in Figure 5.1.

5.3.2 ENS Attacks

ENS domains are often cited as a solution to the challenges posed by address poisoning attacks, as they are easier to verify visually compared to addresses. However, ENS domains suffer from most of the same vulnerabilities as traditional DNS domains, including typosquatting and dropcatching attacks, both shown in Figure 5.2.

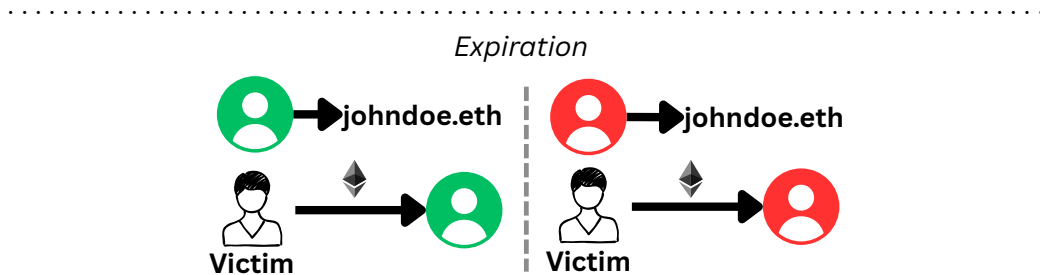
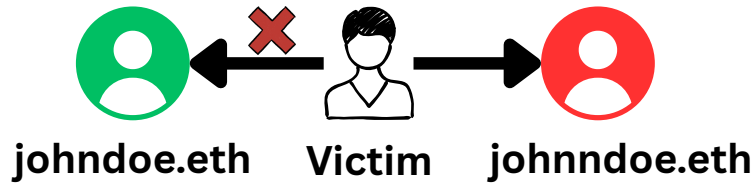


Figure 5.2: Illustrations of ENS-based social engineering attacks: typosquatting (top) and domain dropcatching (bottom).

5.3.2.1 Typosquatting Attacks.

Typosquatting attacks are a long-standing threat on the traditional web, where adversaries register domain names that closely resemble popular legitimate ones. These attacks exploit the fact that users often mistype URLs in their browser’s address bar, causing them to land on the attacker’s site. Once on the attacker’s page, victims may be deceived into entering sensitive information, downloading malware, or completing fraudulent financial transactions. Contrastingly, if a user accidentally mistypes the ENS domain to the attacker-controlled domain, the ENS resolver immediately returns the attacker’s address and the consequences are more direct. Any funds that the user sent will now be transferred into the attacker’s wallet. As Ethereum transactions are irreversible once confirmed, even a single-character mistake results in an immediate and permanent loss of funds.

5.3.2.2 ENS Dropcatching.

Dropcatching in ENS refers to the practice of registering recently expired (or “dropped”) ENS domain names that were not renewed by their previous owners. This is done so that attackers can take advantage of the residual trust and recognition associated with these domains. An ENS domain that has been in use for some time may receive funds from other users who are familiar with it but unaware that it has changed ownership, believing they are sending funds to the previous owner. According to Muzammil *et al.* [167], attackers prefer to register dropped ENS domains that were previously linked to wallets with large balances. As with typosquatting, dropcatching does not require compromising wallets or the ENS protocol, only exploiting predictable user behavior and the trust previously associated with the domain. Moreover, even if a dropcatching or typosquatting ENS domain is registered without any malicious intent, any funds mistakenly sent to it are still irretrievably lost to the new owner.

5.4 Attack Detection Layer

On the traditional web, responsibility for detecting and preventing social engineering attacks is largely delegated to upstream infrastructure, including web browsers, search engines, email gateways, and hosting providers. These systems automatically block known malicious domains and filter phishing content, so that as few users as possible are exposed to them. However, in the context of cryptocurrency transactions, the digital wallet is the sole interme-

diary between the user and the blockchain. Unlike the traditional web, there is no browser-equivalent safety layer capable of intercepting suspicious activity before a transaction is finalized. Once a user enters an address or selects an ENS name, the wallet is the only component with the necessary visibility to detect typographical mistakes or flag malicious addresses prior to issuing a transaction on the blockchain. For this reason, we argue that integrating attack-detection mechanisms directly into the wallet offers the most effective and practical defense against social engineering attacks in the cryptocurrency ecosystem.

To implement the defenses described in Section 5.3, we extend the open-source MetaMask browser extension wallet, which is the most widely used Ethereum wallet at the time of writing [179]. As MetaMask presents the same flow for benign and malicious addresses alike (including ENS domains), users see no visual cue to distinguish a risky transaction from a safe one, making it harder for them to protect themselves against social engineering attacks. Figure ?? in Appendix ?? shows a typical Ethereum transaction flow (without any malicious activity detection) using the MetaMask wallet. Our modifications augment the transaction-confirmation interface by incorporating additional security checks and warnings that will be shown to the user when they are confirming the transaction.

We implement three detection mechanisms corresponding to the attack vectors discussed earlier, and whenever a transaction triggers any of these mechanisms, the wallet displays a prominent warning, requiring the user to

explicitly acknowledge the risk before proceeding. This design is in-line with MetaMask’s existing threat-warning infrastructure while extending it to cover social-engineering attacks specific to address poisoning and ENS names.

5.5 Detection Mechanisms

In this section, we describe the specific detection mechanisms we implement inside the MetaMask wallet to defend against the attack vectors outlined in Section 5.3. We note that our implementations can be adapted to other wallet software across different device types, including mobile wallets and hardware wallets with companion applications. The core detection logic remains the same, with only adjustments needed to accommodate different storage models or user interface designs. Illustrations of the detection workflows for each attack vector are shown in the Appendix (Figures ??, ??, and ??).

5.5.1 Address Poisoning Detection

To defend against the address poisoning attack described in Section 5.3.1, we implement a client-side detection mechanism inside the MetaMask wallet. The detection logic is distributed across three components: (i) A state-management layer that maintains the core detection algorithm, (ii) A set of UI hooks that expose this logic to the interface, (iii) A confirmation-flow alert system that warns users during transaction preparation. This integration allows the wallet to evaluate the safety of a recipient address as soon as it is entered

in the *send* form while the user is preparing a transaction. If the address is flagged as potentially poisoned, the wallet displays an alert to the user before the transaction is finalized (see Figure ??).

The mechanism relies on two pieces of locally stored information: (i) A record of all addresses to which the user has previously sent transactions (outgoing transaction history), and (ii) A record of all addresses from which the user has previously received transactions (incoming transaction history). These two transaction histories are sufficient to capture the characteristic interaction pattern of address poisoning without requiring external services or global blocklists.

The wallet compares the entered address against recipient addresses in the user’s outgoing and incoming history by matching configurable prefix/suffix characters. Prior work suggests that checking 7 characters (3 from the prefix and 4 from the suffix) balances false-positive rate with effective detection of address-poisoning attempts [3, 170]. We revisit these thresholds in Section 5.6. If the entered address is both unfamiliar and visually similar to a known recipient, the wallet classifies the transaction as potentially poisoned. It then displays an inline warning during the confirmation step, prompting the user to double-check the recipient before proceeding. The warning does not block the transaction, but requires explicit acknowledgement from the user before proceeding with the transaction. All checks run locally and in real time, ensuring that the defense remains effective even when attackers generate unique lookalike addresses for each victim.

5.5.2 ENS Attack Detection

5.5.2.1 ENS Typosquatting Detection.

To mitigate the ENS typosquatting attack described in Section 5.3.2, we implement a client-side detection mechanism inside the MetaMask wallet. The design follows the same architectural pattern as the address poisoning defense, consisting of (i) a state-management layer that performs domain resolution and typo analysis, (ii) UI hooks that expose warning information to transaction interfaces, and (iii) a confirmation-flow alert system that warns the user whenever a potentially mistyped ENS name is detected (Figure ??).

The typosquatting detection pipeline is triggered whenever the user enters an ENS domain in the recipient field of the send interface. Instead of immediately resolving the name to an Ethereum address, the wallet first retrieves the set of ENS domains the user has interacted with in past transactions. As MetaMask does not, by default, maintain a history of ENS domains used by the user, we extend the wallet to store this information locally in browser extension’s storage (which MetaMask already uses extensively to maintain user metadata). This extension storage is a persistent key-value store that remains available across sessions and is sandboxed on a per-extension basis. Hence, only MetaMask’s own scripts may access this data. After each successful transaction involving an ENS-based recipient, the domain is added to this local store.

The data is automatically synchronized across devices associated with

the same browser profile. On other platforms, equivalent state can be maintained using platform-provided persistent storage. For instance, the Android application for MetaMask or any other wallet can store state in sandboxed persistent file storage [185].

Once the reference set is retrieved, the wallet evaluates whether the newly entered domain is suspiciously similar to any previously used domain. To detect ENS typosquatting, the wallet compares the entered domain against each domain in the reference set using a set of predefined typo models, including single-character substitutions (e.g., `johndoe.eth` $\rightarrow$ `johnxoe.eth`), deletions (e.g., `johndo.eth`), insertions (e.g., `johndfoe.eth`), duplications (e.g., `johnddoe.eth`), adjacent-character transpositions (e.g., `johndeo.eth`), and trailing pluralization (e.g., `johndoes.eth`). These typosquatting models have been used extensively in prior work on detecting typosquatting on both ENS and DNS domains on the traditional web and capture common typographical mistakes that users make when entering domain names [12, 186, 29, 14, 15, 11, 168]. The comparison between the entered domain and each previously used domain is performed using an edit-distance metric known as the Damerau-Levenshtein distance, which is a string similarity metric specifically designed to model the types of mistakes humans naturally make when typing [187]. It measures the minimum number of single-character operations required to convert one string into another.

If the entered domain name differs by a single edit from a previously used domain and the typo model matches one of those listed above, the wallet

marks the lookup as suspicious and attaches a typosquatting warning to the resolved address. This warning is shown during the transaction confirmation step through the wallet’s UI alert system. The warning does not block the transaction but prompts the user to verify the domain’s correctness.

5.5.2.2 ENS Dropcatching Detection.

To detect ENS dropcatching attacks, we implement a client-side mechanism in MetaMask that tracks the historical resolution of ENS domains the user has previously transacted with.

Whenever the user enters an ENS name in the recipient field, the wallet resolves the domain and retrieves the Ethereum address it currently maps to. In parallel, the wallet consults a locally stored historical record of domain-to-address mappings that were saved after successful past transactions involving ENS names. This allows MetaMask to determine whether the domain currently resolves to the same address as before or whether its resolution has changed since the last interaction.

If the domain has never been used by the user, or if there is no stored history for the domain, the wallet treats the lookup as a first-time use and does not trigger any warnings. However, if the domain has been used previously, the wallet compares the current resolved address with the historical address recorded at the time of the last transaction. A mismatch indicates that the domain now resolves to a different address than before, which is a sig-

nal of a potential dropcatching attack. In such cases, the wallet classifies the transaction as high-risk and displays a warning in the confirmation interface informing the user that the destination address associated with the domain has changed (Figure ??).

Similar to address poisoning and typosquatting detection, the warning does not block the transaction but prompts the user to verify the legitimacy of the address change. This is particularly important because ENS ownership changes and administrative updates do occur legitimately, and the user might actually want to send the transaction to the new owner of the domain. Nevertheless, the wallet’s detection mechanism ensures that the user is aware of the change before authorizing a transfer.

All checks run locally and in real time, using only wallet-stored data and publicly available ENS resolution results. No external APIs, remote services, or global blocklists are required.

5.6 Evaluation and Discussion

5.6.1 Runtime Performance Analysis

In this section, we describe our experiments for evaluating the runtime performance of our detection mechanisms. High runtime overhead could negatively impact the user experience in cryptocurrency wallets, so it is important to assess whether these defenses can operate efficiently during normal wallet usage. We evaluate each attack vector separately.

For address-poisoning detection, we measure runtime across accounts with varying numbers of historical transactions, since the detection logic compares the entered recipient address against all addresses in the user’s transaction history. We evaluate performance under four transaction history sizes: 20, 500, 1,000, and 10,000 transactions. Similarly, for ENS typosquatting and ENS domain dropcatching, we measure performance while varying the number of previously used ENS domains stored in the extension’s local storage, as the detection mechanisms compare the entered domain against this locally maintained reference set.

All experiments were conducted using the same browser instance, with no additional extensions or tabs loaded. Each measurement was repeated three times, and we report the average runtime. Across all experiments, we observe that the detection mechanisms complete within tens of milliseconds. Drop-catching detection is the fastest, consistently executing in under 10 ms. The

only notable outlier is ENS typosquatting detection with a history of 10,000 domains, which takes approximately 290 ms. These overheads remain negligible in practice, particularly given that routine wallet operations incur higher latency. For instance, resolving an ENS domain consistently takes around 150 ms.

5.6.2 Testing Detection Effectiveness

Generating Ethereum addresses with chosen prefixes or suffixes is computationally expensive due to the randomness of private-key generation and the lack of structural shortcuts in ECDSA-based address derivation [188]. Attackers must repeatedly generate keypairs until an address meets the desired string pattern, making the search effort grow exponentially with every additional hexadecimal character they attempt to control. Ye *et al.* [170] show that even on a high-end multi-core machine, producing an address with seven specific hex digits requires several hours of continuous computation, whereas targeting ten specific digits increases the workload to more than 600 days. In the context of address-poisoning detection, lowering the similarity threshold increases the likelihood of false positives, while raising it risks missing attacker-generated lookalikes. Prior work has shown that requiring a 3-character prefix and 4-character suffix match can capture a substantial portion of real-world poisoning attempts [3]. Building on these observations, our defense allows users to configure their preferred prefix and suffix thresholds according to their own risk tolerance. By default, we adopt the same (3, 4) split.

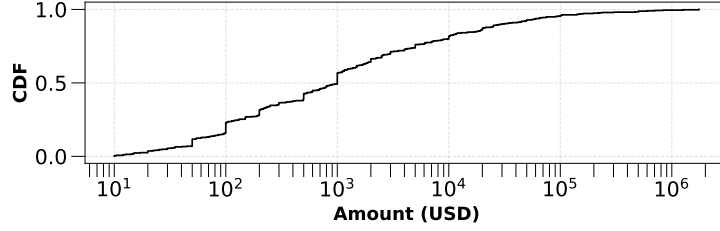


Figure 5.3: CDF of the total USD value lost in the address-poisoning attacks reported by Toxin Tagger [1] that are successfully detected by our MetaMask in-wallet poisoning defense.

To evaluate the effectiveness of our address-poisoning detection implementation, we test our implementation against the dataset published by Toxin Tagger [1], a real-time feed of poisoning attacks compiled by Tsuchiya *et al.* [3]. Using the same parameters as Tsuchiya *et al.* (a match of at least 3 prefix and 4 suffix characters) we achieve 100% detection coverage over all poisoning attacks listed in the dataset. The total amount of funds lost through these 436 address poisoning transactions was 11M USD. Figure 5.3 displays a CDF of the losses of funds through these transactions. Increasing the similarity threshold reduces detection coverage and is therefore not recommended in practice. Owing to the high entropy of Ethereum addresses, the default (3, 4) prefix-suffix split already yields a low probability of false positives. When the threshold is raised to 5 prefix and 5 suffix characters, the detection rate drops substantially, missing roughly two-thirds of the attacks, as expected under a stricter matching requirement. While more stringent configurations, such as (4, 4), further decrease the likelihood of false positives, they do so at the cost of significantly reduced detection coverage, making them overly conservative for practical deployment.

To evaluate our methodology for detecting ENS typosquatting attacks, we collected registered typosquatting variants of ENS domains reported by Muzammil *et al.* [168]. Their study identifies typosquatting domains targeting popular cryptocurrency influencers that actively receive transactions from unsuspecting users. From this dataset, we selected typosquatting variants corresponding to each of the six typosquatting models described in Section 5.5.2. As a representative example, several variants such as `fitalik.eth` and `vialik.eth` target the ENS domain `vitalik.eth`, owned by the Ethereum founder Vitalik Buterin. We evaluated our implementation using these variants and observed that the system successfully detected all attack instances, provided that a transaction to the legitimate domain `vitalik.eth` had occurred prior to sending a transaction to the typosquatting variants. To evaluate ENS dropcatching detection, we registered an ENS domain and first performed a transaction through that domain. We then modified the address associated with the domain to a different address, simulating the behavior of a new owner who acquires an expired ENS name and updates its resolution. In this scenario, our implementation correctly generated a warning indicating the change in address.

We note that our detection methodology relies on the victim’s prior interaction with a benign address or ENS domain. Consequently, additional safeguards are required in cases where a victim encounters a malicious address or domain without having previously interacted with the legitimate counterpart. Currently, wallet providers maintain blocklists of known malicious addresses

and display warnings when users attempt to interact with them. However, blocklists for ENS domains are not maintained. Wallet providers could extend their existing security mechanisms to include ENS domains and further perform client-side analysis of destination addresses before a transaction is finalized. The traditional web ecosystem offers useful analogies. For example, security vendors often analyze newly registered DNS domains to identify suspicious activity associated with newly created infrastructure [189, 190, 76]. Similarly, wallets could flag addresses that are newly created or have very few transactions, as these characteristics may indicate higher risk. Last, to the extent that a list of popular and benign ENS domains can be curated, these could be preloaded in a wallet, conceptually similar to preloaded HSTS websites on the regular web [191]. In this way, even if, e.g., a user has never interacted with `vitalik.eth`, they would still see a warning if they try to send funds to `fitalik.eth`.

5.6.3 Future Directions

If cryptocurrency wallets incorporate in-wallet defenses of this form, users will be alerted before completing malicious transfers resulting from attacks specifically tailored to them, and the associated losses, such as the ones shown in Figure 5.3, will likely be prevented. Our results demonstrate that lightweight, client-side detection mechanisms can substantially reduce users' exposure to social engineering attacks without disrupting normal wallet workflows. Moving forward, integrating similar defenses across the broader ecosys-

tem could significantly strengthen user protection. Wallet developers can extend our approach to the same or additional attack vectors, as well as incorporate adaptive thresholds that respond to evolving attacker strategies.

5.7 Chapter Summary

In this chapter, we presented the first in-wallet defenses against address poisoning, ENS typosquatting, and ENS domain dropcatching—three major classes of cryptocurrency-based social engineering attacks. We integrated our detection mechanisms into the MetaMask wallet, providing contextual and real-time warnings at the moment users make decisions that could irreversibly compromise their funds. We demonstrated that these mechanisms offer effective protection against attacks that routinely lead to significant financial losses, while introducing only minimal performance overhead and requiring lightweight modifications to the existing wallet codebase. We hope that our patches will be adopted by the MetaMask wallet and that our proposed defense mechanisms will eventually become standard across all wallet software.

Chapter 6

The Poorest Man in Babylon: A Longitudinal Study of Cryptocurrency Investment Scams

6.1 Introduction

In September 2024, the US Federal Bureau of Investigation released its *Cryptocurrency Fraud Report 2023*, reporting on 69,000 complaints from the public regarding cryptocurrency-related financial fraud [102]. Among the various types of fraud, *investment fraud* emerged as the most common complaint, accounting for the largest portion of reported losses. Similar statistics were reported by the Australian Competition and Consumer Commission [103] and the UK Financial Conduct Authority [192]. Typical cryptocurrency investment scams are propagated through professional-looking websites that promise unrealistic returns on small investments. Through sophisticated social engineering tactics, scammers exploit the victims' trust, leading them to believe that their investments are secure, only for the victims to lose all their deposited funds.

To attract prospective victims to their sites, scammers commonly abuse popular social media platforms, usually by creating fake influencer profiles or

by hacking legitimate accounts and luring the followers of the compromised account to invest in cryptocurrencies [193, 194, 195]. At the same time, identifying these scammers at large remains a challenge since they can effectively hide among the hundreds of millions of legitimate users of these social media platforms. For example, Li *et al.* [93] reported that scammers often leave comments on popular YouTube channels, persuading users to invest in cryptocurrency through their scam websites. However, their analysis was limited to just 20 popular channels, and they still needed to *manually* interact with scammers before the scammers shared the URL of their cryptocurrency investment scam websites. As such, while other forms of cryptocurrency scams have been studied through prior large-scale studies [86, 196, 99, 197, 122], the true scale of cryptocurrency investment scams remains unknown.

In this paper, we introduce **Crimson**¹, a system that enables real-time detection of cryptocurrency investment scam websites in the wild without relying on social media and without the need to interact with scammers before they share their URLs. **Crimson** processes each website that receives a TLS certificate, leveraging Certificate Transparency logs, and gradually narrows down its search to identify cryptocurrency investment scam websites through a series of filters. Eventually, each narrowed down website is validated using the large-language models **Llama3:70b** and **GPT-4** to ensure that **Crimson** can run in a fully automated fashion without the need for any human intervention for classification.

¹ **Crimson**—CRyptocurrency InvestMent Scam detectiON

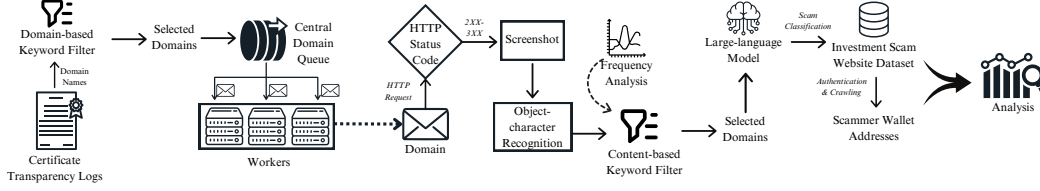


Figure 6.1: A schematic representation of *Crimson*’s pipeline

We utilize *Crimson* to conduct the first longitudinal analysis of cryptocurrency investment scams in the wild, processing billions of domain names over an 8-month period (January–September 2024). During that time, *Crimson* recorded 43,572 unique scam websites. We find that the detected scam websites are hosted on 19,110 unique IP addresses, with 10% of them responsible for hosting more than half of the scam websites. This suggests that a relatively small number of hosts and, by extension, a limited number of hosting providers and scammers are responsible for hosting a large portion of the identified scams. Apart from IP addresses, we cluster scam websites based on their web design, JavaScript inclusions, and other information such as emails and phone numbers. Using these clustering techniques, we were able to detect commonalities between 88% of all detected investment scam websites, with most scam websites belonging to more than one cluster at a time. Almost half of all detected sites remained active at the end of our observation period despite reports of fraudulent activities on social media platforms, suggesting that investment scams are persistent and, because of their facade of legitimacy, remain online over extended periods of time. By extracting scammer-owned wallet addresses from the detected scam websites, we perform a transaction analysis to estimate the financial losses associated with the detected investment

scams. We find that 2.04M USD were sent to scammer-owned wallet addresses through Bitcoin and Ethereum payments, originating from only 6.7% of all detected scam websites. Extrapolating this number points to tens of millions of US dollars in losses across all these websites.

Lastly, we report that popular block-lists are unable to provide extensive coverage of the detected cryptocurrency investment scam websites. A video demonstration of cryptocurrency investment scam websites detected by **Crimson** can be found here [198]. Our contributions are summarized as follows:

- We develop **Crimson**, the first system to detect cryptocurrency investment scam sites as soon as they are created.
- We perform detailed analysis on the detected scam websites and the financial losses that resulted from them, offering insights for cryptocurrency users and web hosting providers.
- To encourage future research in this area and enable researchers and developers to build upon our work, we have released our dataset and open-sourced **Crimson**'s source code [199].

6.2 System Design

The architecture of **Crimson** is illustrated in Figure 6.1. It comprises six modules:

- (1) Domain Selection
- (2) Distribution

- (3) Content-based Selection
- (4) LLM-assisted Classification
- (5) Account Creation and Wallet Extraction
- (6) Analysis

6.2.1 Domain Selection and Distribution

6.2.1.1 Certificate Transparency

Our goal is to curate a dataset of cryptocurrency investment scam websites that is representative of the true scale of the problem. As such, we need a comprehensive and reliable source of domain names. Certificate Transparency logs (CT logs) have been widely used in security research for a variety of applications involving domain names, including the detection of malicious bot activities [200], identification of cryptocurrency giveaway scams [99], and enhancement of phishing website detection [201, 202, 203]. CT is a framework designed to monitor and log the issuance of TLS certificates in a public, append-only log, facilitating the detection of unauthorized certificates. Modern web browsers enforce CT requirements by treating certificates that do not comply with these policies as untrusted, resulting in blocked connections and security warnings in the browser [204]. Given these browser policies and scammers’ incentive to leverage user trust to solicit funds, it is reasonable to assume that investment scam websites will seek the issuance of TLS certificates for their domain names and that, consequently, such domains will appear in CT logs. Moreover, CT logs provide approximately one million TLS cer-

tificates being issued and subsequently logged every hour, therefore providing us with a comprehensive set of domains, ensuring that our results provide a broad view of the threat landscape of cryptocurrency investment scams. We deploy a local server using Certstream [205] to receive CT logs in real-time, capturing domain names from certificates as soon as they are issued.

6.2.1.2 Domain Selection

Each domain fetched from CT logs enters the first processing stage in the **Crimson** pipeline: Domain Selection. Initially, domains are dissected into individual keywords using a customized model based on Word Ninja [206]. Customizing the keyword segmentation model is crucial for identifying non-standard keywords, particularly those commonly found in the cryptocurrency domain, such as “eth” and “btc.” For instance, `btcethinvestments[.]com` is segmented into `['btc', 'eth', 'investments']`. We compile a dataset of known cryptocurrency investment scam websites from URLscan [207] and apply our model to split the domain names into distinct keywords. We select 36 distinct keywords from the resulting keyword-set that frequently occurred in the scam dataset from URLScan. This selection process is intentionally liberal to minimize the risk of omitting potential scam domains at this phase while filtering out irrelevant websites to optimize resource usage in downstream modules. The list of keywords is provided in the **URL-filter** column of Table 6.1. All domains having at least one keyword from the keyword-set are sent to the next processing stage. Note that we apply stemming [208] prior to compar-

ing word lists. Stemming is a natural language process that reduces words to their base or root form. For example, the words “investors” and “investing” are both reduced to “invest”, ensuring consistency in word comparison.

6.2.1.3 Distribution

Given that approximately 200,000 domain names pass through our *Domain Selection* stage per day, we created a distributed setup to process these domains. Selected domains are dispatched into a central queue, from which 24 worker nodes (distributed across three servers) fetch and process them. Each worker node retrieves one domain at a time from the queue and signals completion after completing all processing tasks. In case of any failure during processing, the domain is re-queued to ensure no domain is left unprocessed.

6.2.2 Content-based Selection

When a domain is picked up by one of the 24 workers, it undergoes a three-stage evaluation to determine its active status and relevance to cryptocurrency investments.

6.2.2.1 Responsiveness

A domain entering the **Crimson** pipeline indicates that it has been issued a TLS certificate, but does not guarantee that a website is operational on that domain. To account for potential delays in website responsiveness, we implement a 12-hour buffer between pushing to the queue and when a domain

becomes available to our worker nodes. To verify responsiveness after the 12-hour delay, the worker sends an HTTP request to that domain. Domains are passed onto the next check if the HTTP response has a status code within the 2XX-3XX range, and are discarded otherwise.

6.2.2.2 Screenshot

A full-page screenshot of the website is captured using Selenium [209] and used for analysis (§6.3.2.2).

6.2.2.3 Text Extraction

Using an Object Character Recognition (OCR) tool [210], we extract the text from the captured screenshot. This method is advantageous over merely retrieving HTML, as it also captures text from images and JavaScript-rendered elements, which play a role in the professional theme of the website used to gain the victims’ trust.

The text retrieved using OCR is tokenized, *stemmed* into individual keywords, and compared against a second keyword list composed of words commonly found in the homepage text of known cryptocurrency investment scam websites from URLScan. These keywords are grouped into three categories: *Investment*, which includes variations of the word “invest”; *Coins*, which includes cryptocurrency-related terms like “btc” and “btcusd”; and *Context*, which consists of commonly used scam-related terms such as “deposit”, “withdraw”, as well as words designed to create a sense of urgency, trust, and le-

gitimacy, such as “secure” and “safe.” If the stemmed OCR-generated tokens contain a word from each of these groups, it is forwarded to the next processing stage. As **Crimson** identifies scam websites over time, we perform a frequency analysis to find any recurring words missing from our keyword list, adding them to refine the keyword list. The final list includes a total of 82 keywords and is provided in Table 6.1.

6.2.3 LLM-assisted Classification

Previous studies have relied mainly on human intervention to categorize malicious web pages [12, 99]. However, manual categorization is impractical for **Crimson**, given the total of approximately 320,000 domains processed through the content-based selection module. In contrast, recent advances in large-language models (LLMs) have demonstrated their effectiveness in automating repetitive tasks across multiple domains [211, 212, 213, 214, 215, 216, 217].

As the final step in detecting scam websites, we utilize LLMs to classify websites as either *scam* or *non-scam*. To select the most suitable LLM for our task, we evaluate six popular models available at the time, as shown in Table 6.2. We manually categorized a random sample of 300 websites that had passed the content-based filter, ensuring a balanced distribution, with half identified as scams and the other half as non-scams. The classification process involved assessing indicators of fraud such as objectively implausible claims (e.g., 50% profit per week), fake reviews, suspicious phone numbers, and counterfeit certificates (§6.3.2). Each LLM was tasked with classifying

Table 6.1: Keyword filters used in the URL-filter and Content-filter modules

#	URL-filter	Content-Filter		
		Invest Words	Coin Words	Context Words
1	crypto	invest	cryptocurrency	deposit
2	fx		crypto	withdraw
3	earn		bitcoin	reward
4	deposit		ethereum	growth
5	trade		cardano	gain
6	capital		ripple	capital
7	invest		binance	potential
8	global		shiba inu	wallet
9	bit		dogecoin	safe
10	mining		solana	secure
11	ltd		tether	fund
12	finance		tron	profit
13	trade		polkadot	insurance
14	miner		eth	wealth
15	trust		btc	send
16	profit		xrp	transfer
17	asset		ada	sell
18	cardano		bnb	buy
19	funding		shib	trade
20	capitals		doge	asset
21	fund		sol	client
22	limited		usdt	solution
23	chain		trx	funding
24	digital		dot	
25	btc		algo	
26	assets		litecoin	
27	wealth		chainlink	
28	coin		uniswap	
29	option		pancakeswap	
30	prime		avalanche	
31	bitcoin		neo	
32	exchange		iota	
33	money		aave	
34	eth		luna	
35	ethereum		synthetix	
36	cryptocurrency		theta	
37			grt	
38			linch	
39			sushi	
40			matic	
41			btcsd	
42			usdbtc	
43			ethusd	
44			usdeth	
45			adausd	
46			usdada	
47			xrpusd	
48			usdxrp	
49			bnbusd	
50			usdbnb	
51			shibusd	
52			usdshib	
53			dogeusd	
54			usddoge	
55			solusd	
56			usdtusd	
57			usdusdt	

these websites using the following uniform prompt: “You are a financial advisor programmed to respond in JSON format. Your responses are limited to

Table 6.2: Performance and cost efficiency of LLMs in classifying cryptocurrency investment scam websites. The hybrid approach using *GPT-4 + LLama3:70b* offers a balance between performance and cost.

LLM	Accuracy (%)	Estimated Total Cost (USD)
GPT-4	90	1200
GPT-4 + Llama3:70b	88	130
Llama3:70b	87	0
GPT-4 Vision	79	1800
Mistral:7b	67	0
Llama2:70b	59	0
Llama2:13b	54	0

‘yes’ or ‘no’, represented by the ‘answer’ key, and you must provide a one-word reasoning for your decision under the ‘reason’ key. Be sure of your answer. Determine if the provided text likely originates from a cryptocurrency investment scam website, characterized by promises of high returns from cryptocurrency investments. If the text suggests a low probability of being a scam, does not prompt users to log in/sign up, seems like a news site, or does not solicit users to contact the site for investing in cryptocurrency, respond ‘no’.”

Along with the prompt, we provided OCR-extracted text for the LLMs to reference when making their classifications. For the **GPT-4 Vision** model, we supplied a full-page screenshot instead of text, as it can process visual content directly. The accuracy and total estimated cost of each of the LLMs evaluated are presented in Table 6.2. Our findings show that the **GPT-4** model yielded the most accurate classifications. However, in terms of operational cost, the **GPT-4** and **GPT-4 Vision** models each cost 10 USD per 1M input tokens and 30 USD per 1M output tokens. Meanwhile, **Llama3:70b** offers a cost-effective solution and achieves 87% accuracy—comparable to **GPT-4**—but occasionally

fails to provide a conclusive *yes* or *no* answer, a limitation not observed in GPT-4. To balance accuracy with cost effectiveness, we adopt a hybrid approach and primarily use the Llama3:70b model for classification. In cases where it produced inconclusive results, we route the query to the GPT-4 model for final verification, which yields an overall accuracy of 88%.

6.2.4 Account Creation and Wallet Extraction

Once scam websites are identified using LLMs, **Crimson** automates the process of retrieving wallet addresses owned by scammers where victims are instructed to send funds. This requires interacting with the websites as a typical user, which includes signing up, logging in, and navigating the site’s internal pages. After logging in, users are typically presented with investment plans, cryptocurrency types, and wallet addresses to transfer their investments into. This requirement for authentication is unique to investment scams, as scammers aim to make their services appear more legitimate. In contrast, other forms of cryptocurrency scams, such as giveaway scams [99], typically display the wallet address directly on the homepage, making it easier to crawl scammer wallet addresses.

Crimson first explores the website’s inner pages to locate the sign-up page. Pages containing two or more password fields or specific keywords in the URL are flagged as sign-up pages. Upon detecting a sign-up page, **Crimson** fills in the form fields, typically including first name, last name, country of residence, username, password, and other non-text elements like drop-downs or radio

buttons. To generate unique email addresses for each registration, we use Mailinator [218], using a dictionary of common first and last names combined with a private email domain. This approach ensures that email addresses are not overly reused, reducing the likelihood of raising suspicion among colluding scammers. If scammers detect repeated use of the same email addresses, they could block our connections to their websites, which would risk losing access to future scam websites they might create and the associated wallet addresses. After completing the form, **Crimson** submits the information to complete the sign-up process.

Next, **Crimson** identifies the login page and logs in using the credentials created during the sign-up process. Scam websites then typically redirect users to a dashboard where they can view various investment packages, withdraw or transfer funds, and, most importantly, deposit funds. **Crimson** directs to the deposit page of the scam website and uses **iocsearcher** [219] tool to extract wallet addresses. It also takes Screenshots and stores the HTML code of each page visited during crawling.

Automating the authentication process in arbitrary websites is a known difficult problem [220]. For instance, many require solving CAPTCHAs, or contain a secondary authentication process where users will have to wait till the website administrators provide them access to the user’s profile and dashboard. When automated crawling successfully authenticates to a website but fails to retrieve the wallet address, we manually navigate through the site’s structure by utilizing credentials **Crimson** used to login to the same website to extract

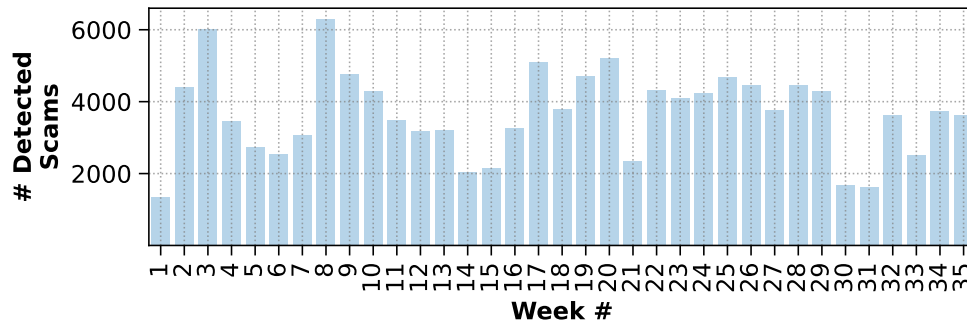


Figure 6.2: Weekly count of unique scam websites discovered by Crimson

this critical information. Even when **Crimson** successfully logs into scam websites, finding the wallet address can be difficult as it is often deep within the site, requiring navigation through multiple links or dropdown menus. We also encountered instances where the deposit page did not reveal the associated wallet address due to website bugs. These complexities result in a low success rate in automatically identifying wallet addresses from scam websites. However, the wallet addresses that we do collect still reveal substantial financial losses tied to investment scams (§6.4).

6.3 Scam Website Analysis

In this section, we provide a comprehensive analysis of our dataset of investment scam websites and associated wallet addresses.

From the approximately 25 million domain names that **Crimson** parses daily through CT logs, it detects an average of 189 unique cryptocurrency investment scam websites each day. Figure 6.2 shows the weekly number of unique websites that **Crimson** detected over our 8-month deployment period.

We identified a total 43,572 unique cryptocurrency investment scam domain names (comprising of 38,365 unique second-level domains) over the first 8 months of 2024, resolving to 19,110 unique IP addresses.

6.3.1 Domain Name Characteristics

We analyze the domain name characteristics of cryptocurrency investment scam websites, focusing on both the top-level and second-level domains. For comparison purposes, we collect data on the top-level domains (TLDs) used by the top 10K websites listed by Tranco [31] as of August 25, 2024.

In terms of the most popular TLDs, we find that the majority of websites in both datasets use common TLDs such as *.com*, *.net*, and *.org*, with *.com* being the most prevalent, accounting for 64% of all scam websites and 50% of the top 10K dataset. The widespread use of these reputable TLDs by scammers suggests that they are willing to pay a premium to create a sense of legitimacy and increase trustworthiness with potential victims. Beyond top-level domains, we examine second-level domain name patterns and observe that only 10 words from the *Domain Selection* module’s keyword list account for 71% of scam websites, compared to 0.6% of websites in the Tranco top 10K. Tables 6.3 and 6.4 list the number of websites across the most popular top- and second-level domains.

6.3.2 Clustering

Table 6.3: Top 5 most frequent TLDs among investment scam websites

TLD	Detected Scams	Tranco Top 10K
com	27,955 (64%)	5,101 (51%)
net	2,394 (5%)	456 (5%)
org	2,079 (5%)	538 (5%)
online	1,264 (3%)	6 (1%)
ltd	1,012 (3%)	0 (0%)
(Total)	34,704 (80%)	6,101 (59%)

Table 6.4: Top 10 words in investment scam domain names detected by Crimson

Word	Detected Scams	Tranco Top 10K
trade	9,706 (22%)	7 (1%)
crypto	4,458 (10%)	2 (1%)
fx	4,078 (9%)	2 (1%)
invest	4,025 (9%)	0 (0%)
coin	3,181 (7%)	4 (1%)
capital	2,926 (6%)	4 (1%)
bit	2,664 (6%)	24 (1%)
global	2,249 (5%)	21 (1%)
bitcoin	1,776 (4%)	3 (1%)
mine	1,551 (4%)	0 (0%)
(Total)	71%	11%

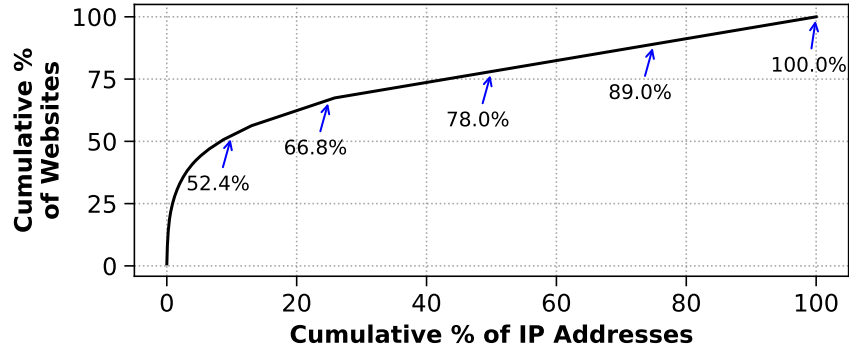


Figure 6.3: Cumulative Distribution of investment scam websites over IP Addresses. A majority of scam websites are hosted on a small percentage of all IP addresses

6.3.2.1 IP-based Clustering

Crimson resolved the 43,572 investment scam websites and identified 19,110 unique IP addresses. Our analysis reveals that of all detected invest-

ment scam websites, 29,300 (67%) of them share only 4,900 (26% of all) IP addresses. Figure 6.3 shows the cumulative percentage of all websites that were hosted over the cumulative percentage of all IP addresses. We can therefore conclude that more than half of the scam websites are associated with merely 10% of the IP addresses in our dataset. This disproportionate concentration of scam websites on a small subset of IP addresses suggests the use of shared hosting infrastructure among scammers, as well as take-down opportunities for defenders.

Furthermore, we observe that a significant portion of websites sharing IP addresses are concentrated among a few hosting providers. Specifically, 10 hosting providers account for 76% of all shared IP addresses. Table 6.5 provides a breakdown of these shared IP addresses by hosting provider, including the size of the largest cluster, the total number of websites hosted by each provider, and the total number of unique IP addresses they resolved to. Hostinger was responsible for sharing 2,149 IP addresses among different scam websites, the highest among all hosting providers. The most concentrated cluster was 55 scam websites hosted on a single IP address. Overall, Hostinger accounted for approximately one-quarter of all detected scam websites. In particular, 8 out of these 10 hosting providers in Table 6.5 have a median of 3 or more websites that share the same IP address.

Although the hosting provider *Unified Layer* was responsible for hosting only 390 scam websites over 32 IP addresses, it hosts the largest cluster of websites sharing a single IP address, with 346 websites resolving to the same

Table 6.5: Shared IP addresses hosting multiple scam websites, along with the largest cluster sizes. Certain hosting providers are hosting large numbers of scam websites, often on the same IP address.

Hosting Provider	Total Shared IPs ($T=4,900$)	Largest Cluster	Total IPs ($T=19,110$)	Total Websites ($T=43,572$)	Perc. in Top 10k
Hostinger	2,149 (44%)	55	5,597 (29%)	11,160 (26%)	1%
Cloudflare	694 (14%)	327	7,207 (38%)	9,296 (21%)	2%
NameCheap	209 (4%)	23	729 (4%)	1,094 (3%)	6%
OVH	170 (3%)	214	312 (2%)	2,826 (6%)	1%
Hetzner	120 (2%)	199	338 (2%)	1,998 (5%)	4%
Interserver	117 (2%)	148	165 (1%)	1,084 (2%)	0%
Amazon	71 (1%)	197	340 (2%)	1,384 (3%)	4%
Contabo GmbH	68 (1%)	55	159 (1%)	607 (1%)	0%
20I Limited	55 (1%)	29	71 (1%)	528 (1%)	0%
WHG	51 (1%)	18	90 (1%)	296 (0%)	0%
(Total)	3,704 (76%)		15,008 (79%)	30,273 (69%)	~16%

IP, among which 301 belong to the same second-level domain. The next largest cluster is hosted by Cloudflare, with 327 websites sharing an IP address. Interestingly, all these websites are subdomains of `cryptocurrencies-offers.com`. Each of these subdomains hosted a cryptocurrency investment scam, using multiple website templates to propagate the same fraudulent scheme, attempting to convince potential victims into trading cryptocurrencies on their platform with promises of high returns.

In total, 43,572 investment scam websites were hosted by only 874 web hosting providers. Similar to domain names, there is a notable difference in the web hosting providers chosen for scam websites compared to those used by Tranco’s top 10K websites. Providers such as Hostinger, OVH, and Hetzner host a significant portion of scam websites, likely due to their low-cost hosting services. These affordable solutions appear to be attractive to scam operators seeking to minimize hosting expenses while maximizing their profits

from scamming.

6.3.2.2 Web Design-based Clustering

To systematically evaluate the design of investment scam websites, we employ the perceptual hash (p-hash) algorithm to generate a 64-bit fingerprint for each website screenshot. Identical p-hash values indicate exact visual similarity between screenshots. However, to cluster screenshots of websites with similar designs but not identical, we group images whose p-hashes differ by a Hamming distance of up to 8 bits, that is, images sharing at least 56 out of 64 bits in their p-hash. We determined this threshold through iterative experimentation and manual analysis, allowing the clustering algorithm to group screenshots that share the same overarching template while permitting minor variations such as background color, investment plans, titles, and (fake) customer reviews.

Our analysis reveals that investment scammers often design their websites to appear professional and trustworthy, aiming to convince potential investors of their legitimacy. Common features of the investment scam sites detected by **Crimson** include attractive and modern interfaces, detailed contact information, live chat services, fabricated user reviews, false notifications of high-profit withdrawals by other investors, misleading statistics indicating substantial earnings, and counterfeit business certificates. After introducing their platforms, scammers typically present users with various investment plans that specify minimum and maximum investment amounts, promise unre-

alistically high returns on investment, and outline short time-frames for these returns to materialize. An example of a counterfeit certificate displayed on the investment scam website alpinextrade.com is shown in Figure 6.4.

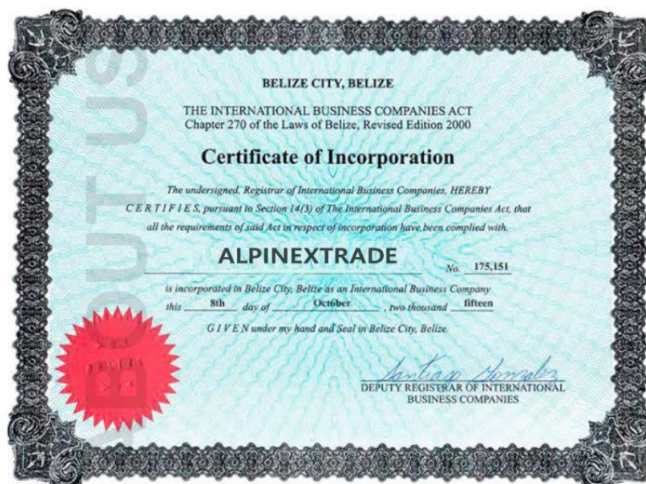
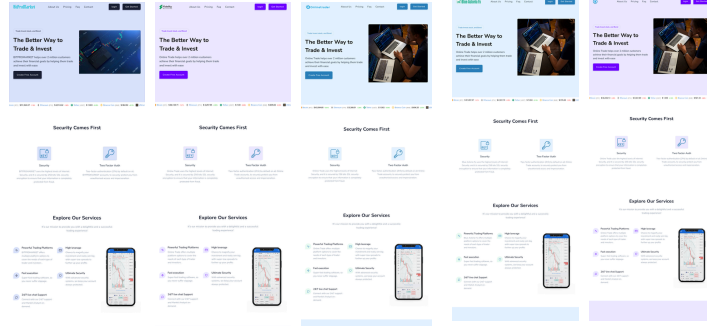


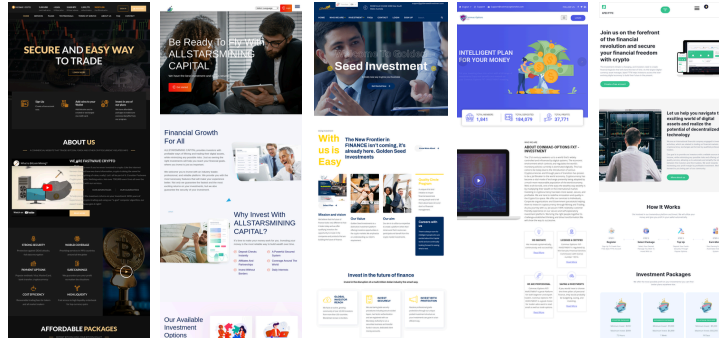
Figure 6.4: Fake certificate displayed by the investment scam website alpinextrade.com on their home-page

Applying our aforementioned clustering methodology, we grouped a total of 17,285 investment scam website *home-page* screenshots—representing 40% of all detected scam websites—into 4,335 clusters, each containing at least two web-pages. The largest cluster comprises 347 scam website screenshots, and each of the top five clusters contain more than 120 screenshots. To validate the accuracy of our clustering algorithm, we randomly sampled 100 clusters of varying sizes and manually inspected the screenshots. Our inspection confirmed that all screenshots within each cluster shared the same website template with only minor alterations (examples are provided in Figure 6.5).

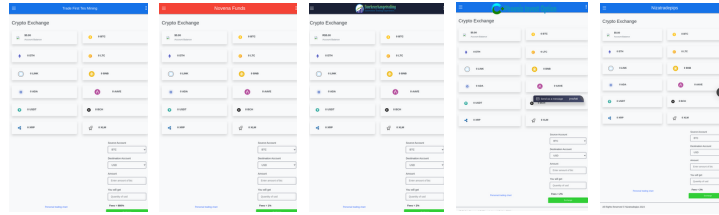
Furthermore, we applied the same clustering approach to inner page



(a) Example clusters of investment scam websites that have similar design.



(b) Example clusters of investment scam websites that have dissimilar design.



(c) Example clusters of investment scam website deposit pages that have similar design.

Figure 6.5: Example clusters of investment scam websites, categorized by design similarities, dissimilarities, and deposit page designs.

screenshots, such as the “About Us”, account settings, login/sign-up, investment plan dashboard, and investment deposit pages. This analysis resulted in

Table 6.6: *Distribution of shared IoCs among detected cryptocurrency investment scam websites. Scammers are reusing the email addresses, phone numbers, and social media handles across websites.*

Identifier	# Websites	# Reused	Largest Cluster
Email Address	27,036 (58%)	1,806	318
Phone Number	12,092 (27%)	1,411	121
Telegram Handle	4,293 (10%)	392	189
Twitter Handle	4,014 (9%)	367	126
Facebook Handle	3,467 (8%)	284	389
Instagram Handle	2,999 (7%)	305	185
GitHub Handle	1,635 (4%)	90	719
LinkedIn Handle	1,409 (3%)	157	50
Ethereum Address	1,334 (3%)	78	26
Bitcoin Address	1,278 (2%)	34	20
YouTube Channel	939 (2%)	122	24
Tronix Address	408 (1%)	13	19

14,042 inner-page screenshots from 2,172 domains (4% of all detected scams) being grouped into 3,732 clusters. Interestingly, we identified 682 cases where websites that were not clustered together based on their home page designs were found in the same clusters when analyzing inner pages. This suggests that scammers may reuse templates for specific sections of their websites, such as post-authentication dashboards and login pages, even if their home pages differ in design.

6.3.2.3 IoC-based Clustering

To establish credibility, scammers make use of tactics to portray legitimacy and trustworthiness to potential victims. To systematically identify and analyze these deceptive practices, we employ `iocsearcher` [221, 219] to extract various indicators of compromise (IOCs) directly from the HTML code of all scam websites from their home- and inner-pages.

Table 6.6 lists the specific indicators extracted across all detected scam websites, along with the count of websites from which each indicator was retrieved. Moreover, it lists the total number of identifiers that are shared among more than one website from each category and the largest cluster of websites that share the same identifier. Note that since the identifiers are extracted from the raw HTML code, it is not necessary that it will appear on the website view. Rather, as scammers often lazily reuse templates to distribute their scam over a large number of domains, these identifiers can also be present inside the commented-out portions of their code.

The top three most shared phone numbers among websites were shared between 121, 78, and 74 websites. Interestingly, the phone number **+19043263***** was shared among 74 websites, and upon further investigation, we found a related report on `scam-detector.com` where, in October 2023, a user had reported being scammed by an investment website providing this exact number [222]. According to the report, the victim was deceived into sending the equivalent of 1,346 USD through Binance to an investment scam website under the guise of promised profits. The scam domain reported by the user is no longer active. However, multiple domains found by **Crimson** that have the same phone number are still active at the time of writing. Moreover, the email address `support@brynamics.xyz` was found to be shared among 184 scam websites. A basic online search of this email yields numerous results linked to various investment scam websites that have advertised it. Tables 6.7, 6.8, and 6.9 list the YouTube channels, Instagram usernames, and Telegram han-

Table 6.7: YouTube channels embedded within the HTML of detected cryptocurrency investment scam websites, along with their subscriber counts, channel titles, example video titles, and the number of scam websites that linked to each channel.

Channel ID	# Subscribers	Channel Title	Example Video Title	# Scam Websites
UCmhlqA0PXvpSj8kuN3zshpDw	6.2K	InstaForex Official	Forex forecast 10/10/2024: EUR/USD, USDX, Gold and Bitcoin	24
UC8ATbwlPxMCrQfYweaizgA	Blocked	N/A	N/A	23
UCRF2-5W_uwflhpj6Hf6r4Jw	32K	Intelligent Cryptocurrency - Dirk Crypto Diggy	How to (Realistically) Make 100k From Crypto in 2024	16
UCvBNXhZD6XlMCb9FY9KJxqw	Blocked	N/A	N/A	12
UCzH0C03Gy8uHyKr-Y59cwJg	3K	PrimeXBT	Trade on an easy-to-use platform - PrimeXBT	12
UCBEu2buLFT8nX2ffFV76XNQ	134	101financial.app - A New Social Way to Invest	EASY WAY TO DEPOSIT BALANCE IN 101.INVEST!	11
UCHxfIung8_7Z7zCk6NTaYrQ	Blocked	N/A	N/A	10

Table 6.8: Instagram account usernames embedded within the HTML of detected cryptocurrency investment scam websites, along with the number of scam websites that linked to each username.

Instagram Username	# Scam Websites
hyiprio	185
zeus.strategy	31
cryptotabme	29
pangmancapital	28
miningautomatic	26

Table 6.9: Telegram handles embedded within the HTML of detected cryptocurrency investment scam websites, along with the number of scam websites that linked to each handle.

Telegram Handle	# Scam Websites
flexytrading1	189
PhoenixFX	130
bitcoinminetrix	67
CryptoTabChannel	29
klassiccapitalchannel	23

dles, respectively, most frequently embedded within the HTML of detected scam websites.

Upon inspection, we found that the shared Ethereum, Bitcoin, and Tronix wallet addresses detected on the homepages of scam websites were

Table 6.10: *Most common JavaScript library use-cases*

Use Case	# Scam Websites	Perc. in Top 10K
JQuery	35,597 (82%)	36%
Language Translators	18,828 (43%)	5%
Trading View	15,260 (35%)	1%
Fake Notification	3,296 (8%)	1%
Chat Services	1,279 (3%)	2%

often dummy addresses, typically displayed alongside fabricated metrics such as large cryptocurrency withdrawals by supposed users. This was done to create the illusion that the scammers' service was trustworthy and actively used. However, the actual wallet addresses, where victims were instructed to send funds, were generally revealed only after the victims had logged in.

6.3.2.4 JavaScript-based Clustering

Apart from replicating common website designs, scammers often reuse common JavaScript elements across websites. When **Crimson** detects a scam site, it extracts all JavaScript inclusions, local or remote, from the HTML code. The most frequently encountered JavaScript inclusions are listed in Table 6.10. Although these JavaScript libraries may not be inherently malicious, understanding their usage patterns helps us identify common elements of investment scam websites and how scammers exploit them to increase their reach, lend their sites an appearance of legitimacy, and manipulate users into sending them funds.

Our analysis reveals that 81% of the scam websites use JQuery. Its features provide scammers with capabilities for manipulating the Document

Object Model (DOM) and thus enhancing website interactivity. For instance, with a few lines of JQuery, scammers have set up chat-bots to facilitate basic functionalities such as text-based interactions and predefined responses. Additionally, we observe third-party JavaScript inclusions for chat services on 3% of the detected scam websites. Beyond JQuery, language translators and trading view widgets are the next most common JavaScript inclusions observed on scam websites. Translator scripts enable scammers to automatically localize their content based on user-selected languages or even adapt dynamically to the user’s browser or device language settings. This tactic creates a more personalized experience that mimics the behavior of legitimate websites and also enables scammers to reach a broader audience across different countries and languages, increasing the pool of potential victims. Trading view widgets embed real-time market data, charts, and financial information into websites. Scammers exploit these widgets to create trading dashboards, price tickers, and candlestick charts. Moreover, scammers employ the social engineering tactic of fake notifications to further manipulate user behavior. These notifications often mimic real-time updates about other users’ activities, such as deposits, withdrawals, or profits earned, aiming to create a sense of social proof. For example, on March 28 2024, **Crimson** detected the scam website **securedcryptoassets.com**, which periodically displayed a notification stating: *“Dustin from Anaheim just earned \$41,851 25 minutes ago.”*. This notification would refresh every few seconds with a random name, city, and earnings.

weeks following its first discovery without that content being necessarily associated with the initial scam (*e.g.*, serving entirely different content, takedown notices from the hosting providers, etc.).

To address this ambiguity, we utilize the title of the website to determine whether it continues to host the same content. If the cosine similarity [223] between the current and initial title exceeds 0.9, we consider the website to still be hosting scam-related content.

Crimson identifies a daily average of 522 scam websites, of which 189 are unique. The total number of scams detected each day also includes websites that were previously identified; this repetition occurs because these domains reappear in CT logs, leading to their re-detection by **Crimson**. These duplicate CT logs can occur due to multiple scenarios, such as obtaining a new certificate after a domain has changed hosting providers following a take-down by the previous hosting provider, upcoming certificate expiration, or when a new certificate is issued for an additional server that hosts the same website content. We observe that 29,340 scam domains appeared more than once in CT logs, resulting in a reappearance in our dataset. Our analysis reveals substantial variability in the operational status of cryptocurrency investment scam websites throughout the 8 months. Specifically, 17,653 websites exhibited intermittent periods of inactivity followed by reactivation after short periods of time. Interestingly, 2,355 websites reactivated with a different hosting provider after a period of inactivity. This pattern likely suggests that these sites were shut down by their previous hosts, prompting scammers to obtain web hosting

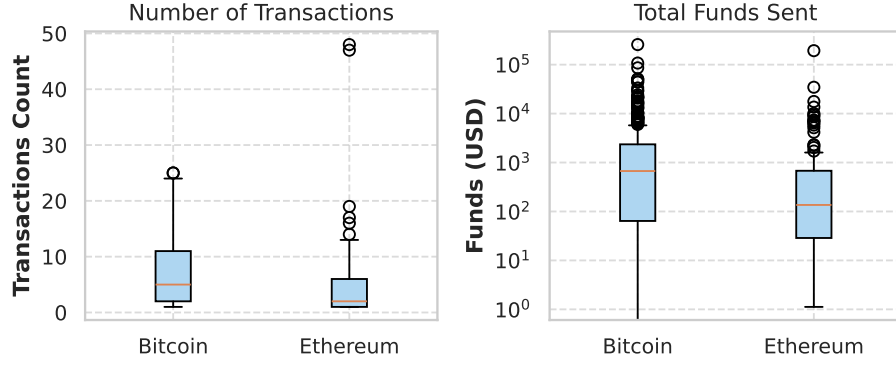


Figure 6.7: Total number of transactions and US Dollars directed towards scammer-owned cryptocurrency wallets from each victim

from new providers in order to make their scam sites available again. We find that 16,635 (44%) of websites remained consistently inactive or underwent content modifications during the last ten days of monitoring. In contrast, 22,983 (47%) websites continued to be active and still hosted investment scams at the end of the observation period.

6.4 Estimating Financial Losses

In this section, we describe our methodology and results for estimating the success of scammers in terms of receiving cryptocurrency transactions in the wallet addresses they provided on their scam websites. Given the predominant market capitalization and the vast user bases of Bitcoin and Ethereum, we choose to focus our analysis on these two cryptocurrencies.

We collected 489 Ethereum addresses and 1,106 Bitcoin wallet addresses from 2,923 scam websites. We then aggregated all incoming transactions to all wallet addresses by leveraging blockchain explorers [133, 224]. For Bitcoin, we aggregate the total amount directed to scammers’ wallet addresses by sum-

ming the Bitcoins from the output slot of each transaction where the address belongs to a scammer. This approach ensures that we avoid over-counting funds in cases where change addresses return a portion of the funds back into the victim’s wallet. For Ethereum, we record the aggregate amount sent where the scammer’s wallet is the receiving address. To further mitigate the risk of overestimation in our results, we adhere to the guidelines provided by Gomez *et al.* [225] and convert the resulting amounts of each cryptocurrency to US dollars based on the adjusted closing prices on the days the transactions occurred to provide a tight estimation of the monetary value victims transferred using each transaction. Furthermore, we exclude any transactions that occurred before the creation date of the scam websites (per WHOIS data), displaying the wallet addresses to ensure that our revenue estimations only reflect transactions influenced by the scam websites themselves. That is, if a specific cryptocurrency scam website discovered by **Crimson** has a domain registration date of June 1, 2024, we exclude cryptocurrency transactions predating that registration date.

Our results, shown in Figure 6.7, clearly reveal that scammers have unfortunately been successful in their goal of luring victims into sending funds into their wallets. We find that 3,497 transactions were sent towards scammer-owned wallets by 189 unique Ethereum wallet addresses and 1,907 Bitcoin senders. In total, transactions sent towards scam wallets sum up to 2.04M US dollars, with 83% of payments sent through Bitcoin. Even though the captured financial losses represent a significant amount of funds, they stem from

Table 6.11: Top 20 investment scam domains sorted by revenue earned through Bitcoin payments, along with their Bitcoin wallet addresses, revenue in USD, and whether they were active at the time of writing. Web browsers show no deception warnings when a user visits any of these websites. Almost all of the listed websites are active, and are still potentially receiving payments from unsuspecting users

Scam Domain	Wallet Address	Revenue	Active?
capitalfxfinance.org	bc1q2em...tcuet	257K	✓
bitgainscapital.com	bc1qtut...tnnn9	108K	✓
duxtonroztrade.com	bc1qwzs...ywx00	86K	✓
digitechmininghub.com	bc1qnzn...xcnck	51K	✗
coincipher.co	bc1qhy9...uzucwn	50K	✓
tslasafeinvest.com	bc1qlcq...sqds6r5	49K	✗
cryptomineenergy.com	bc1qfgx...xxjlrk	45K	✓
crudeportlimited.com	bc1q5c6...lak0z	44K	✓
growthmatrixinvestment.com	bc1q7gn...hapwzm	33K	✓
finance-extra.com, hextechcryptofarm.com	bc1qarp...e8kuj9	30K	✓,✓
tradesprofitly.com	bc1qy33...5z09e	29K	✓
apextradexf.com	bc1qpet...ndqltu	24K	✓
capitalwheelinvestmentcompany.com.ld-bnk.com	bc1q3q7...mh6hqw	22K	✓
compasscloudminings.com	bc1q5g4...3vtykp	22K	✓
bridgefastltd.com	bc1q6mm...skskyq	21K	✓
horizoncrypto.ltd, coinfarmlandltd.com	bc1quxl...6amrrt	21K	✗,✓
xtradeconnect.com	bc1q4gc...yalx77y	21K	✓
mytradepay.com	bc1qxku...apk8kgp	18K	✓
primepinnaclepurse.com	bc1qpcq...vgw8hz	17K	✓
forecasttradeslimited.com	bc1qnr3...uw7jle	17K	✓

only 6.7% of the total scam websites that we identify. This is primarily due to the challenges we face in successfully authenticating and extracting wallet addresses from many sites. We suspect that the actual financial losses linked to these scams are much higher than reported. On average, approximately 3.6K USD were sent to scammer wallet addresses. If this average is extrapolated to all of the detected scam websites, we estimate the total financial loss to be more than 100M USD. We list the top earning investment scam domains through both Bitcoin and Ethereum payments, along with their estimated revenues and operational status in Tables 6.11 and 6.12.

We source a list of 795 custodial wallet addresses belonging to online

Table 6.12: Top 20 investment scam domains sorted by revenue through Ethereum payments detected by *Crimson*, along with their Ethereum wallet addresses, revenue in USD, and whether they were active at the time of writing.

Scam Domain	Wallet Address	Revenue	Active?
apexasset-management.net	0x8507...7dd66	193K	✓
brclimited.com	0x7c53...f950	35K	✓
tradepeakinvest.com	0x1991...26a2	18K	✓
horizoncrypto.ltd,	0xbd95...a45d	14K	✗
findexglobalchain.com			✓
kings-investment.co	0x68e7...ff4c	10K	✗
aqrisprime.io	0xecd2...88d3	9K	✗
firstclassrader.mdxspacetrade.com	0x704b...5ae9	9K	✓
exgrowfundlimited.com	0xdda9...98e2	7K	✓
capitalprimextrades.com	0x0ec2...10a4	7K	✓
bi-investments.com	0x2428...afa8	7K	✓
equityegdecapital.com			✓
mytradepay.com	0xc583...e532	6K	✓
tfxprimes.com	0x28e9...8159	5K	✓
renoexperttrade.online,	0xb664...3ede	4K	✓
bitcorefxtrade.com,			✓
falconexchangealtcoin.online,			✓
fxtradingtrust.com			✓
cryptospacecapitals.com,	0xb4eb...5ac1	2K	✓
horizoncrypto.ltd			✗
globalsprovest.com,	0xd18e...58bd	2K	✓
globalsprovest.com.shipscargo.com			✓
ventures-fundsfx.com	0x0571...9f30	2K	✗
goldcoinridge.com	0x2452...c4f6	2K	✓
graceautoinvestsltd.com	0x0633...a39a	2K	✗
e-musktrading.com	0x11d9...0c37	1K	✓

exchanges such as Coinbase [226] and Binance [227], from Etherscan [133] and CoinCarp [228] and find that only 13% of all transactions to scammers were sent through them. This indicates that non-custodial wallets are more popular among victims of investment scams and that such financial losses could be avoided if non-custodial wallets detect scam websites and warn users in a timely manner. One of the most popular non-custodial wallet providers, MetaMask [178] makes use of block-lists, displaying a warning when users visit a known malicious website. In the following section, we discuss the coverage

of this block-list, along with the warning services by other providers.

Lastly, we briefly report on the phenomenon of multiple *different* users being shown the same wallet address for depositing funds on the same investment site. Having all users deposit funds to the same address would make it difficult for a legitimate service to determine which funds came from which user and would allow malicious users to front-run other users' funds. As such, we argue that a shared wallet address between unrelated users on the same site is one more indicator that the site is a scam with no intention of ever correctly tracking user funds. To this end, we used **Crimson** *twice* on 15 randomly sampled websites where our tool was initially able to create accounts and identify wallet addresses. For all 15 sites, we observed the same wallet address being shown to our two different **Crimson**-generated accounts.

6.5 Discussion

6.5.1 Coverage

Due to the large number of scam websites in the wild, various block-lists have been developed to flag suspicious websites and warn users within their web browsers of potential malicious activity. For example, all modern browsers utilize Google Safe Browsing to display a warning page when users are about to visit a suspicious website. The Metamask wallet extension offers similar

Table 6.13: *Percentage of scam websites detected by Crimson that were also present in known block-lists.*

Name	Intersection
VirusTotal [229]	20%
Metamask [178]	2%
SEAL-ISAC [230]	2%
Google Safe Browsing [162]	1%
WalletGuard [231]	1%
Phishfort [232]	1%
ChainPatrol [233]	1%

functionality to GSB that is specific to cryptocurrency-related malicious websites. Services such as WalletGuard, Phishfort, ChainPatrol, and SEAL-ISAC also provide block-lists for malicious websites and can be integrated into web browsers and third-party applications.

To understand to what extent these existing block-lists and extensions are able to protect users from cryptocurrency investment scams, we check whether our **Crimson**-discovered websites are flagged as malicious. Specifically, we compare the coverage of 7 services against a random sample of one-third of the **Crimson** dataset, and list our results for each block-lists in Table 6.13. Evidently, a majority of the existing block-lists were not able to provide a reasonable detection rate of investment scam websites. We suspect that this low coverage in existing block-lists is due to the general nature of websites they aim to detect. Going forward, these services could use a **Crimson**-like system to augment their detection logic and improve their performance.

6.5.2 Limitations

Although **Crimson** was able to find tens of thousands of real scam investment sites, it suffers from some limitations.

Even though our keyword filters were carefully selected and optimized to identify cryptocurrency investment scams, if attackers deliberately avoid using these targeted keywords or adapt their content to bypass the filters, their scam websites could evade detection. However, it is also difficult for attackers to avoid our keywords since it would be challenging to sell cryptocurrency investment sites without using them. That is, complete avoidance of investment and cryptocurrency terms will also reduce (if not entirely eliminate) their conversion rates for victim users. If necessary, our keyword filters can always be expanded with additional terms to identify such future websites at the expense of additional resources to handle the increased workload and LLM usage.

Our use of LLMs for scam validation was motivated by the goal of eliminating the need for human intervention in classifying scams. However, this approach comes with a trade-off in terms of reduced accuracy compared to manual methods. As LLMs continue to evolve and improve, we anticipate that their accuracy in detecting scams will increase over time, allowing **Crimson** to more reliably identify fraudulent websites.

Since each website has a different authentication template, and many employ CAPTCHA or other mechanisms to block automated access, automating the sign-up and login process to crawl wallet addresses is difficult. Despite these hurdles, we were able to extract thousands of wallet addresses from

post-authentication dashboards and estimate overall financial losses.

Currently, **Crimson** does not include mechanisms to prevent scammers from detecting and blocking it. If and when investment websites adopt evasion techniques that decrease **Crimson**'s performance, standard anti-evasion mechanisms (such as, using higher-fidelity crawling components and a pool of geographically distributed IP addresses) can be straightforwardly added to our system.

6.6 Ethical Considerations

We did not interact with real users (benign or malicious) during the course of this work. During the study period, we refrained from reporting identified scam websites to their respective hosting providers as intervening would interfere with our ability to observe and understand the full scope of how cryptocurrency investment scams operate. We have made our code and data available in [199], so that hosting providers and blocklist operators can take full advantage of our work.

6.7 Chapter Summary

In this chapter, we developed and deployed **Crimson** to detect 43,572 cryptocurrency investment scam websites over a period of 8 months. We conducted an in-depth analysis of these scam websites, clustering them based on IP addresses, web design, JavaScript inclusions, and other relevant information present in the HTML. Our findings revealed that 47% of all detected

scam websites were still active at the end of our data collection period and that scam websites often reappear through different hosting providers if taken down. In terms of financial losses, we estimated a lower bound of 2.04M USD sent by victims into scammer wallets. We also identified that popular blocklists used by web browsers and applications do not provide adequate coverage for investment scam websites, leaving many undetected and failing to issue warnings to users who visit them.

Chapter 7

New Trains, Same Rails: Fingerprinting Cryptocurrency Software via Network Requests

7.1 Introduction

Digital services today predominantly rely on infrastructure controlled by centralized service providers. For example, Internet service providers (ISPs) provide Internet connectivity and payment processors mediate financial transactions. This concentration of control enables them to determine which services users can access, what data is collected about them, and how their behavior is monetized [104]. Web3 has emerged as an alternative to this model. It aims to shift this control away from centralized intermediaries and toward decentralized blockchain-based systems such as cryptocurrency. At its core, Web3 promises users the ability to transact directly on blockchain networks, free from the centralized intermediaries that collect and monetize their data [234].

Yet, Web3 users rarely interact with blockchains directly in practice. Instead, they rely on client-side applications installed on their devices to mediate access to blockchain networks. Despite their role in decentralized sys-

tems, these applications remain coupled to traditional Internet infrastructure, as their core functionality depends on access to external services such as RPC providers or price feeds.

Consequently, the effective privacy boundary for Web3 users extends beyond the cryptographic guarantees of blockchain protocols. It is also shaped by the network-facing behavior of the client software through which these systems are accessed. DNS plays a central role among these dependencies, as every domain an application contacts must first be resolved through third-party resolvers. These resolvers are operated by centralized entities such as ISPs, campus administrators, and enterprise network operators. As a result, these parties can track and block Web3-related activity without the user’s awareness. This dependency thus reintroduces the very centralized control that Web3 seeks to eliminate.

These risks are particularly acute for users who rely on ISP-controlled DNS resolvers or are in countries or sensitive enterprise environments where DNS is subject to surveillance. Even when users configure their devices to use DNS-over-HTTPS (DoH) resolvers, their queries are often downgraded to plaintext DNS or forcibly redirected through resolvers controlled by network operators [235, 236, 237]. At the same time, this visibility may serve legitimate purposes, such as detecting unauthorized cryptocurrency mining on campus networks [117].

Prior work has examined related privacy risks at the application layer. Specifically, they report that website operators can fingerprint Web3 browser

extensions to detect cryptocurrency users, and popular websites such as `tiktok.com` have been shown to engage in this practice at scale [46, 105]. However, the risks arising from Web3 applications’ reliance on DNS infrastructure are not well understood.

In this paper, we investigate how DNS infrastructure enables the observation and attribution of activity generated by Web3-based applications. To this end, we curate an application suite comprising 303 versions of 40 popular applications spanning a range of user devices, with a primary focus on cryptocurrency-related functionality. We exercise these applications in network-isolated environments while recording all emitted DNS queries to extract their *DNS fingerprints*.

We show that these applications heavily rely on DNS infrastructure for routine operation. They produce distinctive DNS emissions for 34 (85%) applications that can be reliably attributed to active application use. In 18 (45%) cases, this attribution extends to specific application versions. We further observe that 90% of the IP addresses associated with representative domains used by these applications are routed through only five Autonomous Systems. These concentrated dependencies constitute both single points of failure and potential choke points for censorship of Web3 services.

We validate the real-world observability of these DNS fingerprints through a collaboration with Palo Alto Networks, by evaluating their prevalence in aggregate telemetry derived from enterprise URL filtering logs. Among other findings, we infer over 74K instances of transaction-related activity using DNS

Category	Application	Oldest	Latest	# Versions	# Users
Browser Extension	MetaMask	2.10.0	12.13.0	11	13M+
	Phantom Wallet	0.13.1.0	25.9.1		5M+
	Trust Wallet	0.0.1.0	2.32.1		1M+
	Keplr Wallet	0.9.8.0	0.12.201		1M+
	Coinbase Wallet	2.3.5.0	3.107.0		1M+
	Solflare Wallet	1.23.1.0	1.74.4		800K+
	Bitget Wallet	0.0.9.0	2.15.18		400K+
	Xverse Wallet	0.1.7.0	0.50.0		300K+
	Argent	4.8.3.0	5.23.1		300K+
	Leap Wallet	0.6.0.0	0.18.5		200K+
	Nightly Wallet	0.1.3.0	1.16.7		100K+
	Eternl	1.3.3.0	1.12.24		100K+
	Pocket Universe	0.0.47.5	0.6.5		100K+
	Aegis Web3	0.0.6.0	0.6.37		100K+
	Crypto.com	1.2.16.0	2.23.0.0		90K+
	Core Wallet	1.31.0.0	1.97.1		60K
	Taho Wallet	0.8.1.0	0.63.1		50K+
	AlphaOS	0.0.1.0	0.31.6		40K+
	Web3 Antivirus	0.2.1.0	0.17.3		20K+
	Typhon Wallet	0.0.9.0	3.2.16		10K+

Category	Application	Oldest	Latest	# Versions	# Users
Mobile Application	Trust Wallet	1.11.1	8.40.1	6	50M+
	Bitcoin.com Wallet	6.6.3	8.19.2	5	10M+
	Blockchain.com	1.2	8.5.4	8	10M+
	Crypto.com	1.71.0	1.78.0	2	10M+
	MetaMask	2.5.0	7.44.0	5	10M+
	OKX	6.0.40	6.114.0	3	10M+
	Phantom	24.24.0	25.12.0	2	10M+
	Kraken	1.37.0	3.11.0	3	5M+
Desktop Application	Atomic Wallet	2.11.0	2.91.5	4	5M+
	Exodus	24.1.29	25.13.3	3	1M+
	Coinomi	1.3.0	1.3.0	1	N/A
	Guarda	1.0.0	1.0.20	4	N/A
	Sparrow Wallet	0.9.2	2.1.3	6	N/A
Hardware Wallet Application	Ledger Live	2.47.0	2.106.0	8	7M+
	Trezor Suite	20.10.1	24.5.3	5	2M+
	Jade	0.0.1	2.0.23	6	N/A
Cryptomining Firmware	HiveOS	1.00	1.03	4	2M+
	Braïns OS	19.06	22.08.1	4	N/A
	cpuminer	2.4.1	2.4.5	3	N/A
	Antminer	2017	2019	3	N/A

Table 7.1: Cryptocurrency software analyzed in this study. For each application, we report the oldest and latest versions included in our measurements, the number of tested versions, and approximate user counts when available.

alone. These instances are generated by the MetaMask browser extension and mobile application, the most widely used digital wallet, and originate from approximately 2K customer networks.

Our main contributions can be summarized as follows:

- We present the first study of DNS-level fingerprintability in cryptocur-

rency client software, demonstrating that passive network observers can identify applications in use and infer user behavior.

- We develop network-isolated experimental setups to extract application-specific DNS fingerprints across 40 applications and 303 versions, and validate their real-world observability using passive DNS and enterprise-scale URL filtering telemetry spanning thousands of customer networks.
- We release our DNS fingerprint dataset and measurement tools to support further research in this area [238].

7.2 DNS Observability and Threat Model

We consider a passive network observer operating at the DNS resolver level, with visibility into DNS queries issued by client devices during normal application use. In practice, this observer may correspond to an enterprise network operator, campus administrator, or ISP that operates or controls the DNS infrastructure used by those devices. In enterprise, educational, and government networks, DNS resolution is routinely centralized and logged for security monitoring and incident response [235, 236]. Similar observability conditions also arise in residential networks, where users typically rely on ISP-operated resolvers.

Let a denote an application executing over a time interval T , and let $\mathcal{Q}$ denote the set of domain names observed in DNS queries collected by a network observer. We define the *DNS footprint* of a as the set of fully qualified domain

names resolved by a during T :

$$\mathcal{D}_a = \{d_1, d_2, \dots, d_n\}. \quad (7.1)$$

We further define the *DNS fingerprint* of a as the subset of domains in its footprint that are unique to a (Section 7.5):

$$\mathcal{F}_a \subseteq \mathcal{D}_a. \quad (7.2)$$

The presence of domains in the intersection

$$\mathcal{F}_a \cap \mathcal{Q} \quad (7.3)$$

enables the observer to attribute the observed traffic to a , to a specific version v of a , or to particular user actions within a .

Under this threat model, network operators may enforce the use of organization-controlled DNS resolvers and restrict or disable direct access to third-party DNS-over-HTTPS (DoH) services, such as those operated by Google or Cloudflare, in order to preserve resolver-level visibility for security monitoring [235, 236]. In some network environments, encrypted DNS traffic may also be intercepted and downgraded to plaintext DNS, as observed in prior measurement studies [237]. However, our analysis does not rely on downgrade behavior, as resolver-side visibility into queried domain names persists even when DNS traffic between clients and resolvers is encrypted. Network observers may also enforce short DNS cache TTLs to ensure that application-specific domain resolutions are repeatedly observable whenever applications invoke functionality that triggers them.

7.3 Application Suite

To obtain a comprehensive view of how cryptocurrency applications can be fingerprinted, we curate a diverse suite of applications spanning five categories listed in Table 7.1. Applications are selected based on their popularity within the Web3 user community, as reflected by download statistics and recommendations from forums and review platforms.

The resulting dataset captures a broad range of functionality and use cases within the cryptocurrency ecosystem. It includes lightweight wallets that focus on basic asset storage and transfer for a single cryptocurrency (e.g., Eternl for ADA), as well as multi-currency wallets that support a wide range of assets and advanced features such as staking or token swapping (e.g., MetaMask). In addition to digital wallets, the dataset also includes specialized security-focused applications (e.g., Web3 Antivirus), which are designed to monitor user activity and warn against interactions with malicious contracts or addresses. We further include hardware wallet ecosystems, which consist of physical devices used to securely store cryptocurrency keys and are commonly paired with companion desktop applications for device configuration and asset management. Finally, our dataset covers cryptocurrency mining software, including firmware deployed on specialized mining hardware, which enables participation in blockchain consensus through computational work.

To study how application behavior evolves over time, we collect multiple versions of each application, ranging from the earliest available releases to

the most recent versions as of mid-2025. While current releases are readily obtainable from official app stores and vendor websites, historical versions often require additional effort to source. We therefore rely on third-party archives, such as APKMirror for mobile applications, the Wayback Machine for desktop software, and GitHub release pages for open-source projects. Table 7.1 presents the complete set of applications included in our study, together with the earliest and latest versions analyzed for each application, the total number of versions examined, and user counts where available. In total, we study 40 distinct applications, encompassing 303 versions released between 2017 and 2025.

7.4 Experimental Setup

To accurately capture the outbound DNS requests generated by each application, we design per-software-class experimental setups that enforce strict isolation from background processes and unrelated network activity. This isolation ensures that all observed traffic can be confidently attributed to the application.

After preparing the isolated environment, we launch each application and exercise its functionality using a combination of automated scripts and manual interactions. For cryptocurrency mining firmware, we deploy each firmware image on mining hardware, connect it to a mining pool, and initiate Bitcoin mining, during which we observe the resulting DNS activity. For the remaining four software classes, which are primarily user-facing, each experimental run

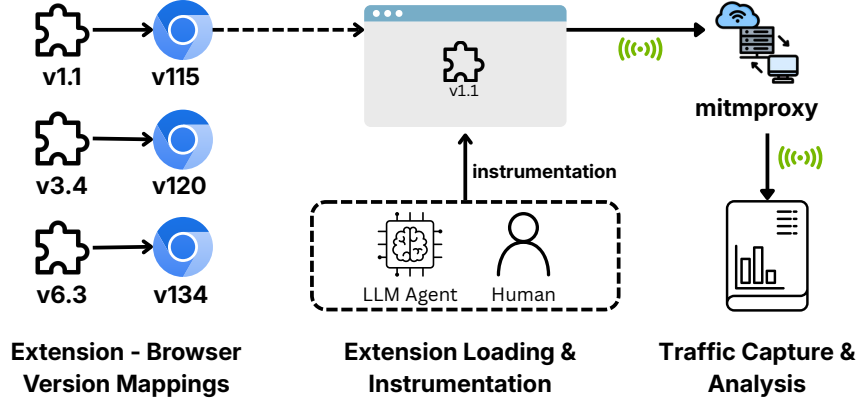


Figure 7.1: Experimental setup for analyzing browser extensions. Each extension version is executed in an isolated Chromium instance with all outbound traffic routed through an mitmproxy instance for traffic interception.

is structured into a sequence of interaction phases. First, the application is launched without user input to capture initialization-related DNS traffic. Second, we perform onboarding actions such as accepting terms of service or importing an existing wallet. Third, we navigate the application interface to trigger additional features and background functionality. Finally, for digital wallet applications, we initiate a small on-chain transfer (e.g., 0.001 ETH) to trigger transaction-related DNS requests. During each run, all outbound traffic generated by the application is recorded at the isolation boundary. These traces form the raw dataset from which we extract DNS fingerprints.

7.4.1 Browser Extensions

Figure 7.1 illustrates the execution environment used for our browser extension experiments. We maintain a local archive of versioned browser extension packages and Chromium/ChromeDriver binaries. As our dataset includes extension versions dating back to 2017, we require browser versions that are

compatible with those historical builds. Newer Chromium releases may not load or behave correctly with older extension APIs, while older Chromium releases may not support newer extensions. For each extension version, we select the Chromium release whose publication date is closest to that of the extension version and pair it with the corresponding driver. Each extension version is then launched in its corresponding Chromium build with the extension preloaded. To further isolate experimental runs, we start Chromium with a fresh sandboxed user profile for each run, preventing state leakage across experiments and across extension versions. We also record and filter out baseline traffic from Chromium instances with no extensions installed, which separates browser-level background noise from extension-induced traffic.

To trigger extension activity in the instrumented browser, we employ an LLM-driven web automation agent integrated with a browser automation framework to execute high-level navigation instructions [239]. The agent uses OpenAI’s GPT-4o model to automate onboarding workflows that are largely consistent across browser extensions, including account registration, login, acceptance of terms of service, and wallet creation or import. The system first activates the extension using OS-level GUI automation to click the browser’s extension icon. If this interaction does not automatically open a full-page interface, the system directly navigates to a known extension-owned web page using its internal `chrome-extension://<id>/` URL specified in the manifest file. If the manifest does not declare a `default_popup` and the extension does not expose a stable, directly loadable UI page, we fall back to manual inter-

action. We observe that this situation occurs most often for older extension versions.

More complex actions, including sending transactions or performing cryptocurrency swaps, vary substantially across extensions and even across versions of the same extension. Automating these workflows is impractical due to non-deterministic execution behavior for each version. We therefore perform complex interactions manually, while relying on the automation agent to execute stable and repeatable onboarding steps. Outbound requests generated by browser extensions are intercepted using *mitmproxy* configured as a local forward proxy. Each Chromium instance is launched with its network traffic explicitly routed through *mitmproxy* via browser proxy settings. To enable HTTPS traffic interception, the browser profile is configured to trust the *mitmproxy* CA.

7.4.2 Desktop and Hardware Wallet Applications

Similar to browser extensions, we execute each desktop application in a network-isolated environment, systematically trigger its features, and capture the resulting traffic to extract DNS fingerprints. However, unlike browser extensions, we cannot rely on *mitmproxy* to intercept communications. Desktop applications establish connections at the operating system level and may use non-HTTP protocols, bypassing user-space proxies such as *mitmproxy*. Moreover, desktop applications may use certificate pinning or custom TLS stacks that prevent interception of HTTPS traffic using a proxy. To address this,

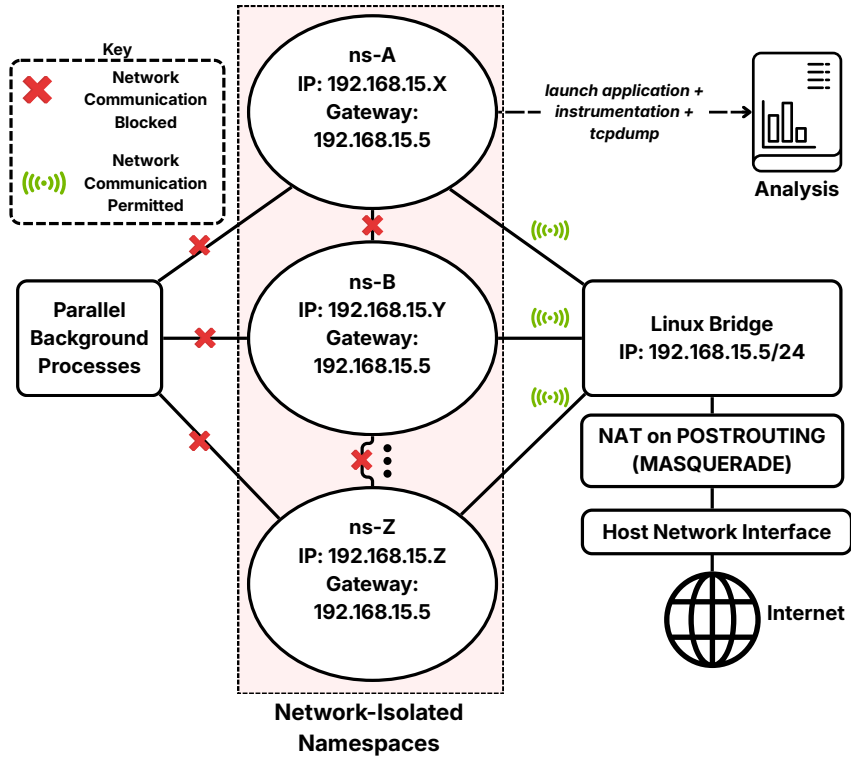


Figure 7.2: Linux network namespace setup for isolating desktop applications and capturing their outbound DNS traffic.

we implement isolation and traffic capture directly at the network layer using Linux network namespaces and a custom network bridge configuration.

A Linux network namespace provides an isolated networking stack with its own interfaces, IP addresses, and routing tables, allowing applications to run in a logically separate network environment from the host. To connect these namespaces to the Internet, we attach them to a Linux bridge, which acts like a virtual Ethernet switch on the host. Each namespace is connected to the bridge via a virtual Ethernet pair, enabling traffic to flow between the namespace and the host’s physical network interface. The bridge forwards packets and, together with iptables-based NAT rules, allows isolated applications to communicate externally while keeping their traffic separate from the

host. This approach mirrors the mechanism used by containerization platforms such as Docker, which also rely on network namespaces and bridges to provide each container with an independent but routable network environment [240].

Our setup is illustrated in Figure 7.2. This design gives us fine-grained control over traffic isolation and capture. By placing each desktop application in its own namespace, we ensure that its network activity does not interfere with other applications or background processes on the host and that the captured DNS traffic solely represents the traffic generated by the underlying application. Within each namespace, we follow the same general execution strategy. Traffic is captured inside each namespace using `tcpdump`.

Hardware wallets are physical devices that store cryptocurrency private keys offline, providing enhanced security against online threats. To interact with these devices, users typically install companion desktop applications that facilitate wallet management and transaction signing. We focus on the desktop applications that interface with popular hardware wallets. These applications are installed and executed within isolated Linux network namespaces, following the same methodology as desktop wallets.

7.4.3 Mobile Applications

We analyze mobile wallet applications by running them within Android emulators, which provide a controlled environment for executing mobile apps on a desktop host. The emulators are themselves launched and exercised within Linux network namespaces to ensure network isolation, similar to the

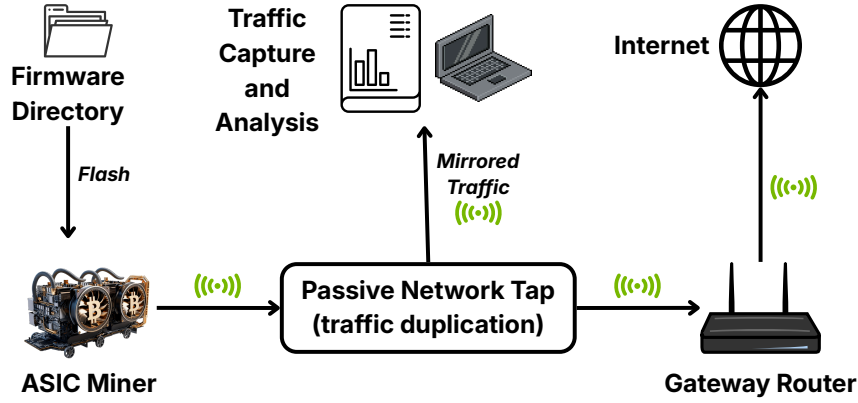


Figure 7.3: *Experimental setup for analyzing cryptocurrency mining firmware. The mining device is connected to a personal router for Internet access, with a passive network tap inserted inline to mirror all outbound traffic to a monitoring host for DNS traffic capture.*

setup used for desktop wallets, using `tcpdump` to capture DNS traffic. Mobile applications under test are controlled on the emulated Android environment using `adb` commands, which enable programmatic interaction with the emulated device, including app installation and deletion.

7.4.4 Cryptocurrency Mining Firmware

Cryptocurrency mining can be performed using CPUs, GPUs, or application-specific integrated circuits (ASICs), with ASIC-based mining firmware offering the highest efficiency in practice. To study mining-related DNS behavior, we deploy mining firmware images on an Antminer S9 device, a widely used ASIC-based miner. The Antminer S9 natively runs a Linux-based mining firmware (denoted as *Antminer* in Table 7.1), and multiple alternative firmware distributions are available that provide different performance optimizations and monitoring features. We select a set of popular mining firmware based on community recommendations and online reviews. Each firmware image is

obtained from its official source and flashed onto the Antminer S9 prior to experimentation. In addition to ASIC-based firmware, we include an open-source CPU-based mining application (*cpuminer*), which we execute within our aforementioned isolated namespaces.

Our experimental setup for mining firmware is illustrated in Figure 7.3. To capture network traffic from the ASIC device, we connect the Antminer to a dedicated router that provides Internet connectivity and insert a passive network tap inline between the miner and the router. The tap mirrors all packets to a separate monitoring host, allowing us to observe the miner’s outbound network activity independently of the firmware in use. The miner is configured to connect to a mining pool and then started, while the monitoring host records all mirrored DNS traffic.

7.5 Analysis

7.5.1 Fingerprintability of Cryptocurrency Client Software

Each of the applications running on a user device emits its own DNS request patterns that are visible to the network observer described in Section 7.2. We ask whether such an observer can infer that a user is running a particular application or mining firmware, even in the presence of DNS traffic from other concurrently running applications.

We categorize observed domains into three classes based on how strongly they reveal application identity, starting with the most distinctive signals. The *strong* category consists of application-specific domains that are tightly

coupled to a particular application and typically support proprietary backend APIs and telemetry services. These domains provide high-confidence signals of application identity. Identity may be explicitly encoded in the domain name itself by embedding the application name or a known alias in the domain label. For example, `api.eternl.io` for the Eternl wallet or `doge-rpc.trustwalletapp.com` for the Trust Wallet Android application. Second, identity may be conveyed through application-specific telemetry and backend endpoints that are accessed exclusively by a single application and persist across versions. As an example, the domain `o1300201.ingest.sentry.io` is consistently resolved by every version of the Core Wallet application. Here, `o1300201` is a unique identifier [241] assigned by `sentry.io`, a third-party telemetry provider, and remains stable across Core Wallet releases. The presence of such domains enables a resolver-level observer to attribute DNS traffic to a specific cryptocurrency application.

The *medium* category consists of cryptocurrency-service domains that are specific to the cryptocurrency ecosystem but shared across multiple applications. These domains support common infrastructure, including blockchain RPC providers, wallet coordination services, block explorers, and exchange APIs that are used by many wallets to implement core functionality. For example, `mainnet.infura.io` is widely used by different wallet applications to relay JSON-RPC requests to the Ethereum mainnet. While these domains indicate cryptocurrency-related activity, they do not uniquely identify the application generating the traffic. We identify such domains using a curated list

Category	Domains
Weak	android.googleapis.com static-cdn.hotjar.com star-mini.c10r.facebook.com cdn-settings.segment.com
Medium	mainnet.infura.io pulse.walletconnect.org bsc-dataseed1.binance.org min-api.cryptocompare.com
Strong	portfolio.api.cx.metamask.io swap.api.cx.metamask.io gas.api.cx.metamask.io tx-sentinel-ethereum-mainnet.api.cx.metamask.io

Table 7.2: Domain categories observed in the latest version (v7.44.0) of the MetaMask mobile application

of known cryptocurrency infrastructure providers and classify them as medium associations.

Finally, the *weak* category includes general-purpose domains that are widely used across the Internet and commonly queried during routine web activity, but are not specific to cryptocurrency activity. Examples include domains supporting authentication services, such as Google login, or web analytics. As these domains are shared across many otherwise unrelated applications, their presence in DNS emissions does not provide meaningful information about application identity.

To systematically identify such domains, we develop a crawler that uses the Tranco top-10K websites [31] as seed URLs. The crawler visits each website and records all domains resolved during page loading. Since many resolved domains appear as subdomains, we canonicalize each hostname to its effective second-level domain using the Public Suffix List [242], aggregating domains that belong to the same underlying service provider. For instance,

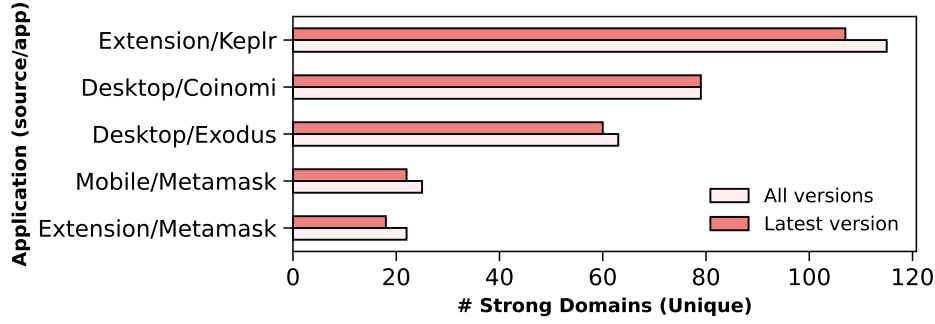


Figure 7.4: Top 5 applications by number of strong domains comparing the number of unique strong domains in all versions vs. latest version.

`ogads-pa.googleapis.com` and `update.googleapis.com` are both mapped to `googleapis.com`. Application-resolved domains whose effective second-level domains intersect with this baseline are classified as weak associations.

Some domains remained unclassified after applying these criteria: either they corresponded to cryptocurrency service providers too obscure to appear in our curated *medium* list, or they were too unpopular to be classified as *weak*. For this residual set, we queried OpenAI’s GPT-5 model to assess whether each domain was associated with a cryptocurrency service. Domains identified as cryptocurrency-related were incorporated into the curated list and assigned a *medium* association, while the remainder were classified as *weak*. We validated the LLM-assisted classifications by confirming, through independent online documentation and service descriptions, the role attributed to *each* domain.

From the perspective of a network observer, domains in the *strong* category provide the highest confidence for attributing traffic to a specific application, whereas domains in the *medium* and *weak* categories offer progressively less certainty. Across the entire dataset, 27 (68%) applications exhibit the

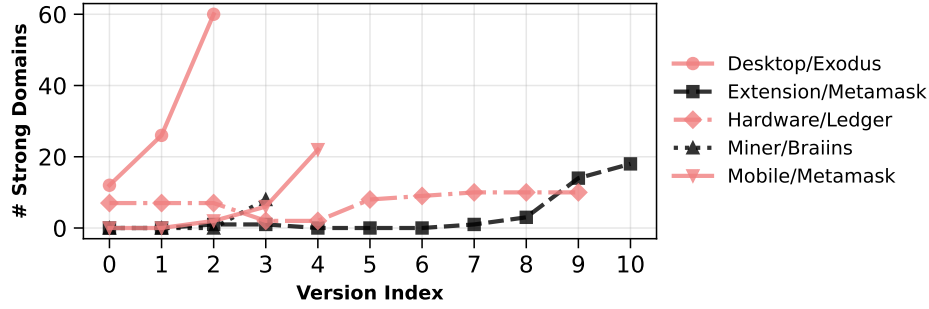


Figure 7.5: Trend of number of strong domains across versions for selected applications, one from each category.

highest number of *strong* domains in their latest versions, and 35 (88%) applications have at least one *strong* domain in their latest version and are therefore uniquely identifiable at the DNS level under our threat model.

We observe a total of 528 unique *strong* domains and 644 unique *medium* domains, with a median of 5 *strong* domains per application. Furthermore, *strong* domains are exclusive to their originating applications and do not appear in the network footprints of other applications or in the crawler-collected *weak* domain set. Figure 7.4 presents the number of *strong* domains for the five applications with the largest counts in their latest versions, and additionally reports the total number of *strong* domains observed across all versions of each application. Figure 7.5 traces the evolution of *strong* domain counts across versions for a representative application from each software class. The observed upward trends suggest that domain-based fingerprintability persists across releases, and in some cases intensifies as applications mature and expand their network dependencies. Taken together, these results demonstrate that the large majority of cryptocurrency applications can be reliably identified

Criterion	Past Version(s)		Latest Version	
	# Unique	# Not Unique	# Unique	# Not Unique
Family	32 (80%)	8 (20%)	34 (85%)	6 (15%)
Global	12 (30%)	28 (70%)	18 (45%)	22 (55%)

Table 7.3: Number of fingerprintable and non-fingerprintable applications under different uniqueness definitions.

based solely on their DNS emissions.

To further quantify attribution potential, we define two notions of fingerprintability for a given application version. Under the *Family* definition, the DNS fingerprint of an application version is non-empty, containing at least one domain not shared with any other application, although it may appear in other versions of the same application. Under the stricter *Global* definition, the fingerprint contains at least one domain that appears in no other application or version. Intuitively, *Family* fingerprintability allows a network observer to infer the presence of a particular application but not its exact version, whereas *Global* fingerprintability enables inference of both the application and its specific version.

Table 7.3 summarizes the number of applications that satisfy these two definitions, both when considering the latest version of each application and when considering all past versions in our dataset. We find that a substantial fraction of applications are fingerprintable based solely on their DNS fingerprints. Applications that do not exhibit a unique fingerprint lack *strong* domains in their DNS footprints. Our results suggest that for 34 (85%) applications, a network observer can determine that a user is running the latest

application version.

7.5.2 User Action Identification

We investigate whether DNS activity reveals information about user interactions with an application. As shown in Table 7.2, domains in the *strong* category not only provide high-confidence evidence that the traffic originates from MetaMask, but also reveal the specific functionality being exercised, such as staking, portfolio management, or transaction-related activity. This behavior-level leakage stems from system design choices made by application developers, who commonly adopt microservice-based designs to support modular functionality and load balancing. As a result, different user interactions trigger requests to distinct backend services, which manifest as separate DNS requests. Consequently, DNS traces can distinguish between different modes of user engagement.

To understand what user actions can be inferred from DNS activity, we interacted with all versions of all applications in our dataset and recorded the DNS requests generated during each interaction type, following the methodology described in Section 7.4. We group user interactions into three categories. *Idle* corresponds to cases where the application or mining firmware is launched but not actively used, with no user interaction or cryptomining activity beyond startup. This captures scenarios in which a user has installed and opened the application or firmware but has not yet engaged with it. *Active* includes interactions such as account setup, wallet import, portfolio browsing, checking

Interaction Group	Past Apps	Past Versions	Latest Versions	Past Avg. Domains	Latest Avg. Domains
<i>Idle</i>	22 (55%)	148 (56%)	17 (43%)	8.91	20.18
<i>Active</i>	20 (50%)	139 (53%)	19 (48%)	5.09	8.95
<i>Transaction</i>	9 (23%)	21 (8%)	9 (23%)	3.19	1.78

Table 7.4: Behavior fingerprintability across interaction groups.

cryptocurrency prices, and cryptomining. *Transaction* refers to cases where the user initiates a cryptocurrency transaction, such as sending and receiving funds, or buying and selling assets. This category applies only to applications capable of performing on-chain operations and represents sensitive financial activity.

An application is considered to belong to a given interaction category if it resolves at least one domain that appears exclusively during that interaction. For example, if a domain is resolved during a transaction but does not appear during application startup or other interactions, it is assigned to the *Transaction* category. At the same time, if there is a domain that only resolves during idle usage, the application is also classified under the *Idle* category.

Table 7.4 summarizes behavior-level fingerprintability per interaction category, broken down by historical and latest versions, with the average number of identifiable domains per version. We find that the latest versions of 9 (23%) popular wallet applications resolve domains that enable a network observer to infer when a user is performing a cryptocurrency transaction using the wallet. Specifically, this behavior is observed in the browser extension versions of Crypto.com, Keplr Wallet, Leap Wallet, MetaMask, Phantom Wallet, Solflare Wallet, Trust Wallet, and Typhon Wallet, as well as in the Meta-

Mask mobile application. Across all of these applications, transaction-related DNS activity arises from interactions with backend APIs used to fetch gas fee estimates or to connect to blockchain nodes, making transaction execution distinguishable at the DNS level.

In the case of the Phantom wallet browser extension, we observe that during idle usage, the extension queries domains related to proxy services and error reporting. As the user becomes active and navigates through the application, additional APIs and data services are contacted. Finally, when the user initiates a transaction, the extension reaches out to `gas-price-oracle.phantom.app` to fetch current gas prices. If the user is sending assets to an Unstoppable Domain [128], the extension also queries `api.unstoppabledomains.com` to resolve the human-readable name to a cryptocurrency address. From this DNS query pattern, the network observer can infer not only that the user is performing a transaction but also that they are using an Unstoppable Domain for their transaction.

Similar patterns are observed in other applications, such as in the MetaMask mobile app, where the `tx-sentinel-...api.cx.metamask.io` domain is queried only when a transaction is initiated. In the case of mining firmware like Braiins OS, multiple *strong* domains are contacted to connect to BraiinsOS services on startup. Similarly, the HiveOS mining firmware connects to a different set of domains on startup (e.g., `api.hiveos.farm`) which are unique to HiveOS.

ASN	Organization	# IP (%)
13335	Cloudflare	99 (47.6%)
14618	Amazon	51 (24.5%)
16509	Amazon	21 (10.1%)
396982	Google	11 (5.3%)
12876	Online SAS	6 (2.9%)

Table 7.5: *Distribution of Web3-related domains across ASNs.*

7.6 Real-World Observability

In this section, we analyze the infrastructure and real-world usage of domains associated with the cryptocurrency applications under study using two vantage points.

7.6.0.1 Passive DNS

Understanding where cryptocurrency-related server endpoints are hosted is important for evaluating the practical decentralization guarantees of Web3 technologies. While blockchain protocols themselves are designed to be decentralized, the supporting services, such as the domains discussed in Section 7.5, often rely on centralized Internet providers, introducing potential chokepoints for censorship. We therefore examine the hosting infrastructure underlying these domains to assess the extent to which the backend services supporting cryptocurrency client software are distributed across Internet infrastructure providers.

To this end, we use DomainTools’ passive DNS (pDNS) dataset [243] to collect the most recent IPv4 and IPv6 addresses for 197 representative *strong* and *medium* domains that are stable across application versions. This dataset

is constructed from telemetry aggregated from recursive resolvers across global vantage points. We then map each observed IP address to its origin AS using a public IP-to-ASN service [244], which infers AS attribution from BGP routing announcements. This mapping captures the network operators that route traffic to the backend infrastructure at the time of observation.

We find that a majority of the infrastructure servicing users of cryptocurrency client software is operated by a concentrated set of network providers, placing these providers in a position to potentially censor these services and disrupt millions of users’ ability to access the blockchain and their digital assets. Table 7.5 shows the distribution of the domains across the top 5 ASes, which together account for 90% of all observed IP addresses.

In addition, passive DNS records reveal sustained and widespread resolution of these domains, as evidenced by large numbers of RRset observations accumulated over extended time periods. Across the analyzed domains, recursive resolvers recorded an average of 11.5M RRset observations and a median of 1.4M observations, with `api.coinbase.com` having over 200M observed RRsets between 2014 and 2025.

7.6.0.2 Enterprise URL Filtering logs

While passive DNS provides a global view of the persistence and deployment of Web3-supporting domains, it does not capture how these domains appear within live operational networks or reflect actual user activity. To understand how Web3-supporting domains manifest in real usage environments,

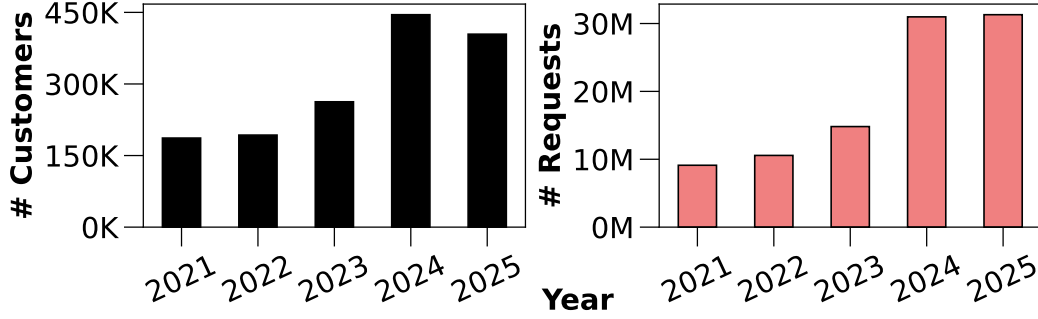


Figure 7.6: Aggregate number of customers and requests associated with domains from DNS fingerprints over time.

we therefore analyze aggregated DNS resolution activity derived from enterprise URL filtering logs collected by Palo Alto Networks. This data is collected through routine security monitoring across enterprise customer networks of varying scale. It allows us to quantify the practical observability of Web3 DNS fingerprints and characterize their prevalence across industry sectors.

To perform this measurement, we analyze resolution activity associated with the same set of domains used in our passive DNS analysis that comprise the DNS fingerprints of the applications under study. These fingerprint-related resolutions appear alongside billions of other domains routinely processed within customer networks during normal security operations. To place these signals in a longitudinal context, we isolate fingerprint-related traffic collected during each October between 2021 and 2025. For each snapshot, we measure both the total number of DNS requests generated towards fingerprint domains and the number of distinct customer networks issuing those requests, where a single customer network may encompass multiple end users.

Overall, our results indicate substantial activity associated with our cu-

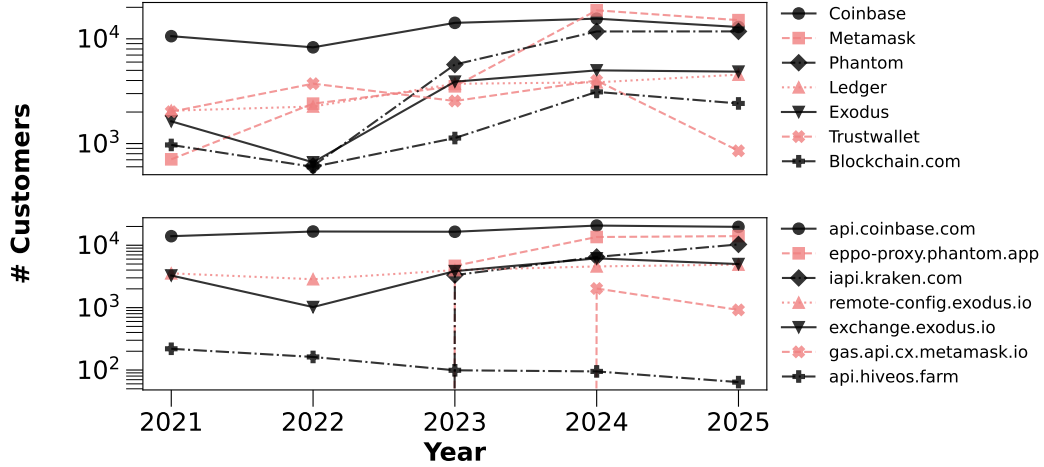


Figure 7.7: The top panel reports the number of customers resolving two or more domains belonging to the same application fingerprint within a 30-minute window, shown over the 2021 to 2025 period. The bottom panel shows the number of customers resolving the five most frequently observed hostnames in the dataset over time.

rated DNS fingerprints. We observe a general upward trend in both metrics over time, with DNS request volume increasing from 9.1M in October 2021 to 31.2M in October 2025. Figure 7.6 shows the total number of unique customer networks and the total volume of DNS requests generated by those networks for domains associated with selected representative fingerprints. The slower growth observed from 2024 to 2025 is likely due to coverage limitations, as fingerprints collected in mid-2025 may not capture domains introduced in the most recent application versions.

To further distinguish genuine application usage, we identify instances in which a single device within a customer network resolves two or more *strong* domains associated with the same application fingerprint within a 30-minute window. Using this criterion, we were able to identify user activity across 27 applications over time, with the number of users increasing from 27K in

2021 to 68K in 2025. The top panel of Figure 7.7 shows the number of user devices through which we detect such activity for 7 popular applications. In the bottom panel, we show the activity towards individual domains, which reveals high activity for *strong* domains in application fingerprints. For example, in October 2024, activity across 2,000 customers was observed for `gas.api.cx.metamask.io` totaling 74.5K requests. This domain is resolved by the MetaMask extension and mobile application to retrieve gas fee estimates for Ethereum transactions when the user is preparing a transaction.

Enterprise networks represent a particularly consequential vantage point for observing cryptocurrency-related activity, as they often operate under strict compliance requirements, and routinely monitor DNS traffic for security purposes. Understanding whether cryptocurrency client software appears in such environments is therefore critical for assessing whether the privacy assumptions users associate with Web3 systems hold in practice. At the same time, the presence of these signals may also reflect opportunities for legitimate defensive practices, such as the use of DNS-based monitoring to detect unauthorized cryptocurrency activity, such as cryptocurrency mining on campus networks.

Figure 7.8 supports this analysis by showing the number of domain resolutions per enterprise customer category associated with cryptocurrency application fingerprints. We observe that these DNS signals span a wide range of sectors, including regulated and security-sensitive industries such as *Healthcare*, *Federal Government*, and *State and Local Government*. This demonstrates that cryptocurrency client software is present not only in consumer or

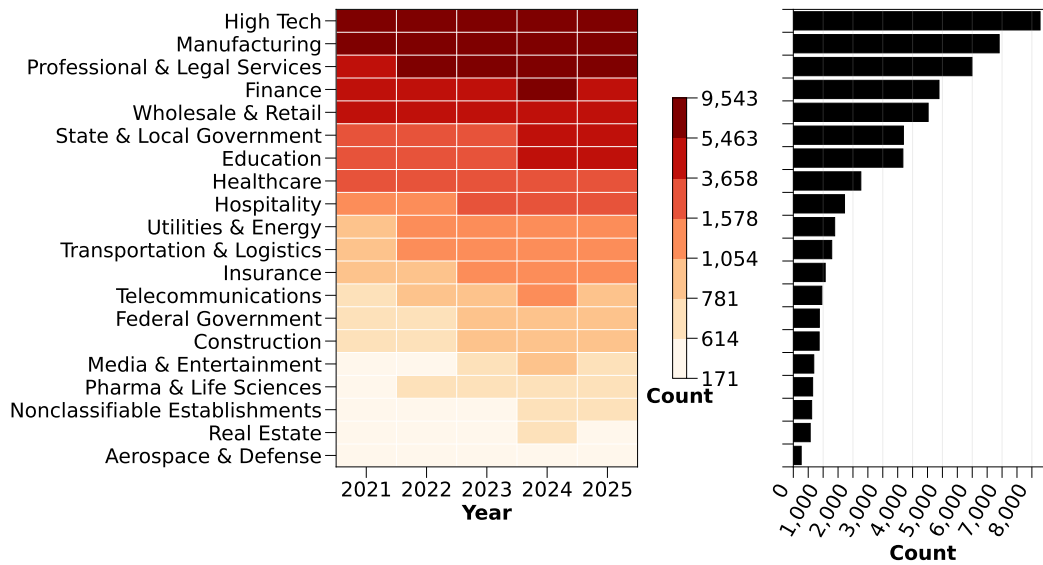


Figure 7.8: Number of customers resolving domains from application fingerprints spanning multiple industry categories over time.

technology-centric settings, but also within organizational environments where network traffic is commonly monitored and retained. In such contexts, the visibility of DNS traffic increases the likelihood that cryptocurrency application usage and associated behavioral patterns can be inferred by network operators, even when users enable third-party DNS encryption mechanisms (Section 7.2).

Together, these results highlight that the DNS dependencies of Web3 applications create practical points of observability and control, with implications for large-scale monitoring and censorship that users may not anticipate.

7.7 Chapter Summary

In this chapter, we showed that privacy and censorship resistance in cryptocurrency applications are only as strong as the client software through which users access them. By analyzing the DNS behavior of 40 cryptocurrency

applications across 303 versions, we demonstrated that a passive observer at the DNS resolver level can identify which application a user runs, determine its version, and detect when a financial transaction is initiated. The infrastructure supporting these applications is highly concentrated, with 90% of representative IP addresses routed through just five Autonomous Systems, creating practical chokepoints for censorship. Validation against enterprise DNS telemetry confirms these signals are observable across thousands of real-world networks, including regulated industries such as healthcare and government. We hope this work encourages Web3 developers to treat DNS-level privacy as a first-class design concern.

Chapter 8

Discussion

This chapter steps back from the individual findings of Chapters 3–7 to discuss what these recurring themes imply for the security and privacy of the cryptocurrency ecosystem as a whole. In particular, what we learned about studying this ecosystem empirically, which problems remain open despite the defenses we proposed, and how other researchers and practitioners can further advance this area of research.

8.1 Implications

The overarching implication of this dissertation is that the threats cryptocurrency users face carry far greater financial consequences than their counterparts on the traditional web, since transactions are irreversible and victims have no recourse once funds are sent. Yet we found that the current state of the cryptocurrency ecosystem provides only limited, and in most cases no, defenses against the threats covered in this dissertation. Where defenses do exist, such as the blocklists that digital wallet vendors rely on, they are inherently reactive. In such reactive defenses, users are only protected after an attack has already occurred. Going forward, new cryptocurrency technologies

should be paired from the outset with security guardrails. With our work in Chapters 5 and 6 of this thesis, we show that deploying practical defenses at scale has the potential to prevent millions of dollars in financial losses.

Moreover, we show that even though Web3 is marketed as eliminating users' dependence on centralized intermediaries, such claims do not hold true in practice. Because cryptocurrency-supporting applications still depend on traditional Internet infrastructure such as DNS, users remain exposed to centralized ISPs, DNS resolvers, and network operators, undermining the decentralization these systems advertise and, by extension, the privacy users expect to come with it.

8.2 Lessons Learned and Open Problems

Carrying out these studies surfaced a number of recurring considerations. For each, we state what we learned in confronting it, what remains unresolved despite our efforts, and, where one exists, how it can be addressed.

8.2.1 Establishing Transaction Intent

Firstly, on-chain data alone is rarely sufficient to establish the intent behind a cryptocurrency transaction. For example, it is difficult to tell whether a payment to an attacker's wallet address came from a victim or from a wallet the attacker operates themselves. A further version of this problem is that using on-chain data by itself, researchers cannot guarantee whether a specific victim's payment resulted from the attack under study or from a different

attack campaign run by the same attacker reusing the same address. Chapters 3 and 4 both confronted a version of this aliasing problem, in which a transaction sent to a squatting or re-registered domain is not, by itself, distinguishable from a transaction the sender genuinely intended to make. Chapter 6 confronted a related problem, where a payment to a wallet address advertised on a scam website is not necessarily a payment made by one of that website’s victims.

In each case, we mitigated the problem by corroborating the on-chain record with independent signals. We layered conservative transaction-pattern-based filters (*e.g.*, requiring a sender to have paid the legitimate domain before paying its typosquatting variant) in Chapters 3 and 4, and cross-checked wallet addresses against signals collected from the scam website itself (*e.g.*, the website’s creation date) in Chapter 6. For future on-chain measurement studies in this space, similar assumptions and filtering choices might be necessary to avoid overestimating the scale of a given threat.

8.2.2 Attributing Transactions to BNS Domains

Even once a transaction is linked to an attacker, the blockchain gives no direct signal of *how* the victim entered the attacker’s address while performing the transaction, i.e., whether they resolved a BNS domain or simply pasted an address into the digital wallet. Name resolution in naming systems, such as ENS, happens off-chain. It takes place through calling resolver smart contracts that happen on the client software. After the user sends a transaction by using

a BNS name, only the resulting address is ever recorded in the transaction on the blockchain. Therefore, no link between a transaction and the name that produced it survives on-chain.

This makes it difficult to measure the popularity of BNS domains in practice, since the only signal available is the on-chain record of transactions, which does not indicate whether a user resolved a BNS name or simply pasted an address into their wallet. A popularity metric for BNS domains would be useful since it would allow defenders to prioritize which domains to protect against attacks such as typosquatting and dropcatching. To address this problem, digital wallets could optionally log BNS resolution activity. Aggregated across users, such logs would reveal which domains are actually resolved most often in practice. This would give defenders a ground-truth signal of domain popularity that could directly inform which names are worth prioritizing when designing security protections.

8.2.3 Digital Wallet Warnings

In Chapter 5, we showed that client-side warnings against cryptocurrency-based social engineering attacks can be deployed at negligible engineering cost. An open research question is how to present these warnings so that users actually read and act on them. The broader security-warning literature offers a cautionary lesson, since overly frequent or generic warnings are known to lead to habituation, where users learn to dismiss them without reading. Future work could design user studies, following this line of research, to determine

how to display warnings in the wallet setting that change user behavior without adding to alert fatigue [245, 246, 247, 248].

8.2.4 Content-based Malicious Website Detection

The scam detection pipeline presented in Chapter 6 pairs Certificate Transparency logs with keyword filtering and large-language-model classification. We designed and evaluated it specifically for cryptocurrency investment scams, but the general approach is not limited to this one category. Researchers could apply the same pipeline to other types of malicious webpages, such as phishing pages, by adjusting the keyword filters and the LLM classification prompt to match the target fraud pattern. The number of keywords used at each filtering stage, and the prompting strategy given to the LLM, are both parameters that can be tuned depending on the computational and financial resources available, trading off coverage against cost.

8.2.5 DNS as a Privacy Leak

In Chapter 7, we showed that the DNS resolution behavior of cryptocurrency client software produces stable, application-specific fingerprints. This is a privacy concern because it allows a network intermediary, such as an ISP or a campus network operator, to identify a user’s cryptocurrency usage from DNS traffic alone. The root cause of this problem is that running a full blockchain node is itself out of reach for most users, as doing so requires a degree of technical expertise and hardware investment that the average user does not

possess. As a result, most users rely on third-party infrastructure to access the blockchain, which exposes them to network-level privacy risks.

Lowering the barrier to running such infrastructure independently is one direction future work could pursue. A second direction targets the DNS traffic itself. Chapter 7 found that the domains most responsible for fingerprinting an application are its own first-party backend domains. This is because developers commonly expose a uniquely named subdomain for each feature, such as staking or transaction submission. Reducing this granularity, for example by routing multiple backend functions through a shared endpoint rather than a distinct subdomain for each one, could limit how much a network observer learns about a specific user action.

Chapter 9

Conclusion

This dissertation examined the gap between the security and privacy that cryptocurrencies are widely believed to provide and what users actually experience in practice. Across five studies, we found that this gap recurs wherever users interact with cryptocurrencies through software that has converged on the infrastructure and design patterns of the traditional web.

Our measurements of blockchain naming systems showed that typosquatting and dropcatching are active, ongoing threats, with attackers registering malicious names at an increasing rate and intercepting funds from thousands of transactions. Motivated by the limited protections against these and related threats in existing wallet software, we showed that lightweight, client-side defenses can be integrated into a widely used wallet with minimal engineering effort. We demonstrated the effectiveness of these defenses in detecting real-world attacks without exclusively relying on the centralized blocklists, which is currently a common practice among popular digital wallets. Beyond naming systems and wallets, we found that the web infrastructure surrounding cryptocurrency adoption introduces its own risks. We designed and deployed a system that detects cryptocurrency investment scam websites in real time

as they are created, and found that the large majority of the scam websites it identified were absent from the blocklists used by popular browsers and applications. We also conducted a systematic study of DNS resolution behavior in cryptocurrency client software, and found that this behavior produces stable, application-specific fingerprints. Using global passive DNS records and enterprise URL filtering logs from a major network security provider, we confirmed that these fingerprints are observable in practice, allowing a network intermediary to identify the specific cryptocurrency application a user is running and to infer sensitive details about their behavior.

We hope that the developers of cryptocurrency wallets, naming services, and related infrastructure adopt defenses similar to those presented in this dissertation, and that the measurements and systems we developed support continued research into the security and privacy of the cryptocurrency application layer.

Bibliography

- [1] CyLab, 2025, “Toxin Tagger (T-T): Real-time Detection System for Blockchain Address Poisoning”, URL <https://cryptotrade.cylab.cmu.edu/poisoning/ethereum>.
- [2] Nakamoto, S., 2008, “Bitcoin: A peer-to-peer electronic cash system”, URL <https://bitcoin.org/bitcoin.pdf>.
- [3] Tsuchiya, T., Dong, J.-D., Soska, K., and Christin, N., 2025, “Blockchain Address Poisoning”, USENIX Security 2025.
- [4] Guan, S. and Li, K., 2024, “Characterizing Ethereum address poisoning attack”, Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security, pp. 986–1000.
- [5] Mockapetris, P., November 1983, “DOMAIN NAMES - IMPLEMENTATION and SPECIFICATION”, <https://datatracker.ietf.org/doc/html/rfc883>.
- [6] “Namecoin”, <http://namecoin.org/>.
- [7] 1999, “Anticybersquatting Consumer Protection Act (ACPA)”, <https://www.govinfo.gov/content/pkg/PLAW-106publ113/html/PLAW-106publ113.htm>.
- [8] Kesmodel, D., 2008, The domain game: how people get rich from Internet domain names, Xlibris Corporation.
- [9] Le Pochat, V., Van Goethem, T., and Joosen, W., 2019, “A Smörgåsbord of typos: exploring international keyboard layout typosquatting”, IEEE Security and Privacy Workshops (SPW), IEEE, pp. 187–192.
- [10] Khan, M. T., Huo, X., Li, Z., and Kanich, C., 2015, “Every second counts: Quantifying the negative externalities of cybercrime via typosquatting”, IEEE Symposium on Security and Privacy, IEEE, pp. 135–150.
- [11] Szurdi, J., Kocso, B., Cseh, G., Spring, J., Felegyhazi, M., and Kanich, C., 2014, “The long “taile” of typosquatting domain names”, USENIX Security Symposium, pp. 191–206.

- [12] Agten, P., Joosen, W., Piessens, F., and Nikiforakis, N., 2015, “Seven months’ worth of mistakes: A longitudinal study of typosquatting abuse”, Proceedings of the 22nd Network and Distributed System Security Symposium (NDSS), Internet Society.
- [13] Edelman, B., 2003, “Large-scale registration of domains with typographical errors”, 2003a. Harvard University., “Domain Name Typosquatter Still Generating Millions.”, 2003b. Harvard University.
- [14] Banerjee, A., Barman, D., Faloutsos, M., and Bhuyan, L. N., 2008, “Cyber-fraud is one typo away”, IEEE INFOCOM-The 27th Conference on Computer Communications, IEEE, pp. 1939–1947.
- [15] Moore, T. and Edelman, B., 2010, “Measuring the perpetrators and funders of typosquatting”, International Conference on Financial Cryptography and Data Security, pp. 175–191.
- [16] Tahir, R., Raza, A., Ahmad, F., Kazi, J., Zaffar, F., Kanich, C., and Caesar, M., 2018, “It’s all in the name: Why some URLs are more vulnerable to typosquatting”, IEEE INFOCOM-IEEE Conference on Computer Communications, IEEE, pp. 2618–2626.
- [17] Koide, T., Fukushi, N., Nakano, H., and Chiba, D., 2023, “PhishReplicant: A Language Model-based Approach to Detect Generated Squatting Domain Names”, Proceedings of the 39th Annual Computer Security Applications Conference, pp. 1–13.
- [18] Blefari, F., Furfaro, A., Ianni, G., Viscomi, A., et al., 2024, “TypoAlert: a browser extension against typosquatting”, Proc. of SEBD: 32nd Symposium on Advanced Database Systems.
- [19] Valentim, R. V., Drago, I., Mellia, M., and Cerutti, F., 2024, “X-squatter: AI Multilingual Generation of Cross-Language Sound-squatting”, ACM Transactions on Privacy and Security.
- [20] Majumdar, D., Arjun, S., Boyina, P., Rayidi, S. S. P., Sai, Y. R., and Gangashetty, S. V., 2024, “Beyond Text: Nefarious Actors Harnessing LLMs for Strategic Advantage”, International Conference on Intelligent Systems for Cybersecurity (ISCS), IEEE, pp. 1–7.
- [21] Lepipas, A., Borovykh, A., and Demetriou, S., 2024, “Username squatting on online social networks: A study on x”, Proceedings of the 19th ACM Asia Conference on Computer and Communications Security, pp. 621–637.
- [22] Holgers, T., Watson, D. E., and Gribble, S. D., 2006, “Cutting through the Confusion: A Measurement Study of Homograph Attacks.”, USENIX Annual Technical Conference, General Track, pp. 261–266.

- [23] Nikiforakis, N., Balduzzi, M., Desmet, L., Piessens, F., and Joosen, W., 2014, “Soundsquatting: Uncovering the use of homophones in domain squatting”, *Information Security: 17th International Conference, ISC*, Hong Kong, China, October 12-14, 2014. Proceedings 17, Springer, pp. 291–308.
- [24] Valentim, R., Drago, I., Cerutti, F., and Mellia, M., 2022, “AI-based Sound-Squatting Attack Made Possible”, *IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pp. 448–453.
- [25] Nikiforakis, N., Van Acker, S., Meert, W., Desmet, L., Piessens, F., and Joosen, W., 2013, “Bitsquatting: Exploiting bit-flips for fun, or profit?”, *Proceedings of the 22nd international conference on World Wide Web*, pp. 989–998.
- [26] Dinaburg, A., 2011, “Bitsquatting: DNS hijacking without exploitation”, *Proceedings of BlackHat Security*.
- [27] Kintis, P., Miramirkhani, N., Lever, C., Chen, Y., Romero-Gómez, R., Pitropakis, N., Nikiforakis, N., and Antonakakis, M., 2017, “Hiding in plain sight: A longitudinal study of combosquatting abuse”, *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, pp. 569–586.
- [28] Vu, D.-L., Pashchenko, I., Massacci, F., Plate, H., and Sabetta, A., 2020, “Typosquatting and combosquatting attacks on the python ecosystem”, *ieee european symposium on security and privacy workshops (eu-ros&pw)*, pp. 509–514.
- [29] Wang, Y.-M., Beck, D., Wang, J., Verbowski, C., and Daniels, B., 2006, “Strider Typo-Patrol: Discovery and Analysis of Systematic Typo-Squatting.”, *SRUTI*, **6(31-36)**, pp. 2–2.
- [30] 2023, “Alexa Top Websites — Last Save before it was closed. <https://www.expireddomains.net/alexa-top-websites/>”, URL <https://www.expireddomains.net/alexa-top-websites/>.
- [31] Le Pochat, V., Van Goethem, T., Tajalizadehkhoob, S., Korczynski, M., and Joosen, W., 2019, “Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation”, *NDSS*.
- [32] Kalodner, H. A., Carlsten, M., Ellenbogen, P. M., Bonneau, J., and Narayanan, A., 2015, “An Empirical Study of Namecoin and Lessons for Decentralized Namespace Design.”, *Workshop on the Economics of Information Security*.
- [33] Xia, P., Wang, H., Yu, Z., Liu, X., Luo, X., Xu, G., and Tyson, G., 2022, “Challenges in decentralized name management: the case of ENS”,

- Proceedings of the 22nd ACM Internet Measurement Conference, pp. 65–82.
- [34] Randall, A., Hardaker, W., Voelker, G. M., Savage, S., and Schulman, A., “The Challenges of Blockchain-Based Naming Systems for Malware Defenders”, 2022 APWG Symposium on Electronic Crime Research (eCrime), pp. 1–14.
 - [35] Ali, M., Nelson, J., Shea, R., and Freedman, M. J., “Blockstack: A global naming and storage system secured by blockchains”, 2016 USENIX annual technical conference (USENIX ATC), pp. 181–194.
 - [36] Dong, Y., Kim, W., and Boutaba, R., “Bitforest: a portable and efficient blockchain-based naming system”, 2018 14th International Conference on Network and Service Management (CNSM), pp. 226–232.
 - [37] Osborn, G. and Alan, N., 2023, “Web 3 disruption and the domain name system: understanding the trends of blockchain domain names and the policy implications”, *Journal of Cyber Policy*, pp. 1–23.
 - [38] Casino, F., Lykousas, N., Katos, V., and Patsakis, C., 2021, “Unearthing malicious campaigns and actors from the blockchain DNS ecosystem”, *Computer Communications*, **179**, pp. 217–230.
 - [39] Theoder, J., Metharath, B. S., and Alouneh, S., “Securing Domain Name Systems with Blockchain”, 2023 Fourth International Conference on Intelligent Data Science Technologies and Applications (IDSTA), pp. 48–53.
 - [40] Tamhankar, A., Dhavale, S., Mishra, A., Rajendran, B., and Palaniappan, G., “Blockchain Based Decentralized Technology For Internet Naming Systems”, 2023 IEEE 11th Region 10 Humanitarian Technology Conference (R10-HTC), pp. 1–6.
 - [41] Ito, D., Takata, Y., Kumagai, H., and Kamizono, M., 2024, “Investigations of Top-Level Domain Name Collisions in Blockchain Naming Services”, *Proceedings of the ACM on Web Conference 2024*, pp. 2926–2935.
 - [42] Huang, J., Xia, P., Li, J., Ma, K., Tyson, G., Luo, X., Wu, L., Zhou, Y., Cai, W., and Wang, H., 2024, “Unveiling the Paradox of NFT Prosperity”, *Proceedings of the ACM on Web Conference 2024*, pp. 167–177.
 - [43] Das, D., Bose, P., Ruaro, N., Kruegel, C., and Vigna, G., 2022, “Understanding security issues in the NFT ecosystem”, *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, pp. 667–681.

- [44] Chen, H. and Cai, W., 2023, “How information manipulation on social media influences the NFT investors’ behavior: A case study of Goblin-town. Wtf”, *IEEE Transactions on Computational Social Systems*.
- [45] Keizer, N., Ascigil, O., Król, M., Kutscher, D., and Pavlou, G., 2024, “A Survey on Content Retrieval on the Decentralised Web”, *ACM Computing Surveys*, **56(8)**, pp. 1–39.
- [46] Torres, C. F., Willi, F., and Shinde, S., 2023, “Is Your Wallet Snitching On You? An Analysis on the Privacy Implications of Web3”, .
- [47] Pentinsaari, J., 2023, “Private Key Vulnerabilities in Browser Wallets”, .
- [48] Yan, K., Zhang, J., Liu, X., Diao, W., and Guo, S., “Bad Apples: Understanding the Centralized Security Risks in Decentralized Ecosystems”, *Proceedings of the ACM Web Conference 2023*, pp. 2274–2283.
- [49] Winter, P., Lorimer, A. H., Snyder, P., and Livshits, B., 2023, “Security, Privacy, and Decentralization in Web3”, .
- [50] Yan, K., Zhang, X., and Diao, W., 2024, “Stealing Trust: Unraveling Blind Message Attacks in Web3 Authentication”, *arXiv preprint arXiv:2406.00523*.
- [51] Chatzigiannis, P., Chalkias, K., Kate, A., Mangipudi, E. V., Minaei, M., and Mondal, M., 2023, “SoK: Web3 Recovery Mechanisms”, *Cryptology ePrint Archive*.
- [52] Hu, S., Zhang, Z., Luo, B., Lu, S., He, B., and Liu, L., 2023, “Bert4eth: A pre-trained transformer for ethereum fraud detection”, *Proceedings of the ACM Web Conference 2023*, pp. 2189–2197.
- [53] So, J., Miramirkhani, N., Ferdman, M., and Nikiforakis, N., “Domains do change their spots: Quantifying potential abuse of residual trust”, *2022 IEEE Symposium on Security and Privacy (SP)*, pp. 2130–2144.
- [54] Lauinger, T., Chaabane, A., Buyukkayhan, A. S., Onarlioglu, K., and Robertson, W., 2017, “Game of Registrars: An Empirical Analysis of {Post-Expiration} Domain Name Takeovers”, *26th USENIX Security Symposium (USENIX Security 17)*, pp. 865–880.
- [55] Lauinger, T., Buyukkayhan, A. S., Chaabane, A., Robertson, W., and Kirda, E., “From deletion to re-registration in zero seconds: Domain registrar behaviour during the drop”, *Proceedings of the Internet Measurement Conference 2018*, pp. 322–328.
- [56] Miramirkhani, N., Barron, T., Ferdman, M., and Nikiforakis, N., “Panning for gold.com: Understanding the dynamics of domain dropcatching”, *Proceedings of the 2018 World Wide Web Conference*, pp. 257–266.

- [57] Halvorson, T., Levchenko, K., Savage, S., and Voelker, G. M., 2014, “XXXtortion? Inferring registration intent in the. XXX TLD”, Proceedings of the 23rd international conference on World wide web, pp. 901–912.
- [58] Halvorson, T., Szurdi, J., Maier, G., Felegyhazi, M., Kreibich, C., Weaver, N., Levchenko, K., and Paxson, V., “The BIZ top-level domain: ten years later”, Passive and Active Measurement: 13th International Conference, PAM 2012, Vienna, Austria, March 12-14th. Proceedings 13, Springer, pp. 221–230.
- [59] Moore, T. and Clayton, R., 2014, “The ghosts of banking past: Empirical analysis of closed bank websites”, International Conference on Financial Cryptography and Data Security, Springer, pp. 33–48.
- [60] Lever, C., Walls, R., Nadji, Y., Dagon, D., McDaniel, P., and Antonakakis, M., “Domain-z: 28 registrations later measuring the exploitation of residual trust in domains”, 2016 IEEE symposium on security and privacy (SP), pp. 691–706.
- [61] Nikiforakis, N., Invernizzi, L., Kapravelos, A., Van Acker, S., Joosen, W., Kruegel, C., Piessens, F., and Vigna, G., “You are what you include: large-scale evaluation of remote javascript inclusions”, Proceedings of the 2012 ACM conference on Computer and communications security, pp. 736–747.
- [62] Vissers, T., Barron, T., Van Goethem, T., Joosen, W., and Nikiforakis, N., “The wolf of name street: Hijacking domains through their name-servers”, Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, pp. 957–970.
- [63] Schlamp, J., Gustafsson, J., Wählisch, M., Schmidt, T. C., and Carle, G., “The abandoned side of the Internet: Hijacking Internet resources when domain names expire”, Traffic Monitoring and Analysis: 7th International Workshop, TMA 2015, Barcelona, Spain, April 21-24, 2015. Proceedings 7, Springer, pp. 188–201.
- [64] Lauinger, T., Onarlioglu, K., Chaabane, A., Robertson, W., and Kirda, E., “WHOIS Lost in Translation: (Mis) Understanding Domain Name Expiration and Re-Registration”, Proceedings of the 2016 Internet Measurement Conference, pp. 247–253.
- [65] Maroofi, S., Korczyński, M., Hesselman, C., Ampeau, B., and Duda, A., “Comar: Classification of compromised versus maliciously registered domains”, 2020 IEEE European Symposium on Security and Privacy (EuroS&P), pp. 607–623.

- [66] Barron, T., Miramirkhani, N., and Nikiforakis, N., “Now You See It, Now You Don’t: A Large-scale Analysis of Early Domain Deletions”, 22nd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2019), pp. 383–397.
- [67] Liu, G., Jin, L., Hao, S., Zhang, Y., Liu, D., Stavrou, A., and Wang, H., “Dial” N” for NXDomain: The Scale, Origin, and Security Implications of DNS Queries to Non-Existent Domains”, Proceedings of the 2023 ACM on Internet Measurement Conference, pp. 198–212.
- [68] Kalafut, A. J., Gupta, M., Cole, C. A., Chen, L., and Myers, N. E., 2010, “An empirical study of orphan DNS servers in the internet”, Proceedings of the 10th ACM SIGCOMM conference on Internet measurement, pp. 308–314.
- [69] Sommese, R., Jonker, M., van Rijswijk-Deij, R., Dainotti, A., Claffy, K. C., and Sperotto, A., “The forgotten side of dns: Orphan and abandoned records”, 2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), pp. 538–543.
- [70] Hao, S., Kantchelian, A., Miller, B., Paxson, V., and Feamster, N., “PREDATOR: proactive recognition and elimination of domain abuse at time-of-registration”, Proceedings of the 2016 ACM SIGSAC conference on computer and communications security, pp. 1568–1579.
- [71] Hao, S., Thomas, M., Paxson, V., Feamster, N., Kreibich, C., Grier, C., and Hollenbeck, S., “Understanding the domain registration behavior of spammers”, Proceedings of the 2013 conference on Internet measurement conference, pp. 63–76.
- [72] Liu, D., Hao, S., and Wang, H., “All your dns records point to us: Understanding the security threats of dangling dns records”, Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security, pp. 1414–1425.
- [73] Alowaisheq, E., Wang, P., Alrwais, S. A., Liao, X., Wang, X., Alowaisheq, T., Mi, X., Tang, S., and Liu, B., 2019, “Cracking the Wall of Confinement: Understanding and Analyzing Malicious Domain Take-downs”, 26th Annual Network and Distributed System Security Symposium, NDSS, The Internet Society.
- [74] Miramirkhani, N., Barron, T., Ferdman, M., and Nikiforakis, N., 2018, “Panning for gold.com: Understanding the dynamics of domain drop-catching”, Proceedings of the Web Conference (WWW).
- [75] So, J., Sanchez-Rola, I., and Nikiforakis, N., 2025, “Lost in the Mists of Time: Expirations in DNS Footprints of Mobile Apps”, USENIX Security 2025.

- [76] Hao, S., Feamster, N., and Pandrangi, R., 2011, “Monitoring the initial DNS behavior of malicious domains”, Proceedings of the 2011 ACM SIGCOMM conference on Internet measurement conference, pp. 269–278.
- [77] Halvorson, T., Der, M. F., Foster, I., Savage, S., Saul, L. K., and Voelker, G. M., “From. academy to. zone: An analysis of the new tld land rush”, Proceedings of the 2015 Internet Measurement Conference, pp. 381–394.
- [78] Valapu, S. T., Heidemann, J., Jonker, M., and Sommesse, R., 2026, “Zombies in Alternate Realities: The Afterlife of Domain Names in DNS Integrations”, arXiv preprint arXiv:2605.06880.
- [79] 2026, “DNS on ENS: ENS supports DNS names, allowing users to import DNS names into ENS.”, <https://docs.ens.domains/learn/dns/>.
- [80] Guan, S. and Li, K., 2025, “Ethereum Crypto Wallets under Address Poisoning: How Usable and Secure Are They?”, arXiv preprint arXiv:2508.12107.
- [81] Krombholz, K., Judmayer, A., Gusenbauer, M., and Weippl, E., 2016, “The other side of the coin: User experiences with bitcoin security and privacy”, International conference on financial cryptography and data security, Springer, pp. 555–580.
- [82] Fröhlich, M., Wagenhaus, M. R., Schmidt, A., and Alt, F., 2021, “Don’t stop me now! exploring challenges of first-time cryptocurrency users”, Proceedings of the 2021 ACM designing interactive systems conference, pp. 138–148.
- [83] Guan, Y., Yu, Y., Sharma, T., Qin, K., Wang, Y., and Wang, Y., 2023, “Examining User Perceptions of Stablecoins: Understandings and Risks”, Posters at the Symposium on Usable Privacy and Security (SOUPS), pp. 1–7.
- [84] Keat, O. S., Aun, O. C., AL, Y. J., and Hao, G. T., 2021, “Embracing Bitcoin: users’ perceived security and trust”, Quality and Quantity, **55**(4), pp. 1219–1237.
- [85] Abramova, S., Voskoboynikov, A., Beznosov, K., and Böhme, R., 2021, “Bits under the mattress: Understanding different risk perceptions and security behaviors of crypto-asset users”, Proceedings of the CHI Conference on Human Factors in Computing Systems, pp. 1–19.
- [86] Acharya, B., Saad, M., Cinà, A. E., Schönherr, L., Dai Nguyen, H., Oest, A., Vadrevu, P., and Holz, T., 2024, “Conning the crypto conman: End-to-end analysis of cryptocurrency-based technical support scams”, IEEE Symposium on Security and Privacy (SP), IEEE, pp. 17–35.

- [87] Weber, K., Schütz, A. E., Fertig, T., and Müller, N. H., 2020, “Exploiting the human factor: Social engineering attacks on cryptocurrency users”, *International Conference on Human-Computer Interaction*, Springer, pp. 650–668.
- [88] Eleshin, F., Sun, Q., Ye, M., Das, S., and Hong, J. I., 2025, “Of Secrets and Seedphrases: Conceptual Misunderstandings and Security Challenges for Seed Phrase Management among Cryptocurrency Users”, *Proceedings of the 2025 CHI Conference on Human Factors in Computing Systems*, pp. 1–19.
- [89] Miramirkhani, N., Starov, O., and Nikiforakis, N., 2017, “Dial One for Scam: A Large-Scale Analysis of Technical Support Scams”, *NDSS*.
- [90] Siu, G. A. and Hutchings, A., 2023, ““Get a higher return on your savings!”: Comparing adverts for cryptocurrency investment scams across platforms”, *2023 IEEE European symposium on security and privacy workshops (EuroS&PW)*, IEEE, pp. 158–169.
- [91] Siu, G. A., Hutchings, A., Vasek, M., and Moore, T., 2022, ““Invest in crypto!”: An analysis of investment scam advertisements found in Bitcointalk”, *2022 APWG symposium on electronic crime research (eCrime)*, IEEE, pp. 1–12.
- [92] Li, X., Rahmati, A., and Nikiforakis, N., 2024, “Like, Comment, Get Scammed: Characterizing Comment Scams on Media Platforms”, *Proceedings Network and Distributed System Security Symposium*, In *Network and Distributed System Security Symposium (NDSS)* San Diego, CA, USA.
- [93] Li, X., Rahmati, A., and Nikiforakis, N., 2024, “Like, Comment, Get Scammed: Characterizing Comment Scams on Media Platforms”, *Proceedings Network and Distributed System Security Symposium*.
- [94] Boshmaf, Y., Elvitigala, C., Al Jawaheri, H., Wijesekera, P., and Al Sabah, M., 2020, “Investigating MMM Ponzi scheme on bitcoin”, *Proceedings of the 15th ACM Asia Conference on Computer and Communications Security*, pp. 519–530.
- [95] Bartoletti, M., Carta, S., Cimoli, T., and Saia, R., 2020, “Dissecting Ponzi schemes on Ethereum: identification, analysis, and impact”, *Future Generation Computer Systems*, **102**, pp. 259–277.
- [96] Chen, W., Zheng, Z., Cui, J., Ngai, E., Zheng, P., and Zhou, Y., 2018, “Detecting ponzi schemes on ethereum: Towards healthier blockchain technology”, *Proceedings of the world wide web conference*.

- [97] Chen, W., Zheng, Z., Ngai, E. C.-H., Zheng, P., and Zhou, Y., 2019, “Exploiting blockchain data to detect smart ponzi schemes on ethereum”, IEEE Access.
- [98] Jung, E., Le Tilly, M., Gehani, A., and Ge, Y., 2019, “Data mining-based ethereum fraud detection”, IEEE international conference on blockchain.
- [99] Li, X., Yepuri, A., and Nikiforakis, N., 2023, “Double and nothing: Understanding and detecting cryptocurrency giveaway scams”, Proceedings of the Network and Distributed System Security Symposium (NDSS).
- [100] Liu, E., Kappos, G., Mugnier, E., Invernizzi, L., Savage, S., Tao, D., Thomas, K., Voelker, G. M., and Meiklejohn, S., “Give and take: An end-to-end investigation of giveaway scam conversion rates”, ACM Internet Measurement Conference 2024.
- [101] Li, K., Lee, D., and Guan, S., 2023, “Understanding the Cryptocurrency Free Giveaway Scam Disseminated on Twitter Lists”, IEEE International Conference on Blockchain.
- [102] of Investigation, F. B., October 2024, “Federal Bureau of Investigation Cryptocurrency Fraud Report 2023”, https://www.ic3.gov/Media/PDF/F/AnnualReport/2023_IC3CryptocurrencyReport.pdf.
- [103] Competition, A. and Commission, C., October 2024, “ACCC calls for united front as scammers steal over \$3bn from Australians”, https://www.accc.gov.au/media-release/accc-calls-for-united-front-as-scammers-steal-over-3bn-from-australians?utm_source=twitter_accc&utm_medium=social&utm_campaign=p_tru_g_awa_c_scams&utm_content=targeting_scams.2023&sf176457037=1.
- [104] Vekaria, Y., Beugin, Y., Munir, S., Acar, G., Bielova, N., Englehardt, S., Iqbal, U., Kapravelos, A., Laperdrix, P., Nikiforakis, N., et al., 2025, “SoK: Advances and Open Problems in Web Tracking”, arXiv.
- [105] Winter, P., Lorimer, A. H., Snyder, P., and Livshits, B., 2021, “Security, privacy, and decentralization in Web3”, arXiv.
- [106] Faulkenberry, A., Avgetidis, A., Ma, Z., Alrawi, O., Lever, C., Kintis, P., Monroe, F., Keromytis, A. D., and Antonakakis, M., 2022, “View from above: Exploring the malware ecosystem from the upper dns hierarchy”, ACSAC.
- [107] Kountouras, A., Kintis, P., Lever, C., Chen, Y., Nadj, Y., Dagon, D., Antonakakis, M., and Joffe, R., 2016, “Enabling network security through active DNS datasets”, RAID, Springer.

- [108] Muzammil, M., Pitumpe, A., Li, X., Rahmati, A., and Nikiforakis, N., 2025, “The poorest man in babylon: A longitudinal study of cryptocurrency investment scams”, *Proceedings of the ACM on Web Conference 2025*, pp. 1034–1045.
- [109] Ahmed, J., 2022, “Monitoring security of enterprise hosts via DNS data analysis”, Ph.D. thesis.
- [110] Lyu, M., Habibi Gharakheili, H., Russell, C., and Sivaraman, V., 2019, “Mapping an enterprise network by analyzing DNS traffic”, *PAM*, Springer.
- [111] Muzammil, M., Ansari, Z., Nikiforakis, N., and Johnson, D., 2026, “Echoes of the Past: Detecting and Classifying Re-registered Domains in Enterprise DNS Traffic”, *MADWeb*.
- [112] Plohmman, D., Yakdan, K., Klatt, M., Bader, J., and Gerhards-Padilla, E., 2016, “A comprehensive measurement study of domain generating malware”, *USENIX Security Symposium*.
- [113] Antonakakis, M., Perdisci, R., Nadji, Y., Vasiloglou, N., Abu-Nimeh, S., Lee, W., and Dagon, D., 2012, “From {Throw-Away} traffic to bots: Detecting the rise of {DGA-Based} malware”, *USENIX Security*.
- [114] Perdisci, R., Papastergiou, T., Alrawi, O., and Antonakakis, M., 2020, “Iotfinder: Efficient large-scale identification of iot devices via passive dns traffic analysis”, *EuroS&P*, IEEE.
- [115] Van Ede, T., Bortolameotti, R., Continella, A., Ren, J., Dubois, D. J., Lindorfer, M., Choffnes, D., Van Steen, M., and Peter, A., 2020, “Flow-print: Semi-supervised mobile-app fingerprinting on encrypted network traffic”, *NDSS*.
- [116] Xue, D., Ramesh, R., Jain, A., Kallitsis, M., Halderman, J. A., Crandall, J. R., and Ensafi, R., 2025, “OpenVPN is open to VPN fingerprinting”, *Communications of the ACM*.
- [117] Sun, H., Shi, R., Lan, L., Peng, Z., and Wang, C., 2024, “A Two-Stage Encrypted Cryptomining Traffic Detection Mechanism in Campus Network”, *ICBC*, IEEE.
- [118] Antonopoulos, A. M. and El Hariry, S., 2016, *The Internet of Money*, volume 1, Merkle Bloom LLC Columbia, MD.
- [119] Voshmgir, S., 2020, *Token Economy: How the Web3 reinvents the internet*, volume 2, Token Kitchen.
- [120] Ethereum, “What is Web3 and why is it important?”, <https://ethereum.org/en/web3/>.

- [121] Benet, J., 2014, “IPFS-content addressed, versioned, p2p file system”, arXiv preprint arXiv:1407.3561.
- [122] Muzammil, M., Wu, Z., Balasubramanian, A., and Nikiforakis, N., 2024, “Panning for gold.eth: Understanding and Analyzing ENS Domain Dropcatching”, Proceedings of the Internet Measurement Conference (IMC).
- [123] Patsakis, C., Casino, F., Lykousas, N., and Katos, V., 2020, “Unraveling ariadne’s thread: Exploring the threats of decentralised dns”, IEEE Access, **8**, pp. 118559–118571.
- [124] Li, Z., Gao, S., Peng, Z., Guo, S., Yang, Y., and Xiao, B., 2021, “B-DNS: A secure and efficient DNS based on the blockchain technology”, IEEE Transactions on Network Science and Engineering, **8(2)**, pp. 1674–1686.
- [125] 2024, “typosquatting3.0”, <https://github.com/pragseclab/typosquattin g3.0>.
- [126] 2023, “Ethereum Naming Service. <https://ens.domains/>”, URL <https://ens.domains/>.
- [127] 2023, “Terminology - ENS Documentation. <https://docs.ens.domains/terminology>”, URL <https://docs.ens.d omains/terminology>.
- [128] 2023, “Unstoppable Domains. <https://unstoppabledomains.com/>”, URL <https://unstoppabledomains.com/>.
- [129] 2023, “ADA Handle. <https://adahandle.com/>”, .
- [130] Florian, 2022, “What is Adahandle? The Cardano Name Service”, URL <https://altcoinoracle.com/what-is-adahandle/>.
- [131] 2023, “GraphQL — A query language for your API”, <https://graphql.org/>.
- [132] 2023, “ENS Subgraph”, <https://thegraph.com/hosted-service>.
- [133] 2023, “Etherscan — Ethereum (ETH) Blockchain Explorer”, <https://et herscan.io/>.
- [134] 2023, “Polygonscan — Polygon (Matic) Blockchain Explorer”, <https://polygonscan.com/>.
- [135] 2023, “Unstoppable Domains Developer Portal”, <https://docs.unstopp abledomains.com/openapi/partner/v2/>.
- [136] 2023, “Blockfrost.io - Cardano API”, <https://blockfrost.io/>.

- [137] Devlin, J., Chang, M., Lee, K., and Toutanova, K., 2018, “BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding”, CoRR, **abs/1810.04805**, URL <http://arxiv.org/abs/1810.04805>.
- [138] 2023, “Google Chrome now detects typos in your URLs - The Verge”, <https://www.theverge.com/2023/5/18/23728705/google-chrome-detects-typos-urls-accessibility>.
- [139] Thomas, K., McCoy, D., Grier, C., Kolcz, A., and Paxson, V., 2013, “{Trafficking} Fraudulent Accounts: The Role of the Underground Market in Twitter Spam and Abuse”, 22nd USENIX Security Symposium (USENIX Security), pp. 195–210.
- [140] Motoyama, M., Levchenko, K., Kanich, C., McCoy, D., Voelker, G. M., and Savage, S., 2010, “Re:{CAPTCHAs—Understanding}{CAPTCHA-Solving} Services in an Economic Context”, 19th USENIX Security Symposium (USENIX Security 10).
- [141] Mirian, A., DeBlasio, J., Savage, S., Voelker, G. M., and Thomas, K., 2019, “Hack for hire: Exploring the emerging market for account hijacking”, The World Wide Web Conference, pp. 1279–1289.
- [142] Van Goethem, T., Miramirkhani, N., Joosen, W., and Nikiforakis, N., 2019, “Purchased fame: Exploring the ecosystem of private blog networks”, Proceedings of the ACM Asia Conference on Computer and Communications Security, pp. 366–378.
- [143] Hernandez, O., May 2024, “Puma registers ENS domain, changes name to Puma.eth on Twitter”, <https://cointelegraph.com/news/puma-rebrands-to-puma-eth-on-twitter>.
- [144] Lab, P., August 2024, “ens-dropcatching”, <https://github.com/pragsec/lab/ens-dropcatching>.
- [145] ENS, March 2024, “ENS Subgraph”, <https://docs.ens.domains/web/subgraph>.
- [146] Graph, T., March 2024, “The Graph”, <https://thegraph.com/>.
- [147] Buterin, V. et al., 2013, “Ethereum white paper”, GitHub repository, **1**, pp. 22–23.
- [148] Eigenmann, D., May 2024, “Let’s Talk ENS Migration (Post-Mortem)”, <https://medium.com/deaneigenmann/lets-talk-ens-migration-a92d5c21df28>.
- [149] Opensea, April 2024, “Opensea.io”, <https://opensea.io/>.

- [150] Rodeck, D., August 2024, “Top NFT Marketplaces Of August 2024”, <https://www.forbes.com/advisor/investing/cryptocurrency/best-nft-marketplaces/>.
- [151] API, O., April 2024, “Opensea.io API”, <https://docs.opensea.io/reference/api-overview/>.
- [152] Gnosis, April 2024, “Gnosis Chain”, <https://www.gnosis.io/>.
- [153] Etherscan, April 2024, “Etherscan: Gnosis Active Treasury Management Smart Contract”, <https://etherscan.io/address/\0x849d52316331967b6ff1198e5e32a0eb168d039d>.
- [154] Boey, N., May 2024, “Most Expensive Crypto Domains”, <https://www.coingecko.com/research/publications/most-expensive-crypto-domains>.
- [155] Vision, April 2024, “Vision.io 3 Letters Club”, <https://vision.io/category/3-letters>.
- [156] Yahoo, May 2024, “Ethereum USD (ETH-USD)”, <https://nz.finance.yahoo.com/quote/ETH-USD/history/>.
- [157] ENS, March 2024, “ENS FAQ: What happens if I forget to renew my name”, <https://docs.ens.domains/faq>.
- [158] Sikorski, M., 2025, “Social Engineering on the Rise — New Unit 42 Report”, URL <https://www.paloaltonetworks.com/blog/2025/07/social-engineering-rise-new-unit-42-report/>.
- [159] Council, E. U., 2025, “Cybersecurity: social engineering”, URL <https://www.consilium.europa.eu/en/policies/cybersecurity-social-engineering/>.
- [160] Authority, U. N. P. S., 2025, “Social Engineering”, URL <https://www.npsa.gov.uk/security-campaigns/social-engineering-0>.
- [161] of State, U. D., 2025, “Understanding the Dangers of Social Engineering”, URL <https://www.state.gov/understanding-the-dangers-of-social-engineering>.
- [162] Google, September 2024, “Safe Browsing – Google Safe Browsing”, <https://safebrowsing.google.com/>.
- [163] Federal Bureau of Investigation, I. C. C. C. I., 2025, “2024 Internet Crime Report”, URL <https://www.ic3.gov/AnnualReport/Reports/2024.IC3Report.pdf>.
- [164] Huang, J., Chintapalli, S. R., Wang, M., and Gu, G., 2025, “Beyond Visual Confusion: Understanding How Inconsistencies in ENS Normalization Facilitate Homoglyph Attacks”, Proceedings of the ACM on Web Conference 2025, pp. 3004–3013.

- [165] Li, K., Lee, D., and Guan, S., 2023, “Understanding the cryptocurrency free giveaway scam disseminated on twitter lists”, 2023 IEEE International Conference on Blockchain (Blockchain), IEEE, pp. 9–16.
- [166] Liu, E., Kappos, G., Mugnier, E., Invernizzi, L., Savage, S., Tao, D., Thomas, K., Voelker, G. M., and Meiklejohn, S., 2024, “Give and Take: An End-To-End Investigation of Giveaway Scam Conversion Rates”, arXiv preprint arXiv:2405.09757.
- [167] Muzammil, M., Wu, Z., Balasubramanian, A., and Nikiforakis, N., 2024, “Panning for gold. eth: Understanding and Analyzing ENS Domain Dropcatching”, Proceedings of the 2024 ACM on Internet Measurement Conference, pp. 731–738.
- [168] Muzammil, M., Wu, Z., Harisha, L., Kondracki, B., and Nikiforakis, N., 2024, “Typosquatting 3.0: Characterizing squatting in blockchain naming systems”, 2024 APWG Symposium on Electronic Crime Research (eCrime), IEEE, pp. 94–108.
- [169] Chainalysis, 2025, “Anatomy of an Address Poisoning Scam”, URL <https://www.chainalysis.com/blog/address-poisoning-scam/>.
- [170] Ye, G., Hong, G., Zhang, Y., and Yang, M., 2024, “Interface Illusions: Uncovering the Rise of Visual Scams in Cryptocurrency Wallets”, Proceedings of the ACM Web Conference 2024, pp. 1585–1595.
- [171] Protos, 2025, “Refund of \$70M address poisoning scam ongoing, over 50% returned”, URL <https://protos.com/refund-of-70m-address-poisoning-scam-ongoing-over-50-returned/>.
- [172] Coinmetro, 2025, “What Are Address Poisoning Attacks?: How to protect yourself from address poisoning attacks”, URL <https://www.coinmetro.com/learning-lab/address-poisoning-attacks>.
- [173] Stokel-Walker, C., 2025, “Scammers are making thousands of dollars through blockchain typosquatting”, URL <https://www.fastcompany.com/91228285/scammers-are-making-thousands-of-dollars-through-blockchain-typosquatting>.
- [174] MetaMask, 2025, “MetaMask and ChainPatrol protect users with phishing warnings”, URL <https://metamask.io/news/metamask-chainpatrol-protect-users-with-phishing-warnings>.
- [175] Cube, 2025, “Wallet security”, URL <https://www.cube.exchange/what-is/allowlistblocklist>.
- [176] MetaMask, 2025, “Product Spotlight: Privacy Preserving Features in MetaMask”, URL <https://metamask.io/news/product-spotlight-privacy-preserving-features-in-metamask>.

- [177] MetaMask, 2025, “MetaMask Security Alerts by Blockaid: the new normal for a safer transaction experience”, URL <https://metamask.io/news/metamask-security-alerts-by-blockaid-the-new-normal-for-a-safer-transaction>.
- [178] MetaMask, 2025, “MetaMask”, URL <https://metamask.io/>.
- [179] Creatonics, M., 2025, “The Top 12 Best Ethereum Wallets (2025 Edition)”, URL <https://coinsutra.com/best-ethereum-wallets/>.
- [180] Ethereum.org, 2025, “Introduction to smart contracts”, URL <https://ethereum.org/developers/docs/smart-contracts/>.
- [181] Handshake, 2025, “Handshake: Decentralized Naming and Certificate Authority”, URL <https://handshake.org/>.
- [182] Service, S. N., 2025, “Solana Name Service: Decentralized Domain Names on Solana”, URL <https://sns.id/>.
- [183] ENS, 2025, “How to Register a .eth name”, URL <https://support.ens.domains/en/articles/7882582-how-to-register-a-eth-name>.
- [184] ENS, 2025, “Name lifecycle”, URL <https://support.ens.domains/en/articles/8046877-name-lifecycle>.
- [185] Android, 2025, “Access from internal storage”, URL <https://developer.android.com/training/data-storage/app-specific>.
- [186] Spaulding, J., Nyang, D., and Mohaisen, A., 2017, “Understanding the effectiveness of typosquatting techniques”, Proceedings of the fifth ACM/IEEE Workshop on Hot Topics in Web Systems and Technologies, pp. 1–8.
- [187] Damerau, F. J., 1964, “A technique for computer detection and correction of spelling errors”, Communications of the ACM, **7**(3), pp. 171–176.
- [188] Kobel, V., 2025, “Generating a usable Ethereum wallet and its corresponding keys”, URL <https://kobl.one/blog/create-full-ethereum-key-pair-and-address/>.
- [189] Networks, P. A., 2025, “What Are Malicious Newly Registered Domains?”, URL <https://docs.netskope.com/en/rbi-category-definitions>.
- [190] Networks, P. A., 2025, “What Are Malicious Newly Registered Domains?”, URL <https://www.paloaltonetworks.com/cyberpedia/what-are-malicious-newly-registered-domains>.
- [191] “HSTS Preload List Submission”, URL <https://hstspreload.org/>.

- [192] (FCA), F. C. A., October 2024, “Over £27 million reported lost to crypto and forex investment scams”, <https://www.fca.org.uk/news/press-releases/over-27-million-reported-lost-crypto-and-forex-investment-scams>.
- [193] (FTC), F. T. C., October 2024, “Social media: a golden goose for scammers”, <https://www.ftc.gov/news-events/data-visualizations/data-spotlight/2023/10/social-media-golden-goose-scammers>.
- [194] Norton, October 2024, “12 Instagram scams to know and avoid in 2024”, <https://us.norton.com/blog/online-scams/instagram-scams>.
- [195] Mavusi, C. C., October 2024, “My Instagram account was hacked and I was tricked into promoting scam cryptocurrency”, <https://www.getsafonline.org/personal/blog-item/my-instagram-account-was-hacked-and-i-was-tricked-into-promoting-scam-cryptocurrency/>.
- [196] Xia, P., Wang, H., Zhang, B., Ji, R., Gao, B., Wu, L., Luo, X., and Xu, G., 2020, “Characterizing cryptocurrency exchange scams”, *Computers & Security*, **98**, p. 101993.
- [197] Muzammil, M., Wu, Z., Harisha, L., Kondracki, B., and Nikiforakis, N., 2024, “Typosquatting 3.0: Characterizing Squatting in Blockchain Naming Systems”, *Proceedings of the Symposium on Electronic Crime Research (eCrime)*.
- [198] et al., M. M., October 2024, “The Poorest Man in Babylon: Demonstration Video”, <https://www.youtube.com/watch?v=1-vG0JRVfUM>.
- [199] et. al, M. M., “Crimson”, <https://github.com/pragseclab/Crimson>.
- [200] Kondracki, B., So, J., and Nikiforakis, N., 2022, “Uninvited guests: Analyzing the identity and behavior of certificate transparency bots”, *USENIX Security Symposium*.
- [201] AlSabah, M., Nabeel, M., Boshmaf, Y., and Choo, E., 2022, “Content-agnostic detection of phishing domains using certificate transparency and passive dns”, *International Symposium on Research in Attacks, Intrusions and Defenses*.
- [202] Faslija, E., Eniger, H. F., and Prünster, B., 2019, “Phish-Hook: Detecting phishing certificates using certificate transparency logs”, *Security and Privacy in Communication Networks: 15th EAI International Conference*.
- [203] Kondracki, B., Azad, B. A., Starov, O., and Nikiforakis, N., 2021, “Catching transparent phish: Analyzing and detecting mitm phishing toolkits”, *ACM SIGSAC Conference on Computer and Communications Security*.

- [204] Google, July 2024, “Certificate Transparency in Chrome”, <https://googlechrome.github.io/CertificateTransparency/>.
- [205] CaliDog, October 2024, “certstream-server”, <https://github.com/CaliDog/certstream-server>.
- [206] keredson, July 2024, “Word Ninja”, <https://github.com/keredson/wordninja>.
- [207] URLScan, July 2024, “URLScan”, <https://urlscan.io/>.
- [208] IBM, Oct 2024, “What is stemming?”, <https://www.ibm.com/topics/stemming>.
- [209] Selenium, September 2024, “WebDriver”, <https://www.selenium.dev/documentation/webdriver/>.
- [210] tesseract ocr, July 2024, “tesseract”, <https://github.com/tesseract-ocr/tesseract>.
- [211] Liu, P., Liu, J., Fu, L., Lu, K., Xia, Y., Zhang, X., Chen, W., Weng, H., Ji, S., and Wang, W., 2024, “Exploring {ChatGPT’s} Capabilities on Vulnerability Management”, USENIX Security Symposium.
- [212] Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., and Rass, S., 2024, “{PentestGPT}: Evaluating and Harnessing Large Language Models for Automated Penetration Testing”, USENIX Security Symposium.
- [213] Haroon, R. and Dogar, F., 2024, “Twips: A large language model powered texting application to simplify conversational nuances for autistic users”, International ACM SIGACCESS Conference on Computers and Accessibility.
- [214] Liu, R., Lin, Y., Teoh, X., Liu, G., Huang, Z., and Dong, J. S., 2024, “Less Defined Knowledge and More True Alarms: Reference-based Phishing Detection without a Pre-defined Reference List”, USENIX Security Symposium.
- [215] Li, Y., Huang, C., Deng, S., Lock, M. L., Cao, T., Oo, N., Hooi, B., and Lim, H. W., 2024, “KnowPhish: Large Language Models Meet Multimodal Knowledge Graphs for Enhancing Reference-Based Phishing Detection”, arXiv preprint arXiv:2403.02253.
- [216] Martin, N., Faisal, A. B., Eltigani, H., Haroon, R., Lamelas, S., and Dogar, F., 2024, “LLMProxy: Reducing Cost to Access Large Language Models”, arXiv preprint arXiv:2410.11857.

- [217] Kim, Y., Aamir, Z., Singh, M., Boorboor, S., Mueller, K., and Kaufman, A. E., 2025, “Explainable XR: Understanding User Behaviors of XR Environments using LLM-assisted Analytics Framework”, *IEEE Transactions on Visualization and Computer Graphics*.
- [218] Mailinator, July 2024, “Mailinator”, <https://www.mailinator.com/>.
- [219] Lab, M., September 2024, “iocsearcher”, <https://github.com/malicialab/iocsearcher>.
- [220] Drakonakis, K., Ioannidis, S., and Polakis, J., 2020, “The cookie hunter: Automated black-box auditing for web authentication and authorization flaws”, *ACM SIGSAC Conference on Computer and Communications Security*.
- [221] Caballero, J., Gomez, G., Matic, S., Sánchez, G., Sebastián, S., and Villacañas, A., 2023, “The rise of goodfatr: A novel accuracy comparison methodology for indicator extraction tools”, *Future Generation Computer Systems*.
- [222] Sharma, A. K., October 2024, “Anup Kumar Sharma October 23, 2023 at 8:56 am”, <https://www.scam-detector.com/crypto-info/>.
- [223] Educative.io, October 2024, “How to find similarity between two words using NLP”, <https://www.educative.io/answers/how-to-find-similarity-between-two-words-using-nlp>.
- [224] Blockstream, September 2024, “Bitcoin Explorer - Blockstream.info”, <https://github.com/Blockstream/esplora/blob/master/API.md>.
- [225] Gomez, G., van Liebergen, K., and Caballero, J., 2023, “Cybercrime bitcoin revenue estimations: Quantifying the impact of methodology and coverage”, *ACM SIGSAC Conference on Computer and Communications Security*.
- [226] Coinbase, October 2024, “coinbase”, <https://www.coinbase.com/>.
- [227] Binance, October 2024, “binance”, <https://www.binance.com/>.
- [228] CoinCarp, September 2024, “Bitcoin(BTC) Exchange Wallet Address List and Balance Change — CoinCarp”, <https://www.coincarp.com/currencies/bitcoin/exchange-wallets/>.
- [229] VirusTotal, September 2024, “VirusTotal API v3 Overview”, <https://docs.virustotal.com/reference/overview>.
- [230] SEAL-ISAC, October 2024, “An ISAC Tailor-Made for Crypto, Blockchain, and Web3.”, <https://isac.securityalliance.org/>.

- [231] WalletGuard, September 2024, “Protect your Crypto — Wallet Guard”, URL <https://www.walletguard.app/>.
- [232] Phishfort, October 2024, “Protect your brand and revenue from attacks”, <https://www.phishfort.com/>.
- [233] Chainpatrol, October 2024, “Real-time Brand Protection for Leading Web3 Companies”, <https://chainpatrol.io/>.
- [234] AWS, 2025, “What is Web3?”, URL <https://aws.amazon.com/what-is/web3/>.
- [235] Cybersecurity and Agency, I. S., 2024, “ENCRYPTED DNS IMPLEMENTATION GUIDANCE”, URL https://www.cisa.gov/sites/default/files/2024-05/Encrypted%20DNS%20Implementation%20Guidance_508c.pdf.
- [236] (NSA), N. S. A., 2021, “Adopting Encrypted DNS in Enterprise Environments”, URL https://media.defense.gov/2021/Jan/14/2002564889/-1/-1/0/CSLADOPTING_ENCRYPTED_DNS_U_OO_102904.21.PDF.
- [237] Lee, J., Mohaisen, D., and Kang, M. S., 2024, “Measuring DNS-over-HTTPS Downgrades: Prevalence, Techniques, and Bypass Strategies”, Proceedings of the ACM on Networking.
- [238] PragSecLab, 2025, “New Trains, Same Rails: Fingerprinting Cryptocurrency Software via Network Requests”, URL <https://pragseclab.github.io/DNS-Web3/>.
- [239] Müller, M. and Žunič, G., “Browser Use: Enable AI to control your browser”, URL <https://github.com/browser-use/browser-use>.
- [240] Rana, S., 2025, “Docker: What’s under the hood?”, URL <https://blog.kubesimplify.com/docker-networking-demystified>.
- [241] Sentry, 2025, “Organization Subdomains in DSNs”, URL <https://forum.sentry.io/t/organization-subdomains-in-dsns/9360>.
- [242] Mozilla, 2025, “Public Suffix List”, URL <https://publicsuffix.org/>.
- [243] DomainTools, 2025, “DomainTools Technical Documentation”, URL <https://docs.domaintools.com/dnsdb/>.
- [244] Cymru, T., 2025, “IP to ASN Mapping Service”, URL <https://www.team-cymru.com/ip-asn-mapping>.
- [245] Anderson, B. B., Kirwan, C. B., Jenkins, J. L., Eargle, D., Howard, S., and Vance, A., 2015, “How polymorphic warnings reduce habituation in the brain: Insights from an fMRI study”, Proceedings of the annual ACM conference on human factors in computing systems.

- [246] Bravo-Lillo, C., Cranor, L. F., Downs, J., and Komanduri, S., 2010, “Bridging the gap in computer security warnings: A mental model approach”, IEEE Security & Privacy.
- [247] Akhawe, D. and Felt, A. P., 2013, “Alice in warningland: a {Large-Scale} field study of browser security warning effectiveness”, USENIX Security Symposium.
- [248] Sunshine, J., Egelman, S., Almuhiemedi, H., Atri, N., and Cranor, L. F., 2009, “Crying wolf: An empirical study of ssl warning effectiveness.”, USENIX Security Symposium.